

PRIVACY ENGINEERING · A FIELD GUIDE IN SIX CHAPTERS

Every arrow is a decision.

A privacy policy is a promise written in human language. Privacy engineering is the machinery that keeps it true after the data starts moving. Follow one person's data through a company that doesn't exist, then into her home, where some arrows open the door. Every copy, join, inference, deletion and unlock turns out to be a decision.

PADDY IYER PUBLISHED 26 SEPTEMBER 2026 REVISED 30 SEPTEMBER 2026 6 CHAPTERS 31 SCENES

PROLOGUE · THE PROMISE

Privacy engineering turns **promises** into **mechanisms**.

THE ARGUMENT OF THIS GUIDE

A privacy policy is a promise written in human language. Privacy engineering translates that promise into architecture, controls, runtime behaviour and evidence. Every movement, copy, join, inference, retention decision and deletion failure is an engineering decision — whether the organization made it consciously or inherited it by default.

And it does not stop at the application boundary. The home, the car, the network and the household are data systems too — and some of their arrows don't just move information. They open doors, reveal who is home, and make things happen in rooms. Chapter 5 follows Dana there.

On 3 September, **Dana** signs up for Northstar, an online shop with a payments wallet, a health app called Pulse and an assistant called Nova. The privacy notice she scrolls past says: *"We use your data to fulfil your orders and improve your experience. We never sell your data. Delete your account at any time and we'll delete your data."* A lawyer wrote it in an afternoon. It is a good promise.

Two months later, when Dana asks to be forgotten, the request has to reach **26 systems**. Nobody decided that number. It is what the promise became after the data started moving.

SYNTHETIC DATA Dana and Northstar are fictional. Northstar's systems, vendors and numbers are the same synthetic dataset that powers the [Privacy Command Center](#), so the two can be read side by side.

01

Promise

"We delete your data when you close your account."

02

Architecture

Which systems hold it, and how they connect.

03

Data

The actual fields, copies and identifiers.

04

Control

The job, gate or check that enforces it.

05

Evidence

Logs and tests that show the control ran.

06

Runtime

What production does at 3 a.m. on a Sunday.

A promise fails at whichever link nobody owns. So the discipline has three jobs, and every scene below names which one it is doing.

HAT 01 · BEFORE
LAUNCH

Reviewer

Reads designs before launch and finds the exposure nobody drew on the whiteboard.

Output: findings,
required changes, a
risk rating, a
signed decision

HAT 02 · IN THE
PLATFORM

Builder

Ships the controls: consent propagation, retention, deletion, purpose enforcement, identity isolation, access control, privacy-enhancing technologies, deployment gates.

Output: libraries,
platforms, deploy
gates

HAT 03 · IN
PRODUCTION

Auditor

Checks what really runs — logs, joins, retention and runtime enforcement — not what the design said or the policy says.

Output: invariants,
dashboards, incident
fixes

Lawyers write what must be true. Product decides what users should feel. The privacy engineer makes the system actually behave that way. **The job is not saying no. It is finding the design where the product works and the exposure shrinks — and writing down the trade-off when it doesn't.**

How to read this guide

Four layers

The *executive path* reads each scene's brief (about 13 minutes). The *full path* adds the narrative and the figures. *Builder notes* (►) hold schemas, pseudocode and control patterns. *Field notes* hold the supporting cases. The field kit is the part to keep.

Every figure answers five questions

What you can change, what changes in the system, what changes for the people involved, which control prevents the problem, and what evidence would prove the control worked. Each figure has a reset, a link to its current state, keyboard support and a written reading of what it shows. Without JavaScript, and in print, each becomes a static sequence or table.

What each label means

REAL CASE A documented event, cited beside the claim.

HISTORICAL EXAMPLE Documented, but old; the lesson outlived the details.

SIMPLIFIED MODEL Arithmetic to compare designs, not to predict harm.

SYNTHETIC DATA Northstar's invented dataset.

ILLUSTRATIVE SCENARIO Invented people and events that show a mechanism.

ANECDOTE A story as told by one person; not verified.

LEGAL UNCERTAINTY Law varies by place and changes. Nothing here is legal advice.

DANA'S AUTUMN AT NORTHSTAR

ILLUSTRATIVE SCENARIO

Sep 3 Signs up; says yes to personalised ads	Sep 10 Buys a pregnancy test on her phone	Sep 18 Says no to personalised ads, at 01:58	Sep 20 Her house disarms itself while nobody is home
Sep 22 Asks Nova which painkillers are safe	Sep 23 The kitchen reads out her appointment	Oct 3 Opens her clinic portal on library Wi-Fi	Oct 12 An old password of hers leaks
Oct 14 Theo hands his old phone to Mira	Oct 16 A browser extension she forgot about updates itself	Oct 20 The internet goes down; a deleted code still works	Oct 22 Her payment is declined by a model
Oct 25 Asks what Northstar holds about her	Nov 2 Asks Northstar to forget her		

CHAPTER 1 OF 6

See

What data becomes when ordinary identifiers, histories and inferences meet.

SITUATION

Dana shops on her phone, and once buys something she tells no one about.

SYSTEM

Identifiers collected for good reasons are joined; documents keep their past; models infer.

CONSEQUENCE

A profile nobody designed: routine, household, pregnancy — some of it wrong.

CONTROL

Scoped identifiers, uniqueness tests, history you can purge, accuracy you can correct.

EVIDENCE

An inventory of every inference about a person, with its source and join path.

01 SEE · IDENTITY

What could a company know about Dana without her name?

IN BRIEF

Five ordinary identifiers, each collected for a good reason, become a profile the moment they can meet: Dana's routine, her late-night pharmacy visits, a likely pregnancy. The decision is not whether to collect an email; it is **which identifiers may join, and for what.**

Nobody at Northstar needs Dana's name. Watch what happens when five ordinary identifiers — each collected for a perfectly reasonable reason — are allowed to meet.

The email arrived at sign-up. The device ID came with the app. The advertising ID came with an SDK. The payment token is how checkout works. The location ping powers “stores near you”. None of them is secret. **The harm is not in any one of them. It is in the join.**

FIG. 01 Five identifiers, zero names, one person ILLUSTRATIVE SCENARIO

WHICH INFERENCES ABOUT DANA EXIST UNDER EACH JOIN POLICY

INFERENCE (WHAT IT NEEDS)	EVERYTHING JOINS	PURPOSE-SCOPED IDS	SCOPED + NO SENSITIVE INFERENCE
Leaves home at 7:40 on weekdays (location × time)	Yes	Yes	Yes
Visits a pharmacy after 11 p.m. (payment × location)	Yes	No — needs a cross-purpose join	No — sensitive inference blocked
Likely pregnant (basket × timing × account)	Yes	Yes	No — sensitive inference blocked
Household of three (devices × one account × home IP)	Yes	No — needs a cross-purpose join	No — needs a cross-purpose join

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
The join policy: everything joins, identifiers scoped to a purpose, or scoped plus a ban on sensitive inference.	Whether a global ID travels with every event, and whether a team can join tables across purposes.	Four facts she never shared, down to one she might expect: that the app knows when she leaves home.	Purpose-scoped identifiers; joins across purposes only through a reviewed, logged path; no sensitive inference for marketing.	A join registry (which identifiers may meet, and who approved it) and a daily scan for joins that aren't on it.

Collected, derived, inferred.

“We only use what customers give us” is almost never true, because most of what a company holds about a person was never given. It is useful to sort it by where it came from, because each kind fails differently: **provided** data is what the person typed; **observed** data is what the system recorded while they used it; **derived** data is computed from those; **inferred** data is a guess about them. Inference counts as collection — and it can be wrong.

WHAT NORTHSTAR HOLDS ABOUT DANA, BY ORIGIN

WHAT	ORIGIN	TIER	KIND	JOINS NEEDED TO KNOW IT
Name, email, postal address, date of birth	provided	T3	fact	Email → Customer / Account ID
Phone number (given for 2FA)	provided	T2	fact	Customer / Account ID → Phone number
Every purchase for 7 years, with amounts	observed	T3	fact	Customer / Account ID
Where they stood at each purchase (precise)	observed	T3	fact	Customer / Account ID → Device ID
Home and work locations	inferred	T3	inference	Customer / Account ID
18 months of movement history	observed	T3	fact	Customer / Account ID
"Likely a parent" (from basket)	inferred	T3	inference	Customer / Account ID
Fraud risk band	derived	T2	inference	Customer / Account ID → Device ID → Device fingerprint
Which Pulse screens they open (cycle, symptoms)	observed	T4	fact	Device ID → Pulse user ID

WHAT	ORIGIN	TIER	KIND	JOINS NEEDED TO KNOW IT
"Health interest" advertising segment	inferred	T4	inference	Device ID → Advertising ID (MAID)
What they asked the assistant (400 days)	provided	T3	fact	Customer / Account ID → Nova conversation ID
Health topics mentioned to the assistant	inferred	T4	inference	Customer / Account ID
Their support conversation, verbatim	provided	T3	fact	Email
Websites visited via the browser extension	observed	T3	fact	Customer / Account ID
When they reset their password (from logs)	observed	T2	fact	Email
Linked advertising ID across apps	derived	T2	inference	Customer / Account ID → Advertising ID (MAID)
Their messages	provided	T3	unknowable	—

SYNTHETIC DATA

Northstar’s view of Dana, from the Command Center’s *One Person* page. The last column shows what Northstar would need to join to know it.

FIELD NOTE The purchase model that predicted pregnancy

REAL CASE

In February 2012 the *New York Times Magazine* reported that a Target statistician had built a “pregnancy prediction” score from about 25 products, able to estimate a due date. [NYT Magazine, Feb 2012](#) The article’s best-known story — an angry father who learned from coupons that his daughter was pregnant — came from an unnamed source and was never confirmed by Target.

ANECDOTE

 The mechanism doesn’t need the anecdote: a basket is enough to infer a sensitive fact, and an inference is data about a person.

CORNER CASE · INFERENCE AND SHARED SCREENS

Nothing leaked. The family TV told them anyway.

On 10 September Dana buys a pregnancy test on her own phone, late, on purpose. A home router can join one person’s private purchase to every screen in the house — while every system works exactly as designed.

- SEP 10 22:10 **Dana buys a pregnancy test on her phone** She hasn’t told anyone. She bought it on her own phone, late, on purpose. *It’s between the shop and everything it links to.*
- SEP 10 22:11 **22:11 — the model files her as “likely expecting”** One purchase becomes a sensitive fact she never shared. Inference counts as collection. *You used what she gave to create what she didn’t.*
- SEP 11 01:00 **01:00 — the graph links the family’s screens to her** Same home IP, same evenings: the family iPad and the living-room TV join her profile. *Cross-device moves a secret from one screen to every screen.*

- 4. SEP 11 07:45 **07:45 — the family iPad lights up** It's signed into her account. The lock screen names the product to whoever walks past. **On a shared device, the user is whoever is looking.**
- 5. SEP 11 20:30 **20:30 — movie night, and an ad for prenatal vitamins** What one device revealed now follows her to the biggest screen in the house. **An ad can be an announcement.**
- 6. SEP 11 20:31 **"Dana — is there something you want to tell us?"** She didn't tell her family. The system did. Two screens, 4 people, one sentence she didn't get to say herself. **Context collapse doesn't need a breach.**

WHERE IT ENDS — AS IT USUALLY GOES, AND WITH EVERY HABIT ON

COUNTER	AS IT USUALLY GOES	WITH THE HABITS
shared screens that revealed it	2	0
people who could learn before she told them	4	0
things inferred about her that she never said	2	0

The habits:

- Generic lock-screen text.** “Your order is out for delivery” — never the product.
- No sensitive inferences for ads.** Health and pregnancy categories are excluded from targeting.
- No household linking.** Shared IP and evening timing never join devices into one person.
- Family profile on shared devices.** The family iPad isn't signed in as Dana.

ILLUSTRATIVE SCENARIO A composite, not any specific company. Sensitive inferences such as health or pregnancy carry special rules in many jurisdictions. **LEGAL UNCERTAINTY**

In the Command Center: **One Person** — every fact and inference Northstar holds about Dana, with the join path that produced it → —paddyspeaks.com/privacy-command-center/v10/#/explore/person

TAKEAWAY
Personal data is not a column. It is what the columns become when they are joined.

02 SEE · LINKABILITY

Two harmless tables name a stranger.

IN BRIEF

Removing names does not make data anonymous: ZIP code, birth date and sex single out most people, so a “de-identified” table joined to a public list names them. The review question: **can we use a weaker, scoped or rotating identifier — or none?**

On the left, a clinic dataset with the names removed — the textbook idea of “de-identified”. On the right, a public list of the kind many places publish. Neither table, alone, tells you who has which diagnosis. Now join them on the three columns they share.

FIG. 02A A join on three quasi-identifiers ILLUSTRATIVE SCENARIO

BEFORE AND AFTER THE JOIN (FICTIONAL PEOPLE)

STATE	WHAT ANYONE CAN LEARN
Clinic table alone	Three diagnoses, each with a ZIP, birth date and sex — no names.
Public list alone	Three names, each with a ZIP, birth date and sex — no health data.
Joined on ZIP, birth date, sex	R. Alvarez · 02139 · 1961-07-31 · F → depression. One exact match; a name is back on a diagnosis.

YOU CHANGE	THE SYSTEM	FOR THE PERSON	THE CONTROL	THE EVIDENCE
Whether two datasets are joined on the columns they share.	A release or export that kept quasi-identifiers because they “aren’t names”.	A diagnosis attached to their name by anyone holding a public list.	Generalise quasi-identifiers (age band, 3-digit ZIP), suppress small groups, or release with differential privacy.	A uniqueness scan before every release: the share of records unique on any combination of quasi-identifiers, recorded with the release.

How many columns does it take to find one person?

In 2000, Latanya Sweeney estimated that about **87% of the US population** was likely to be unique on just three things: five-digit ZIP code, gender and full date of birth. [Sweeney, 2000](#) HISTORICAL EXAMPLE Treat the number with care: it was an estimate of *uniqueness* from 1990 census data, not a count of people re-identified, and a 2006 re-analysis on 2000 census data put it nearer **63%**. [Golle, 2006](#) Either way, most people are one lookup away. Try it on a crowd of 1,000 synthetic people — your target is in there somewhere.

FIG. 02B Singling out one person in a crowd of 1,000 SYNTHETIC DATA

HOW MANY OF 1,000 SYNTHETIC PEOPLE MATCH WHAT YOU KNOW

WHAT YOU KNOW	PEOPLE WHO MATCH
Nothing	1,000
ZIP code	343
+ sex	176
+ birth year	4
+ birthday	1 — the target, identified

YOU CHANGE	THE SYSTEM	FOR THE PERSON	THE CONTROL	THE EVIDENCE
Which ordinary attributes an attacker knows.	A dataset that keeps those attributes at full precision.	The crowd they were hiding in shrinks to one.	Keep the coarsest value the feature needs: birth year not date, region not ZIP.	The smallest group size in each released table (k), checked and recorded before release.

So choose the weakest identifier that still works.

Identifiers are not equal. A global, durable one — an email, a phone number, a government ID — links a person across every system that sees it, and **hashing an email does not change that**: the same email hashes the same way everywhere. Move right along the spectrum whenever the feature allows.

FIG. 02C

The identifier spectrum

SIMPLIFIED MODEL

IDENTIFIER CLASSES, FROM LINKS EVERYTHING TO LINKS NOTHING

CLASS	EXAMPLE	LINKS A PERSON ACROSS	USE WHEN
Global durable	Email, phone number, government ID — or a hash of any of them	Every system that sees it, for years	Only when the feature is identity itself: login, billing, legal.
Cross-app	A device-level advertising ID	Every app on the device that can read it	Rarely justified outside advertising, and often requires opt-in.
Per-vendor	An ID scoped to one company’s apps	Everything that one company does	Internal analytics across a product family.
Purpose-scoped	reminders_id — minted for one purpose	One purpose; useless to every other	Most features. Mint one per purpose and refuse joins.
Rotating	A token that changes daily	One person within one window	Measurement that needs repeat visits, but not forever.
Ephemeral	A per-session or per-request nonce	One session, then nothing	Rate limiting, abuse checks, a single transaction.
None	Aggregates with small groups suppressed	Nothing — no person to link	Dashboards, reporting, most analytics questions.

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
The class of identifier a feature uses.	How many systems, companies and years a single value can connect.	Whether her reorder reminders can be tied to her ad profile, her health app, her household.	Mint identifiers per purpose; rotate where repeat visits matter only for a window; refuse cross-purpose joins by default.	An identifier registry with each ID’s scope and lifetime, and a scan for any value used outside it.

FIELD NOTES Five failures every privacy engineer should know — and the assumption each broke

2006 · REAL CASE

AOL search logs

AOL released about 20 million search queries from some 650,000 users, keyed by number. Reporters used one user’s queries to find her, then confirmed it with her.
[NYT, Aug 2006](#)

“Removing names makes data anonymous.”

2006–08 · REAL CASE

Netflix Prize

Researchers showed that about eight movie ratings with rough dates single out almost every subscriber record, and matched a small sample to public IMDb reviews.
[Narayanan & Shmatikov, 2008](#)

“Data nobody else has is safe to publish.”

2012 · REPORTED

Retail inference

A retailer’s purchase model reportedly scored the likelihood of pregnancy from about 25 products.
[NYT Magazine, 2012](#)

“We only use what customers gave us.”

2018 · REAL CASE

Fitness heatmap

A published global activity heatmap outlined military bases and patrol routes. Nothing was hacked; it had been public for two months before anyone noticed.

[Guardian, Jan 2018](#)

“Aggregates can’t reveal anything sensitive.”

2018 · REAL CASE

Cambridge Analytica

A quiz app used friend permissions to collect data on people who never used it — up to 87 million, by Facebook’s own upper estimate.

[Facebook, Apr 2018](#)

[FTC, Dec 2019](#)

“One user’s consent covers their friends.”

In the Command Center: **Identities** — every Northstar identifier, its scope, and the joins that connect them → — paddyspeaks.com/privacy-command-center/v10/#/explore/identities

TAKEAWAY

“We removed the names” is not anonymization. Linkability is the risk; identifiers are the lever.

03 SEE · HISTORY

“Delete” is a word, not a mechanism.

IN BRIEF

Tools that remember edits keep what you deleted. In a shared document, permission to edit the present is permission to read the past. **Share clean copies, give history a retention clock, and treat anything ever exposed as exposed.**

Before Dana’s data, Northstar’s own. On **Monday** a manager pastes a salary sheet into a planning doc: forty names, forty numbers. On **Tuesday** she deletes the table. The doc looks safe. On **Friday** a contractor is added as an Editor. At **4 p.m.** the contractor opens *File > Version history > Monday*. Every name, every number.

Google Docs keeps a version history — being able to rewind is the feature. People with edit access can open it; viewers and commenters cannot. [Google Docs Editors Help](#) Scrub the week, then change who is looking.

FIG. 03 One week in a shared document

ILLUSTRATIVE SCENARIO

THE WEEK, AND WHO CAN OPEN THE PAST ON FRIDAY AT 4 P.M.

MOMENT	WHAT THE PAGE SHOWS	WHAT VERSION HISTORY HOLDS
Mon 9:03	Salary sheet pasted in: 40 names, 40 numbers	Monday's version
Tue 10:12	Table deleted — the doc looks safe	Monday's version, still there
Fri	A contractor is added	Unchanged
Fri 4 p.m. · Owner or Editor	Opens Version history > Monday	Reads all 40 salaries
Fri 4 p.m. · Commenter or Viewer	Sees only the present	Not available to them
Fri 4 p.m. · clean-room fix	Was given a fresh copy	History starts today — nothing to see

YOU CHANGE

The day, the role you grant, and whether you share a clean copy.

THE SYSTEM

An editor's permissions include every past version, from before they joined.

FOR THE PEOPLE

Forty colleagues' salaries read by an outsider on a Friday afternoon.

THE CONTROL

Least role (Commenter to suggest, Viewer to read); share a copy, not the original; retire the original.

THE EVIDENCE

A sharing audit: external editors on documents that ever held personal data, and the clean-copy rate for external shares.

!

You can't remove one old version

No one can delete a single version of a native Google Doc. On some Workspace editions an owner can delete a version together with all older ones; consumer accounts can't delete versions at all. [Google Help](#)

1

Make a copy

File > Make a copy. The copy's history starts today.

2

Share the copy, not the original

Viewers and commenters never see history at all.

3

Retire the original

Drive empties trash after 30 days; your organization's retention rules may hold it longer. [Google Help](#)

Permission to edit the present is **permission to read the past.**

Docs are the loudest example. Not the only one.

Every tool that remembers is a leak waiting for the wrong reader. Eight places “deleted” data keeps living:

01 · VERSION HISTORY

Docs, Sheets, wikis

Every editor can rewind.

02 · HIDDEN METADATA

Word files

The UK's 2003 Iraq dossier carried a revision log with four civil-service usernames, later matched to officials.

[R. M. Smith, 2003](#)

HISTORICAL EXAMPLE

03 · FAKE REDACTION

PDF black boxes

A January 2019 filing in *US v. Manafort* put black boxes over text that could still be copied, revealing prosecutors' allegations. [BuzzFeed News, 2019](#)

04 · CODE HISTORY

Git

A password committed and then deleted lives on in every clone and fork. Rotate it.

05 · SENT MESSAGES

Email & chat

Edits, recalls and unsends rarely reach copies already in inboxes, exports and backups.

06 · TRASH & BACKUPS

Drives & servers

Recycle bins, snapshots and legal holds keep “deleted” files for weeks or years.

07 · INDEXES & CACHES

Search & previews

Search indexes, previews and thumbnails keep their own copy of what you removed.

08 · AI TOOLS

Assistants & retrieval

Conversation logs, memory rows, vector indexes and training sets can each hold what the source no longer does. [Scene 17](#) takes them apart.

BUILDER NOTE

Six design rules for engineers who build history — and a one-minute check for everyone else

1. **Separate the permissions.** Seeing today's document shouldn't automatically mean seeing every past version.
2. **Redact verifiably, across time.** A redaction must reach old versions, backups and indexes — and leave a receipt that proves it did.
3. **Share snapshots, not live files.** Send a flattened copy to outsiders; keep the working draft inside.
4. **Give history a retention clock.** Old versions are data too: expire them like logs.
5. **Scan the past on share.** Before a new person gets access, check old versions for secrets and personal data.
6. **Treat exposure as permanent.** A leaked key or password is burned. Rotate it — deleting isn't enough.

BEFORE YOU HIT SHARE

- Does this person need Editor, or just Viewer?

- Is the link set to “anyone”?
- Was anything sensitive ever in this file?
- Are resolved comments hiding secrets?
- Would a clean copy be safer?

CORNER CASE · THE INVISIBLE TIMELINE

You think you shared a page. You shared a timeline.

On 10 September an analyst pastes a customer export — Dana's row among 1,284 — into a doc to build a summary, then cleans it up. Two days later she shares it with Tom. Nobody does anything wicked. Follow the file for five days, then replay the week with four small habits switched on.

1. SEP 10 09:05 **You paste the customer export to build a summary** 1,284 rows — names, emails, phones, plans — go straight from the CRM into a working doc. It feels temporary. Every autosave makes it a version. **Scratch docs keep permanent history.**
2. SEP 10 16:20 **Version 12: the table becomes three numbers** You replace the rows with counts and percentages. The page is clean. Version 11, saved at 16:05, still holds every row. **You removed it from the page. Version 11 kept it.**
3. SEP 12 10:00 **Sep 12: Tom joins as an Editor** He only needs to tidy the wording. As an Editor he can open version history back to Sep 10 — version 11 included. **Editor access includes every past version.**
4. SEP 12 10:40 **10:40 — Tom clicks “Restore this version” on v11** Hunting for an older opening paragraph, he opens version 11 and restores it to copy from. The raw customer table is back on the live page — for everyone with access. **Any Editor can make an old version the current one.**
5. SEP 12 10:42 **10:42 — a meeting pulls Tom away** The restore is one line in version history. Nobody is asked to confirm it, and nobody looks at the page again for three hours. **A restore looks like any other edit.**
6. SEP 12 14:05 **14:05 — Tom shares “the latest” with Mike** Back at his desk, Tom adds Mike as an Editor. Mike sees the customer table on the page itself — he doesn't even need history. **By default an Editor can share like an owner.**
7. SEP 13 09:30 **Sep 13 — Mike sends the agency a live link** They open it for the flyer copy. The table of 1,284 customers is on page one, and their designer makes a copy to work offline. **It left the company — as a copy nobody here can recall.**
8. SEP 15 11:00 **You notice, restore version 14 and remove Mike and the agency** That works going forward only. The agency's copy has its own owner now. Customer data reached a third party, so this may be a notifiable breach: bring in your privacy team today — under GDPR the regulator clock is 72 hours from when you become aware. **Restore and revoke work forward. Exposure doesn't rewind.**

WHERE IT ENDS — AS IT USUALLY GOES, AND WITH EVERY HABIT ON

COUNTER	AS IT USUALLY GOES	WITH THE HABITS
people besides you who can see the customer list	1	0
people who got in without you deciding	2	0
copies of the list you can't recall	1	0
customers exposed outside the company	1,284	0

The habits:

Tom gets Commenter. He was fixing wording. Commenters can suggest edits but can't open version history — so they can't restore from it.

Break the timeline. Share File > Make a copy. The copy's history starts today; version 11 isn't in it.

Lock the gear ⚙️. Untick *Editors can change permissions and share* and the viewers' download / print / copy option.

Flatten for outsiders. The agency gets File > Download > PDF from you — not a live link.

ILLUSTRATIVE SCENARIO People, rows and figures are invented. Menu names follow Google Docs; other editors have equivalents. A PDF can still carry a title or author in its properties, and nothing stops a screenshot — these habits shrink exposure, they don't erase it. Whether an incident is notifiable is a legal call: ask your privacy team, early. LEGAL UNCERTAINTY

TAKEAWAY

Delete removes it from your view. History keeps it for everyone else. If it was ever in the document, assume it's still in the document.

04 SEE · ACCURACY

Wrong data hurts as surely as leaked data.

IN BRIEF

Wrong data harms as surely as leaked data. Dana's payment is declined because an identity job merged her with her partner's device. **The more a use decides, the more it needs a merge threshold, human review, an explanation, a correction path and an appeal.**

On 22 October Dana tries to pay for her vitamins. *Declined*. Her account is restricted “for your security”. What happened is ordinary: Northstar's identity job saw the same home IP and overlapping evenings, merged her profile with her partner's old tablet at 0.71 confidence, and the fraud model read his chargebacks as hers.

Nobody leaked anything. The data was simply wrong about her, and a system acted on it. Choose where the wrong inference is used, then choose the safeguards.

FIG. 04 The same wrong merge, five different uses SIMPLIFIED MODEL

THE SAME WRONG MERGE, USED FIVE WAYS

USE	HARM IF WRONG	WHAT HAPPENS TO DANA	SAFEGUARDS THIS USE NEEDS
Ad segment	Low	Dana sees irrelevant ads for her partner’s hobbies.	A correction path, as courtesy
Recommendations	Low	Her home page fills with someone else’s taste. Annoying, visible, easy to shrug off.	Corrections propagate
Fraud decline	High	Her card is declined at checkout and her account is restricted. Nobody tells her why.	Merge only above 0.9 confidence; A person reviews adverse actions; Say which data drove it; Corrections propagate; An appeal a human decides
Pay-later eligibility	High	Northstar Pay refuses her instalment plan. The reason is her partner’s missed payment.	Merge only above 0.9 confidence; A person reviews adverse actions; Say which data drove it; Corrections propagate; An appeal a human decides
Hiring screen (a partner’s use)	Severe	A “risk” flag sold on to a screening vendor follows her into a job application she never connects to a shop.	Merge only above 0.9 confidence; A person reviews adverse actions; Say which data drove it; Corrections propagate; An appeal a human decides; Risk scores never leave for another purpose

With every needed safeguard in place, the harm of each high-stakes use falls to: Ad segment — low; Recommendations — low; Fraud decline — low; Pay-later eligibility — low; Hiring screen (a partner’s use) — low. Illustrative ranking.

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
Where a probabilistic inference is used, and which safeguards surround it.	An identity graph that merges on weak evidence, feeding models that decide.	From irrelevant ads to a refused payment she can’t explain — or a flag that follows her into a job application.	Stakes-based rules: a merge threshold, human review of adverse actions, explanations tied to inputs, corrections that propagate, an appeal a person decides.	Decision logs with inputs and model version; correction receipts from every system; appeal outcomes and time to decide.

The severity scale is an illustrative ranking of consequences, not a prediction of harm to any real person.

FIELD NOTES When automated inaccuracy became a public failure

REAL CASE **Robodebt, Australia.** From 2015 to 2019 a government scheme averaged annual income across fortnights to raise welfare debts automatically. A Royal Commission found in 2023 that income averaging, as used, neither produced accurate results nor complied with the law. [Royal Commission, 2023](#)

REAL CASE **Childcare benefits, the Netherlands.** The Dutch data protection authority fined the tax administration €2.75 million in 2021 for processing (dual) nationality in a way it found discriminatory while assessing benefit applications. [Autoriteit Persoonsgegevens, 2021](#)

REAL CASE **Tenant screening, US.** In 2023 the FTC and CFPB settled charges that TransUnion’s rental-screening business failed to ensure the accuracy of eviction records in its reports: \$15 million. [FTC, Oct 2023](#)

LEGAL UNCERTAINTY

Accuracy is a principle in the GDPR (Art. 5(1)(d)) with a right to rectification (Art. 16) and, for decisions based solely on automated processing with legal or similarly significant effects, a right to human intervention and to contest (Art. 22). [GDPR](#) In the US, consumer reporting agencies must follow reasonable procedures to assure maximum possible accuracy. [FCRA §1681e\(b\)](#) Whether a given model counts as either depends on the facts.

TAKEAWAY

An inference is a claim about a person. The more it decides, the more it must be checkable, correctable and contestable.

CHAPTER 1 · EVIDENCE**What proves you can **see** your data**

- An inventory of every fact *and inference* held about a person, with its source, tier and join path.
- A uniqueness report (smallest group size) recorded with every data release.
- A join registry: which identifiers may meet, for which purpose, approved by whom — and a daily scan for joins that aren't on it.
- A sharing audit of documents that ever held personal data, with their external editors.
- Correction receipts and appeal outcomes for decisions made on inferred data.

CHAPTER 2 OF 6

Decide

Why the data exists, what people expect, which purpose permits the use, and which trade-off is being made.

SITUATION

Northstar wants to remind Dana when she is running low on vitamins.

SYSTEM

Order events fan out to a bus, a warehouse, a marketing tool and a vendor.

CONSEQUENCE

Every arrow is a copy with a reason, a clock and a reader — most chosen by default.

CONTROL

A fixed review, purpose checked at use, harm traced to people, trade-offs written down.

EVIDENCE

A decision record per arrow: owner, approver, expiry, and the proof each condition holds.

05 DECIDE · THE REVIEW

Eight questions. Every feature.

IN BRIEF

A short, fixed review — value, data, identity, flow, access, time, misuse, reduce — asked the same way for every feature, turns opinion into an instrument. Dana's reorder reminder ships **with four conditions**. Tier data by what it reveals, not by column type.

Here is the review, applied to one ordinary feature: a **smart reorder reminder** that nudges Dana when she is probably running low on something she buys regularly. Each question comes with the red flag to listen for.

FIG. 05 The eight review questions, applied to the reorder reminder

ILLUSTRATIVE SCENARIO

THE EIGHT REVIEW QUESTIONS, APPLIED TO DANA’S REORDER REMINDER

QUESTION	ASK	APPLIED TO THE REMINDER	RED FLAG
1. VALUE	What customer outcome needs data?	Saves a trip when Dana is running low on something she buys regularly. Expected for items she bought. Not expected: anything the reminder implies about why she bought them.	“We might need it later.”
2. DATA	Exactly what enters the system?	Order lines are T2. But the catalogue includes prenatal vitamins and pregnancy tests, so a purchase cadence can reveal health: those categories are T4. Tier by what data reveals, not by column type.	Free text, full URLs, raw payloads.
3. IDENTITY	Can it be linked to a person?	It needs an account-scoped ID to send the reminder. It does not need the device ID or any advertising ID — and must never be joined to them.	A durable ID shared across features.
4. FLOW	Where does it travel?	Orders → cadence job → notification service → MailPost. The vendor needs a token and a template — not the purchase history.	Unlisted SDKs, logs, exports.
5. ACCESS	Who can see or join it?	The model team reads cadences, not baskets. Support sees “reminder sent”, not why. Ad systems have no read path at all.	Warehouse-wide read by default.
6. TIME	How long does raw data remain?	Keep the cadence (“every 28 days”) for 180 days. Raw baskets for the model: 90 days rolling. Vendor message logs: per contract.	No TTL, or “until deleted.”
7. MISUSE	What secondary use is possible?	A future team asks for a “likely expecting” ad audience built from the same cadences. Nothing technical stops it today.	Security data readable by ads.
8. REDUCE	What can we remove or enforce?	Exclude sensitive categories by default. Compute cadence inside the account service. Send the vendor a template ID, never a product name. Put the purpose check in the query layer.	Controls that live only in a doc.

YOU CHANGE

Which of the eight questions you are asking.

THE SYSTEM

Orders → cadence job → notification service → MailPost.

FOR DANA

A useful reminder, or a message that implies why she bought something.

THE CONTROL

The four conditions below, each enforced by a mechanism rather than a sentence.

THE EVIDENCE

The review record, its conditions, and a link from each condition to the control that enforces it.

REVIEW OUTCOME

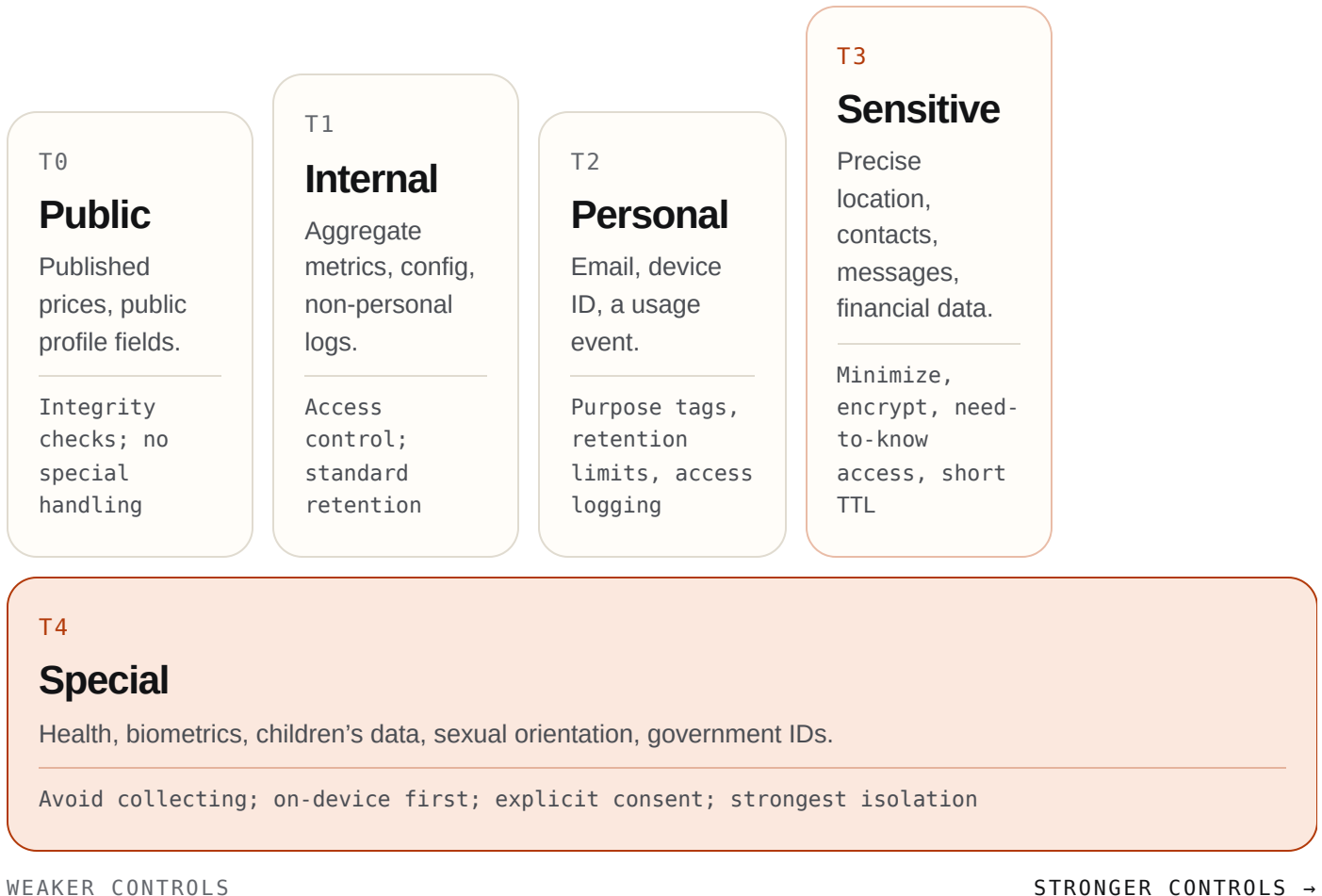
Ship — with four conditions.

- 1. Sensitive product categories are excluded from reminders by default.
- 2. The cadence (“every 28 days”) is stored; raw baskets expire after 90 days.
- 3. MailPost receives a template ID and a token — never the product name.
- 4. Cadence data is purpose-bound to reminders; ad systems cannot read it.

Remember these four. Scene 21 ships six ordinary changes to this feature and counts how many conditions still hold.

The DATA question needs a scale.

“Is it personal?” is too blunt to act on. Tier the data first; the tier decides the default controls, so reviewers debate exceptions, not basics. One subtlety matters more than the rest: **tier data by what it reveals, not by the column type.**



In the Command Center: **Privacy reviews** — the eight answers for every Northstar feature, and which launches they block → — paddyspeaks.com/privacy-command-center/v10/#/privacy/reviews

TAKEAWAY

Same eight questions, same order, every feature. Consistency is what turns a review into an instrument.

06 DECIDE · THE MAP

Every arrow is a decision.

IN BRIEF

Each arrow on an architecture diagram is **a copy with a reason, a clock and a reader**. On Northstar’s order path the dangerous ones are an SDK talking straight to a third party, emails in logs, product names sent to a vendor, and fulfilment data reused for targeting.

Data moves through a lifecycle, and a good review asks one question — and names one control — at every stage.

FIG. 06A One question per lifecycle stage

ONE QUESTION AND ONE CONTROL PER LIFECYCLE STAGE

STAGE	QUESTION	CONTROL
Collect	What?	Collect the minimum; derive on device where you can.
Process	Where?	Process locally or inside isolated services.
Use	Why?	Purpose tags checked at read time, not just intake.
Share	With whom?	Contracts, scoped tokens, aggregation before export.
Store	How long?	TTL per field: raw → derived → aggregate.
Delete	Prove it.	Propagated deletes, audit trail, verification scans. The deletion path is part of the architecture — not a ticket you file after launch.

YOU CHANGE

The lifecycle stage under review.

THE SYSTEM

Where Dana’s order data is collected, processed, used, shared, stored and deleted.

FOR DANA

Each stage is a place her data can outgrow the reason she gave it.

THE CONTROL

One named control per stage: minimise, isolate, purpose-check, scope, expire, delete with proof.

THE EVIDENCE

For each stage, the record that the control ran: field lists, isolation tests, deny logs, contracts, TTL reports, deletion receipts.

Now the arrows themselves. This is Northstar’s order path, from Dana’s phone to the dashboard. Orange arrows leave the trust boundary or change purpose.

FIG. 06B Northstar’s order path: every arrow as a privacy object

SYNTHETIC DATA

NORTHSTAR’S ORDER PATH: EVERY ARROW AS A PRIVACY OBJECT (ORANGE = LEAVES THE BOUNDARY OR CHANGES PURPOSE)

ARROW	FIELDS	PURPOSE	RETENTION	OWNER	CONTROL	THE DECISION
-------	--------	---------	-----------	-------	---------	--------------

ARROW	FIELDS	PURPOSE	RETENTION	OWNER	CONTROL	THE DECISION
Storefront app → API gateway	customer_id, cart, delivery address, device_id, IP	Place and deliver the order	In transit only	Observability & SRE	TLS; gateway allow-list drops unknown fields	Does the device ID need to travel with every order?
Storefront app → GeoGrid SDK EGRESS	lat, lon, advertising ID — every 15 minutes, in the background	Unknown — arrived inside another SDK	Unknown — vendor default	None	None on your servers: this arrow never touches them	The most dangerous arrow is the one your own logs cannot see.
API gateway → Checkout service	Order, customer_id, delivery address	Fulfilment	Orders ledger: 7 years for accounting	Checkout Platform	Service mTLS; field-level encryption for address	The ledger may need seven years. Does the street address?
API gateway → Application logs UNFILTERED	request_url (with email in the query string), IP address	Debugging	395 days kept; 30 declared	Observability & SRE	A redactor that reads bodies, not URLs	Debugging is a real purpose. It does not need the customer's email.
Checkout service → MailPost EGRESS	Email, first name, order summary with item names	Order confirmation	MailPost keeps message content for its own period	Checkout Platform	Contract — but item names can reveal health	Send a template ID and an order link, not “prenatal vitamins × 2”.
Checkout service → Event bus	order_placed {customer_id, device_id, SKUs, total, geo_city, precise_lat, precise_lon}	Fan-out — no single purpose	Topic: 7 days	Data Platform	Schema registry; tier tags — but a “compatible” change added precise location	A bus without purpose tags turns every new subscriber into a new purpose.
Event bus → Core warehouse	Every event field, joined to profile	Analytics	4 years; the TTL policy is a wiki page	Data Platform	Role-based access; column controls for T3 and above	A retention rule nobody enforces is the absence of one.
Event bus → Audience Builder PURPOSE CHANGE	SKU list, customer_id → joined to email	Collected to fulfil orders; now used for targeted campaigns	390 days	Audience Engineering	None at read time — the purpose check happens at use, or not at all	The data didn't move far. The reason moved a long way.
Core warehouse → Snapshot backups	Everything	Disaster recovery	35-day snapshots	Observability & SRE	Separate backup keys; deletions re-applied on restore	Deletion must reach backups, or expire out of them on a stated clock.

ARROW	FIELDS	PURPOSE	RETENTION	OWNER	CONTROL	THE DECISION
Core warehouse → Feature store	Days since last order, cadence per category	Reorder reminders	180 days rolling	Storefront Growth	Sensitive categories excluded by rule	Derived, narrower, shorter-lived: what the raw event should become.
Feature store → Reorder model	Cadence vectors — no names, no address	Predict the next reorder date	Training snapshots: 180 days	Storefront Growth	Training lineage recorded per snapshot; retrained weekly	Can you retrain without a person who asked to be deleted?
Reorder model → Exec dashboard	Reminders sent, reorder rate by region	Measure the feature	2 years	Data Platform	Small groups suppressed (fewer than 50)	The safest arrow on the map: no identifier crosses it.

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
Which arrow you inspect.	Each arrow’s fields, identifier, purpose, consent, retention, owner and control.	Her location leaving with an ad ID; her email in logs for 395 days; “prenatal vitamins” in a vendor’s mail archive.	No arrow without a purpose, a retention and an owner; SDK allow-lists; egress gates; purpose checks at read.	A flow inventory reconciled daily against observed traffic and lineage: any arrow nobody described is a finding.

FIELD NOTES The orange arrows are where regulators’ case files come from

Each of these started as an ordinary marketing or analytics integration. The pixel or SDK behaved as designed; what failed was a review that never asked where the events went. All three ended in settlements without an admission of wrongdoing.

FTC · 2023 · REAL CASE

GoodRx

Shared health information with advertising platforms through pixels and SDKs despite privacy promises. The FTC’s first Health Breach Notification Rule enforcement: a \$1.5M civil penalty and a ban on sharing health data for advertising. [FTC, Feb 2023](#)

A “standard” pixel on a health page is a health-data disclosure.

FTC · 2023 · REAL CASE

BetterHelp

An online counselling service shared emails, IP addresses and intake answers with advertisers after promising privacy. \$7.8M for consumer refunds, and a ban on sharing health data for advertising. [FTC, Jul 2023](#)

Hashed emails of people seeking therapy are still health data.

FTC · 2022–2026 · REAL CASE

Kochava

A location broker sold precise coordinates tied to mobile ad IDs, exposing visits to clinics, places of worship and shelters. Sued in 2022; a 2026 stipulated order bars selling sensitive location data without consumers’ affirmative express consent. [FTC, May 2026](#)

An “anonymous” ad ID plus precise location is a person.

CORNER CASE · EXPORTS

The arrow nobody drew

Data-flow diagrams show systems talking to systems. The busiest arrow in most companies isn’t on them: a person, an export button and a deadline. Follow one CSV for one evening.

1. OCT 6 16:50 **Leo needs one churn chart for tomorrow’s board deck** The dashboard has the chart. The export button is right there. *It’s whatever the export button gives you.*
2. OCT 6 16:52 **16:52 — the export is every row** 48,210 customers: name, email, phone, plan — and a health add-on flag. A CSV escapes every control the dashboard had. *The file isn’t.*
3. OCT 6 17:05 **17:05 — emailed to a consultant** A copy now lives in someone else’s mailbox, with its own backups and retention. *Email is between two companies’ servers.*
4. OCT 6 19:30 **19:30 — uploaded to a personal drive to finish at home** It syncs to a laptop, a tablet and a phone Northstar has never heard of. *That’s the problem: it’s not the company’s.*
5. OCT 6 21:10 **21:10 — pasted into a public chatbot: “summarise the churn drivers”** Prompts are records. Depending on the provider’s terms they may be retained, reviewed, or used for training. *Its terms decide what it forgets.*
6. OCT 9 10:00 **J. Park asks to be deleted. Where is she?** In the CRM, the warehouse — and in 3 copies nobody inventoried. No system can find them; no request can reach them. *You can honour it where you can find it.*

WHERE IT ENDS – AS IT USUALLY GOES, AND WITH EVERY HABIT ON

COUNTER	AS IT USUALLY GOES	WITH THE HABITS
copies with names, contacts or health flags outside company control	3	0
identifiable people in each copy	48,210	0
copies no deletion request can reach	4	0

The habits:

- Export aggregates, not rows.** Dashboards export counts. Row-level exports need a ticket and a reason.
- Identifying columns can’t leave.** Names become internal IDs; email, phone and health flags are stripped on export; DLP blocks attachments that carry them.
- Share links, not files.** The consultant gets an expiring, logged, revocable link.
- Approved AI only.** A company AI tool with no training on inputs and zero retention.

ILLUSTRATIVE SCENARIO

People and figures are invented. What a chatbot keeps depends on the provider, plan and settings — check the terms that apply to you.

In the Command Center: **Lineage & flows** — all of Northstar’s arrows, including the ones nobody reviewed → — paddyspeaks.com/privacy-command-center/v10/#/explore/flows

TAKEAWAY

If an arrow has no purpose, no retention and no owner, it is not a design. It is an accident with a network connection.

07 DECIDE · PURPOSE

Purpose is checked when data is used — not just when it’s collected.

IN BRIEF

Data rarely moves far to be misused; the reason moves. A phone number collected for sign-in codes becomes an ad-matching key. **Bind purpose to the data and check it at every read:** a purpose written only in a privacy notice cannot stop a query.

Consent screens and privacy notices happen once, at collection. Drift happens at every read. The question a reviewer asks is not “is this data sensitive?” but “does this flow match what Dana expected when she shared it?” — Helen Nissenbaum’s idea of *contextual integrity*. [Nissenbaum, 2004](#)

SAME DATA. DIFFERENT FLOW. DIFFERENT VERDICT.

Diagnosis

Your doctor

Expected by everyone involved

Your insurer

Only with a clear, disclosed basis

Your employer

Breaks the norm of the clinic

Precise location

Turn-by-turn maps

The reason you shared it

A friend you chose

You set the flow yourself

A data broker

Sold on without your knowledge

Purchase history

Receipts & returns

Part of the transaction

Fraud checks

Fine if proportionate

Pregnancy inference for ads

A new, sensitive fact

FIG. 07 A use-time purpose check on phone_number ILLUSTRATIVE SCENARIO

SIX REQUESTS TO READ PHONE_NUMBER, CHECKED AT THE MOMENT OF USE

REQUESTER	WANTS TO	VERDICT	WHY
Login service	send 2FA code	Allowed	Account security — the original purpose
Support desk	verify caller during recovery	Allowed	Account security — compatible
Risk engine	flag a takeover attempt	Allowed	Fraud prevention — declared at collection
Audience Builder	match to custom audience	Denied	Ad targeting — never declared
Growth team	“people you may know”	Denied	Contact discovery — new purpose
ML platform	train a model	Denied	Model training — a new purpose: needs a compatibility test or a new basis

YOU CHANGE

Whether six real-world-shaped requests are checked against the field’s declared purposes.

THE SYSTEM

A query layer that knows each field’s purposes and each request’s purpose.

FOR DANA

The number she gave for sign-in codes never becomes an ad-matching key.

THE CONTROL

Purpose annotations on fields; purpose declared on every read; deny by default; exceptions logged and time-boxed.

THE EVIDENCE

Deny logs by purpose and consumer, and a count of reads that carried no purpose at all (should be zero).

\$150M

CIVIL PENALTY · 2022

REAL CASE In May 2022 the FTC and the Department of Justice announced that Twitter would pay a **\$150 million civil penalty** to settle charges that, from 2013 to 2019, it used phone numbers and email addresses collected for account security — two-factor authentication and recovery — to target advertising, affecting more than 140 million users. [FTC, May 2022](#) The data had not been stolen. It had been reused.

BUILDER NOTE A purpose check in the query layer, in twenty lines

```
# policy: every field carries purposes; every read declares one
fields:
  users.phone_number: { purposes: [account_security, fraud_prevention], tier: T2 }
  orders.sku:         { purposes: [fulfilment, reminders], tier: T2, reveals:
```

```

T4_if_category_in(health) }

# enforcement, at read time, for every query
def authorize(query, principal):
    purpose = query.declared_purpose or DENY("no purpose declared")
    for col in query.columns:
        allowed = policy[col].purposes
        if purpose not in allowed and not exception(principal, col, purpose):
            log_deny(principal, col, purpose)          # evidence
            return DENY(f"{col}: {purpose} not in {allowed}")
    if consent_required(purpose) and not consent.current(query.subjects, purpose):
        return FILTER_OUT(revoked_subjects)           # consent is read now, not at
midnight
    return ALLOW

# exceptions expire; nobody gets a permanent pass
exception(principal, col, purpose) := ticket.approved and ticket.expires > now()

```

In the Command Center: **Purpose** — Northstar's purpose findings, including a fraud feature store now read by marketing → — paddyspeaks.com/privacy-command-center/v10/#/privacy/purpose

TAKEAWAY

Bind purpose to the data, and evaluate it at the moment of use. A purpose written only in a privacy notice cannot stop a query.

08 DECIDE · THREAT MODELING

Think like the adversary. Then like the person.

IN BRIEF

Privacy threat models ask what anyone — including the company, doing its job — can learn or do that the person wouldn't expect. Walk every technical issue to a human consequence. **Children, biometrics, location, health, employees and people at risk change the default design.**

LINDDUN, a privacy threat-modeling framework from KU Leuven, names seven threat categories — the STRIDE of privacy. [LINDDUN](#) Walk every category across every element of your data-flow diagram.

L**Linking**

Can items or actions be tied to the same person?

I**Identifying**

Can someone learn who the person is?

N**Non-repudiation**

Is a person unable to deny an action they'd want to?

D**Detecting**

Can someone tell that data about a person exists?

D**Data disclosure**

Is personal data exposed more than necessary?

U**Unawareness & unintervenability**

Are people uninformed, or unable to act?

N**Non-compliance**

Does it violate law, policy, or promise?

Outsider · breach, theft → encryption, isolation, minimal stored data

Partner · over-collection, reuse → contracts, scoped APIs, aggregation, audits

Insider · excess or curious access → need-to-know, access logs, break-glass review

Tracker · cross-context linkability → partitioning, rotating IDs

Future you · retention, scope creep → TTLs, purpose enforcement, deletion by default

Always walk the whole chain: technical issue → privacy harm → human consequence.

FIG. 08 From a technical issue to a human consequence

FROM A TECHNICAL ISSUE TO A HUMAN CONSEQUENCE

TECHNICAL ISSUE	PRIVACY HARM	HUMAN CONSEQUENCE	CONTROL
Precise location kept for 18 months	Surveillance and sensitive inference	A visit pattern reveals a clinic, a place of worship, a shelter.	Keep city, not coordinates; 30-day TTL on raw pings.
Lock-screen notification previews on	Exposure and household leakage	A preview reveals a diagnosis on a shared phone.	Generic notification text for T3+ items.
Hashed email uploaded to an ad partner	Linkability and secondary use	Activity here follows a person across other sites and apps.	No hashed identifiers leave without consent checked at export.
Purchase history feeds a pricing model	Discrimination and manipulation	Two people see different prices for reasons neither can see.	Pricing may not read purchase history; audit prices by segment.
Opt-out checked in the app, not the warehouse	Loss of control and secondary use	The person said no. The warehouse, and every model trained from it, never heard.	Consent evaluated at read in the query layer.
“Anonymized” export with ZIP and birth date	Re-identification	A journalist, or a stalker, puts a name back on a record.	Generalise quasi-identifiers or release with differential privacy.
Identity graph merges two people at 0.71 confidence	Inaccuracy and discrimination	One person inherits another's fraud history and is refused service.	Merge threshold, human review of adverse actions, a correction path.

YOU CHANGE

Which technical issue you trace.

THE SYSTEM

A property of a design: a retention, a notification, an export, a join.

FOR THE PERSON

Surveillance, exposure, discrimination, loss of control — named in words a roadmap can't ignore.

THE CONTROL

The specific change that breaks the chain, shown under each issue.

THE EVIDENCE

A threat model per feature, dated, with each threat linked to its control and that control's health.

Where the stakes change the design.

Six contexts in which a default that is fine elsewhere becomes harmful. These are field notes for engineers, not a legal encyclopedia; the law differs by place and changes.

LEGAL UNCERTAINTY

Children

Assume a child can be on the other end.

Why it changes: children can't meaningfully consent to profiling and are more exposed to manipulation. **Default move:** separate stores, no ad identifiers, no behavioural advertising, the shortest retention, parental controls that don't become surveillance. **Real case:** Epic Games paid a \$275M COPPA penalty in 2022 over children's data and default settings. [FTC, Dec 2022](#) **Law:** COPPA (under 13 in the US; the FTC's 2025 amendments took effect that June) [FTC](#); GDPR Art. 8 sets 16 for consent to online services, which member states may lower to 13.

Precise location

A trail of coordinates is a diary.

Why it changes: a few points reveal home, work, clinic, place of worship and who sleeps where. **Default move:** coarse by default; foreground only; compute on the device; hours, not months, of raw history; no ad IDs alongside. **Real case:** the FTC's 2024 X-Mode order was its first ban on selling sensitive location data.

[FTC, Jan 2024](#)

Employee data

The power runs one way.

Why it changes: employees can't easily refuse, and monitoring data invites misuse in decisions about them. **Default move:** separate HR data from operational telemetry; aggregate productivity signals; access by case, not by rank; no notes about health or family life. **Real case:** Hamburg's data protection authority fined H&M €35.3M in 2020 for keeping detailed profiles of service-centre staff's health, family and beliefs. [EDPB, Oct 2020](#)

Biometrics

You can change a password, not a face.

Why it changes: biometric identifiers are permanent and link across contexts. **Default move:** match on the device; store templates, not images; never build a shared face index. **Real case:** the Dutch data protection authority fined Clearview AI €30.5M in 2024 for scraping faces into a recognition database. [AP, Sep 2024](#) **Law:** Illinois's BIPA requires written release before collection and lets individuals sue. [740 ILCS 14](#)

Health

Including health you inferred.

Why it changes: disclosure can cost a job, insurance or safety; inferences from purchases and app screens count. **Default move:** no third-party pixels or SDKs on health surfaces; per-user encryption; explicit consent for each use. **Real case:** the FTC found that the Flo Health period tracker shared health data with analytics and marketing firms despite its promises. [FTC, Jun 2021](#) **Law:** in the US, the FTC's Health Breach Notification Rule was extended to health apps in 2024. [FTC, Apr 2024](#)

People at risk

Design for the abuser in the room.

Why it changes: for someone leaving an abusive partner, a shared account, a location share or an order notification can be dangerous. **Default move:** quiet exits (leave a shared plan without notifying), no "last seen" by default, discreet notifications, fast help-desk routes that verify without exposing. **Real case:** the FTC banned the stalkerware maker SpyFone from the surveillance business in 2021. [FTC, Dec 2021](#) Apple and Google now alert people to unknown Bluetooth trackers travelling with them. [IETF draft](#)

In the Command Center: **Threat models** — LINDDUN walked across Northstar's riskiest flows → —paddyspeaks.com/privacy-command-center/v10/#/privacy/threats

TAKEAWAY

The privacy question: what can an actor learn or infer — even if the system behaves exactly as designed? Put “future you” on the list.

09 DECIDE · TRADE-OFFS AND OWNERSHIP

Collect less is not the lesson. Choose on purpose.

IN BRIEF

“Collect nothing” is rarely an option; every real design choice trades utility, trust and residual risk. The failure is **choosing by default and writing nothing down**. A decision record names an owner, a reviewer, an approver, an expiry and the evidence that will prove it holds.

Four decisions Northstar has to make about Dana’s data. Each has three real options. Read the costs, choose one, and see the record it produces — then see what “just ship it” leaves behind.

FIG. 09 Three options, one decision record ILLUSTRATIVE SCENARIO

REORDER REMINDERS: WHERE IS DANA’S PURCHASE CADENCE COMPUTED?

	OPTION A: SERVER-SIDE, FROM THE WAREHOUSE	OPTION B: SERVER-SIDE, PURPOSE-BOUND FEATURE (REVIEWER’S PICK)	OPTION C: ON THE DEVICE
Pros	Simple; one pipeline for every platform.	Cadence only (no baskets) in a store only the reminder service can read.	The server never learns the cadence.
Cons	Raw baskets centralised; any team with warehouse access can read cadences.	One more store to run and to include in deletion.	Reminders only on devices with the app; harder to measure.
Utility cost	None — best accuracy.	Small: a 90-day basket window.	Moderate: no email reminders; per-device history only.
Privacy benefit	None beyond access control.	Sensitive categories excluded; ads have no read path.	Nothing on the server to breach or repurpose.
Trust assumption	Every warehouse reader and every future consumer.	The query-layer purpose check.	The app and the device.
Residual risk	A “likely expecting” audience is one query away.	Cadences are still personal; a breach of that store reveals habits.	Aggregate measurement still needs a privacy-preserving path.

Decision record. Owner: Storefront Growth · Reviewer: Privacy Engineering · Approver: VP Commerce · Expires: Review again in 12 months, or at any new consumer of the cadence store · Evidence: Purpose policy on the cadence store, with its deny log; TTL job report: no basket older than 90 days; Category exclusion list under version control.

STORE FINDER: HOW PRECISELY DO WE NEED TO KNOW WHERE DANA IS?

	OPTION A: BACKGROUND PRECISE LOCATION	OPTION B: PRECISE, ONLY WHILE THE FINDER IS OPEN	OPTION C: NEAREST STORES COMPUTED ON THE DEVICE (REVIEWER'S PICK)
Pros	Can nudge Dana when she walks past a store.	Accurate nearest store.	Accurate, and coordinates never leave the phone.
Cons	Home, work, clinic and routine become inferable; T3 data at scale.	Still precise coordinates on the server.	The app ships a store list.
Utility cost	None.	Loses walk-past nudges.	None for the finder itself.
Privacy benefit	None.	No background trail.	Northstar never learns where Dana is.
Trust assumption	Every holder of the location history, for as long as it is kept.	That coordinates are dropped after the request.	The app.
Residual risk	An 18-month movement history of millions of people.	Request logs can keep coordinates unless redacted.	Pickup still needs a chosen store — which is what Dana chose to share.

Decision record. Owner: Local & Pickup · Reviewer: Privacy Engineering · Approver: Director, Commerce · Expires: Review on any new location consumer or SDK · Evidence: Network test: no coordinates in any request from the finder; SDK allow-list check on each release.

PRODUCT ANALYTICS: HOW DOES NORTHSTAR LEARN WHETHER THE REMINDER FEATURE WORKS?

	OPTION A: RAW EVENT STREAM, FOREVER	OPTION B: PSEUDONYMOUS EVENTS, 30 DAYS	OPTION C: DIFFERENTIALLY PRIVATE AGGREGATES (REVIEWER'S PICK)
Pros	Any question, any time, down to one person.	Funnel and cohort questions still work.	A provable bound on what any output reveals about one person.
Cons	Every event is a record about someone; retention and access sprawl.	Long-range trends need aggregates.	Noise; small groups become unreliable; the budget runs out.
Utility cost	None.	Small.	Moderate for small segments.
Privacy benefit	None.	Joins to identity need a governed path; raw ages out.	Published answers cannot single out Dana (within the budget).
Trust assumption	Every analyst and every future use.	The key holder for the pseudonym mapping.	A correct implementation and honest accounting.
Residual risk	Re-identification and scope creep.	Still personal data; rare paths can single someone out.	Privacy loss accumulates across releases; population-level facts still show.

Decision record. Owner: Data Platform · Reviewer: Privacy Engineering · Approver: Chief Data Officer · Expires: Review each budget year · Evidence: DP ledger with per-release ϵ ; Raw-event TTL job report; Query audit of pseudonym re-identification requests.

SUPPORT TRANSCRIPTS: WHAT DOES NORTHSTAR KEEP AFTER DANA’S SUPPORT CHAT?

	OPTION A: VERBATIM, 365 DAYS, SUMMARISED BY A THIRD PARTY	OPTION B: SUMMARY KEPT, TRANSCRIPT 30 DAYS (REVIEWER’S PICK)	OPTION C: NO TRANSCRIPT KEPT
Pros	Every word available for quality review and training.	Agents keep the context they need.	Nothing to leak.
Cons	Health, money and family details sit at HelpHub and its subprocessor LLMCo.	Loses verbatim quotes for audits after 30 days.	Disputes and quality reviews become guesswork.
Utility cost	None.	Small.	High.
Privacy benefit	None.	Exposure window drops from a year to a month.	Maximum.
Trust assumption	HelpHub, LLMCo and their retention.	That the vendor deletes on the day it says.	None.
Residual risk	A year of people’s worst days, in two companies.	The summary can still carry sensitive facts; redact before summarising.	Agents keep private notes instead — the copy you didn’t design.

Decision record. Owner: Support Tooling · Reviewer: Privacy Engineering · Approver: VP Customer Support · Expires: Review at contract renewal or any new subprocessor · Evidence: Vendor deletion attestation each quarter; Redaction recall measured on a labelled sample; Subprocessor list checked against the contract.

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
The decision, the option, and whether it is recorded.	Where Dana’s data is computed, how precisely, for how long, and who can read it.	The residual risk someone accepted on her behalf — named, or not.	A decision record with owner, reviewer, approver, expiry and evidence; decisions that expire and come back.	The record itself, and the listed proof — deny logs, TTL reports, attestations — collected on a schedule.

Every important privacy decision has five names on it.

Owner

The team that runs the system and answers when it drifts. Not “privacy”.

Reviewer

The person who asked the eight questions and wrote the conditions.

Approver

The executive who accepts the residual risk, with any dissent recorded.

Expiry

A date, or a trigger — a new consumer, a new field, a new vendor — that reopens the decision.

Evidence

What will show, on a schedule, that each condition still holds.

A decision without an expiry outlives every assumption it was made under. [Scene 21](#) shows how quickly that happens.

In the Command Center: **Privacy reviews** — owners, approvers and launch blockers for every Northstar feature → — paddyspeaks.com/privacy-command-center/v10/#/privacy/reviews

TAKEAWAY

The job is not to collect nothing. It is to make the trade-off consciously — and to sign it.

10 DECIDE · ASKING

Complexity is where consent goes to die.

IN BRIEF

A banner with 847 partners hands the person hundreds of decisions and one bright yes. The product should absorb the complexity: **one honest question, two equal answers, and a no that is respected** — everywhere, which is the next chapter.

A story Apple people tell about iDVD, around 2000: shown a many-step design for burning a DVD, Steve Jobs drew one window with one button on the whiteboard and wrote a single word. **Burn.** ANECDOTE As told by Mike Evangelist, who was in the room, in *The Guardian*, 2006 It is one participant's recollection, not a documented quotation — but the principle stands on its own: *the product absorbs the complexity; it never hands it to the person.* Now look at what most consent flows hand the person instead.

FIG. 10 851 decisions, or one ILLUSTRATIVE SCENARIO

TWO WAYS TO ASK THE SAME QUESTION

	THE BANNER (COMPOSITE)	ONE QUESTION
Decisions handed to the person	851 — 4 switches, 847 partners, 1 pre-ticked interest	1
Answers	One bright “Accept all”; “reject” in small print	Two equal buttons
Default	Legitimate interest pre-enabled	Tracking only after the person says yes

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
How the question is asked: a banner of switches and partners, or one prompt.	What the consent record says — and whether it means anything.	A choice she can actually make, in one tap, either way.	Off by default; one clear question per purpose; refusal as easy as acceptance; no pre-ticked interests.	Consent records with the exact text shown, the version, the answer and the time; accept and refuse rates by design variant.

The single prompt above is the kind iPhone apps have had to show since iOS 14.5 in April 2021 — App Tracking Transparency: apps must ask before tracking across other companies' apps, and without a yes they can't. One identical question in every app. Measured opt-in rates depend on how you count: among apps that actually showed the prompt, published estimates in 2021 were around a quarter. [Flurry, 2021](#) REAL CASE

It was also good strategy for its maker. Competition authorities fined Apple over how the framework treated its own apps and others' — France €150M in March 2025 and Italy €98.6M in December 2025 — while Germany closed its case with binding commitments and no fine in August 2026. [Autorité de la concurrence](#) [AGCM](#) [Bundeskartellamt](#) The French authority said the privacy goal itself was not open to criticism; the implementation was. Apple disputes the rulings. Both things can be true: a clear question is good design, and who controls the question matters.

But a “no” is only a promise until it reaches every system that acts on the person. That is the next chapter.

In the Command Center: **Tracking** — the SDKs and pixels on Northstar's pages and apps, and which ever asked → — paddyspeaks.com/privacy-command-center/v10/#!/privacy/tracking

TAKEAWAY

The best privacy setting is the default nobody has to find. One honest question beats 847 toggles.

CHAPTER 2 · EVIDENCE

What proves you **decided**, rather than defaulted

- A review per feature with the eight answers and its conditions, each linked to the control that enforces it.
- A flow inventory in which every arrow has a purpose, a retention, an owner and a review date — reconciled against observed traffic.
- Deny logs from use-time purpose checks, and zero reads without a declared purpose.
- A threat model per feature that ends in human consequences, with sensitive contexts called out.
- Decision records with alternatives, accepted risk, owner, approver, expiry and evidence; consent records with the exact words shown.

CHAPTER 3 OF 6

Build

How consent, purpose, retention, deletion, isolation and access become technical mechanisms.

SITUATION

Dana says no to ads, asks what Northstar holds, talks to its assistant, and asks to be forgotten.

SYSTEM

Her data lives in batch jobs, caches, vendors, logs, memory, models and backups.

CONSEQUENCE

Each promise holds only as far as the slowest copy, the weakest recovery path, the vendor nobody audits.

CONTROL

Mechanisms, not sentences: gates, read-time checks, orchestrated workflows, keys, budgets.

EVIDENCE

Receipts from every system, canaries that must disappear, ledgers that say no.

11 BUILD · PROMISE → MECHANISM

Move privacy out of documents and into machines.

IN BRIEF

A promise can be enforced by a policy, a reviewer, a linter, a deploy gate, a runtime check or a daily audit. Low rungs depend on people remembering; high rungs on machines refusing. **Pre-deploy is not runtime.**

Take one promise almost every company makes: **“We don’t log personal data.”** Now ask what, exactly, stops an engineer from typing `logger.info(user)` at 6 p.m. on a Friday. The answer sits somewhere on a ladder.

FIG. 11 Six rungs between a promise and a machine that refuses

SIX RUNGS BETWEEN A PROMISE AND A MACHINE THAT REFUSES

RUNG	ENFORCED BY	FAILS WHEN	EVIDENCE IT LEAVES
0 • Policy (Reviewer)	Memory and good intentions — easy to write, easy to ignore	Whenever someone hasn't read it, forgot, or is in a hurry.	An acknowledgement count. Says nothing about the code.
1 • Review (Reviewer)	A reviewer, on a good day	When the diff is 900 lines and the reviewer is on call.	A ticked template. Evidence of attention, not of behaviour.
2 • Static check (Builder)	The editor and CI, on every commit	On dynamic code paths and untyped data the rule can't see.	Blocks per week, coverage by repository.
3 • Deployment gate (Builder)	The pipeline — nothing ships without it	Only when an exception is granted. Exceptions are logged and expire.	Gate decisions and every exception, with owner and expiry.
4 • Runtime enforcement (Builder)	The platform, at runtime, for every line	On formats the redactor doesn't recognise — which is why rung 5 exists.	Deny and redaction counts, per service, per day.
5 • Continuous audit (Auditor)	Evidence, every day, whether anyone looks or not	Only if nobody reads the ticket. Route it to an owner.	The scan itself: dated results, routed findings, time to close.

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
The rung at which a promise is enforced.	Who or what stops a personal field reaching a log: memory, a reviewer, CI, the pipeline, the platform, a daily scan.	Whether her email sits in 395 days of gateway logs readable by 1,200 people.	Climb as high as the risk warrants: gates for what must never ship, runtime for what must never run, audits for what slips through.	Each rung leaves a different kind: acknowledgements, ticked templates, block counts, gate decisions, deny counts, dated scans.

Every rung up is harder to build and harder to bypass. Mind the gap between rungs 3 and 4: **pre-deploy is not runtime.**

CORNER CASE • DEBUG LOGGING

The debug flag that stayed on for eleven days

The promise was “we don’t log personal data.” Here is how it breaks without anyone breaking it: one flag, switched on for a good reason on 20 September — the day Dana’s checkout was one of the failing payments — and every system that quietly keeps a copy of logs.

- 1. SEP 20 14:00 **A payment fails and Ana turns on DEBUG** Policy says “Do not log personal data.” The flag doesn’t read policy. **A policy is a sentence. The logger is code.**
- 2. SEP 20 14:01 **Full request bodies go to the log** Emails, addresses, last four digits — and password-reset links with live tokens. **Logs are one of the commonest places raw personal data ends up.**
- 3. SEP 20 14:30 **14:30 — fixed. The flag stays on.** Nobody owns turning it off. It will run for eleven days. **Nobody’s job is nobody’s job.**
- 4. SEP 21 02:00 **02:00 — logs are shipped** To the observability vendor, and every night a copy lands in the warehouse “for analytics” — with no TTL. **Every sink keeps its own clock.**
- 5. SEP 26 03:00 **Sep 26 — the warehouse is snapshotted** Now the lines exist in backups for 35 days, beyond any delete you run on the table. **Backups remember what tables forget.**
- 6. OCT 1 10:12 **Oct 1 — a contractor searches an ex-partner’s email** 1,214 people can search these logs. One of them does something no policy anticipated. **Trust is not an access model.**
- 7. OCT 1 17:00 **The flag is found — after 11 days** 422,400 lines with personal data, in 4 places. Deleting the app logs touches one of them. **You’ll delete one copy of the logs.**

WHERE IT ENDS – AS IT USUALLY GOES, AND WITH EVERY HABIT ON

COUNTER	AS IT USUALLY GOES	WITH THE HABITS
log lines holding personal data	422,400	0
places those lines now live	4	0
people who can search them	1,214	0

The habits:

Redact at write time. The logger drops any field tagged personal before the line exists.

Debug flags expire. Every flag carries a 24-hour TTL. Forgetting it is harmless.

Logs live 7 days. And they never flow into the warehouse ‘for analytics’.

Scoped log access. Only the on-call for this service, by just-in-time grant.

ILLUSTRATIVE SCENARIO People, systems, retention periods and headcounts are invented examples, not recommendations.

In the Command Center: **Controls & evidence** — every Northstar control, its rung and its health → —paddyspeaks.com/privacy-command-center/v10/#/assurance/controls

TAKEAWAY

A promise nobody can violate by accident is worth more than a promise everybody has read.

12 BUILD · CONSENT

Consent is state, not a checkbox.

IN BRIEF

Consent is a value that changes, and every system acting on Dana must know its current value. When she says no, the truth changes in one place and must reach fourteen. **Real consent latency is the slowest consumer's — and one that never re-checks has a latency of “never”.**

Grant consent, then revoke it, and watch the revocation propagate through Northstar's 14 consumers. Latencies are the Command Center's synthetic measurements. Four consumers never re-check at all — wire them, and watch the end-to-end number change from “never” to something you can promise.

FIG. 12 A revocation, propagating through Northstar

SYNTHETIC DATA

SIMPLIFIED MODEL

NORTHSTAR'S CONSENT CONSUMERS (SYNTHETIC LATENCIES)

CONSUMER	HOW IT LEARNS	P50	P95	P99
Web collection (tag manager)	read-time	0s	1s	2s
Mobile SDK collection	read-time	1s	4s	30s
Checkout API	read-time	0s	0s	1s
Consent cache (edge)	cached 15 min	7m	15m	15m
Warehouse reads (analytics)	not checked	never	never	never
Search personalisation	read-time	0s	1s	3s
Audience Builder (nightly)	nightly batch	12h	1.0d	1.0d
Ads export → AdReach	filter missing	never	never	never
Conversion API forwarder	cached 24h	12h	1.0d	1.0d
Lookalike model features	weekly retrain	3.5d	7.0d	7.0d
AdReach (vendor)	opt-out not sent	never	never	never
MailPost (marketing email)	webhook	30s	3m	10m
Pulse health reads	read-time	0s	0s	1s
Nova training pipeline	not checked	never	never	never

END-TO-END: TIME UNTIL THE LAST CONSUMER HONOURS A REVOCATION

	P50	P95	P99
As it is (4 consumers never re-check; 72,600,000 people's choices ignored)	never	never	never
With the silent consumers wired to read-time checks	3.4d	7.0d	9.2d

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
The consent state, and whether the consumers that never re-check are wired to read-time checks.	Fourteen consumers, each learning of a change on its own clock — or not at all.	Her “no” takes effect everywhere within a stated time — or she keeps seeing ads with no way to know why.	Consent read at use; derived data purged on revoke; vendors told by API; a propagation SLO.	End-to-end P99 over real revocations, and a canary identity that has opted out and must vanish from every export.

End-to-end latency is the time until the *last* consumer honours a revocation, over 2,000 simulated revocations drawn around each consumer’s synthetic P50 and P95. A consumer with no check contributes “never”.

CORNER CASE · REVOCATION MID-JOB

She said no at 01:58. The job had read yes at midnight.

Consent latency isn’t how fast the toggle flips. It’s how long the slowest copy keeps acting on the old answer: a batch job, a retry queue, a segment built last week, a partner.

- 1. SEP 18 00:00 **The nightly audience job loads consent — once** 41.9 million consent states are read at 00:00 and cached for the run, which takes four hours. *It respects consent as of midnight.*
- 2. SEP 18 01:58 **Dana taps “Stop personalised ads”** The consent service records REVOKED instantly, and the app thanks her. The job, two hours into its run, doesn’t hear about it. *It took effect in one system.*
- 3. SEP 18 02:10 **02:10 — the job reaches Dana’s row** Its snapshot says GRANTED, so her row goes into tonight’s audience file. *It was checked — before she changed it.*
- 4. SEP 18 03:00 **03:00 — the file goes to the ad partner** Her hashed email and segments leave the company. Nothing now can pull them back except the partner. *A hashed email is the same key on every site.*
- 5. SEP 18 03:04 **03:04 — a timeout, and a replay** The partner actually received the file, but the upload timed out. The dead-letter queue replays the same file. The partner now holds two copies. *A retry can replay a decision that has since changed.*
- 6. SEP 19 00:00 **Sep 19 — tonight’s job excludes her. Last week’s segment doesn’t.** The ‘likely parent’ segment built on Sep 11 still lists her, and it seeds the lookalike model. *Old derivatives keep the old answer.*
- 7. SEP 25 20:15 **Dana is still seeing personalised ads** Her “no” reached the consent service in milliseconds, but the partner’s copies never heard it. She has no way to know which system ignored her. *Opt-out is a message that must reach every copy.*

WHERE IT ENDS – AS IT USUALLY GOES, AND WITH EVERY HABIT ON

COUNTER	AS IT USUALLY GOES	WITH THE HABITS
copies of Dana’s data the partner still uses	2	0
places still acting on her old answer	2	0
until her no reaches everything	never	minutes

The habits:

- Check consent per record.** The job asks the consent service for each row as it reads it — not once, at midnight.
- Re-filter every retry.** A retried batch is rebuilt against today’s consent, never replayed from the dead-letter queue.
- Revocation reaches derived data.** Segments and features built from her data are purged when she says no.
- Tell the partner.** Revocations go to the partner’s suppression API within minutes.

ILLUSTRATIVE SCENARIO

 Systems and figures are invented.

In the Command Center: **Consent** — propagation latency for each of Northstar’s consumers, and the ones that never hear → — [paddyspeaks.com/privacy-command-center/v10/#/privacy/consent](#)

TAKEAWAY

Your real consent latency is the slowest consumer’s. Measure P99, not the demo — and count “never” as a number.

13 BUILD · INDIVIDUAL RIGHTS

Every right is a distributed workflow.

IN BRIEF

People can ask to see, correct, restrict, move and object to their data, and to contest an automated decision. Each request fans out to every system, vendor and AI store, against a deadline. **A ticket fails silently; an orchestrated workflow returns receipts.**

After the declined payment, Dana wants to know what Northstar holds about her. Then she wants the wrong merge fixed, the disputed record left alone while it is checked, her order history in a file she can take elsewhere, and a person to look at the decision that refused her. Six rights; each one a fan-out.

FIG. 13 Six rights, and the systems each must reach

ILLUSTRATIVE SCENARIO

LEGAL UNCERTAINTY

SIX RIGHTS, AND THE SYSTEMS EACH MUST REACH (SIMPLIFIED; NOT LEGAL ADVICE)

RIGHT	LAW	SYSTEMS IT MUST REACH	HOW IT FAILS AS A TICKET IN A QUEUE	PROOF IT WORKED
Access	GDPR Art. 15 · CCPA right to know	Profile & orders; Core warehouse; Assistant logs & memory; Vendors (HelpHub, AdReach); Identity graph	Exports the profile and forgets the warehouse; Inferences are "not data she gave us", so they are left out	An export manifest listing every system queried, with the row counts returned, signed and kept with the request.
Correction	GDPR Art. 16 · CCPA right to correct	Identity graph; Fraud features; SignalRisk (vendor); Downstream decisions	The nightly job merges them again; The feature store keeps the old band until its TTL	A correction receipt from each system, and a re-run of any decision that used the old value.
Restriction	GDPR Art. 18	Every reader of the record; Batch jobs; Models	Restriction is implemented as deletion — then the dispute can't be resolved; Jobs read yesterday's snapshot without the flag	A restriction flag checked in the query layer, with deny counts for her ID while the flag is set.
Objection & opt-out	GDPR Art. 21 · CCPA opt-out of sale/sharing	Consent service; Nightly audience job; Derived segments; AdReach (vendor)	Records it — the easy part; Read consent once, at midnight	Propagation latency per consumer, and a canary identity that must disappear from every export.
Portability	GDPR Art. 20	Orders; Account security; Other people	A PDF is not portable; The export link goes to an unverified email	Schema of the export, identity-verification record, and a check that no third party's data is included.
Appeal an automated decision	GDPR Art. 22 · CCPA ADMT rules (from 2027)	Decision log; Human reviewer; Explanation; Correction	Scores are logged; inputs are not; The reviewer can only re-run the same model	Decision log with inputs and model version, the human reviewer's outcome, and the time to decide.

YOU CHANGE

Which right Dana exercises, and whether Northstar handles it as a ticket or an orchestrated workflow.

THE SYSTEM

Profile, warehouse, identity graph, feature stores, AI stores and vendors, each with its own API — or none.

FOR DANA

An answer that is complete and on time, or one that leaves out the inferences, the vendors and the decision that hurt her.

THE CONTROL

One request fans out to every registered system; each must return a receipt; verification of identity proportionate to the right.

THE EVIDENCE

A manifest per request: systems queried, receipts returned, deadline met, and a canary check where the right changes data.

LEGAL UNCERTAINTY

Rights and deadlines are simplified orientation from the GDPR (Arts. 12–22) [GDPR](#) and California's CCPA regulations, whose automated-decision rules apply from 2027. [CPPA CPPA, 2025](#) Which rights apply, and exceptions to them, depend on where the person is and what the processing is. Not legal advice.

BUILDER NOTE A rights request as a saga, with receipts

```
# one request, many systems; nothing is "done" without a receipt
request = Rights.open(subject="dana.k", right="ACCESS", region="EU", received="2026-10-25")
request.deadline = policy.deadline(right, region)           # e.g. one month,
extendable, with notice
request.verify_identity(level=policy.idv(right))             # stronger for access and
portability
for system in registry.holders_of(subject, include=[derived, inferred, vendors,
ai_stores]):
    step = request.dispatch(system, right)                   # each system implements
the right
    step.expect(receipt=True, within=system.sla)
    step.on_timeout(retry=backoff, then=page(system.owner)) # never silently "done"
request.complete_when(all_receipts and canary_checks_pass)
request.evidence = manifest(systems, receipts, row_counts, deadline_met)
```

In the Command Center: **Individual rights** — Northstar's open requests, deadlines by region, and the systems that slow them down → —paddyspeaks.com/privacy-command-center/v10/#/privacy/rights

TAKEAWAY

A right is a promise to a person with a deadline. It is kept by a workflow that can prove it reached everything.

14 BUILD · TIME

After the decision is made, do we still need the raw event?

IN BRIEF

Retention is a risk multiplier. A raw event's usefulness decays in days; its risk never does. Keep the conclusion, not the evidence: raw becomes derived becomes aggregate, each with a clock someone chose and a job enforces.

Every extra day is another day for breach, subpoena, misuse, inference and scope creep. Drag the retention window. Watch how little value you give up, and how much exposure you stop carrying.

FIG. 14 Usefulness decays; exposure doesn't SIMPLIFIED MODEL

KEEPING RAW EVENTS LONGER (ILLUSTRATIVE MODEL: USEFULNESS HALVES ABOUT EVERY TWO WEEKS)

KEEP RAW EVENTS	VALUE RETAINED	ROWS AT RISK ON ANY DAY	EXPOSURE VS TWO YEARS
7 days	28%	14M	1%
30 days	76%	60M	4%
90 days	99%	180M	12%
180 days	>99%	360M	25%
365 days	>99%	730M	50%
730 days	>99%	1.46B	100%

YOU CHANGE

How long raw events are kept.

THE SYSTEM

How many rows exist on any given day for a breach, a subpoena or a curious query to reach.

FOR DANA

Whether her 23:41 pharmacy purchase is still a readable row two years later.

THE CONTROL

A TTL per field, enforced by a job; derived and aggregate forms that live longer than raw.

THE EVIDENCE

A retention scanner comparing each store's declared retention with its oldest observed row, daily.

Illustrative model: usefulness halves about every two weeks; the time axis is square-root, so read the numbers, not the shaded areas. It compares choices; it does not measure harm.

Raw becomes derived becomes aggregate.

The answer is rarely “keep nothing”. It is: keep the *conclusion*, not the evidence.

RAW EVENT

What happened

```
{account: 81723, sku: "PRN-VIT-60", ts: "2026-09-12T23:41:07Z", lat: 37.7793, lng: -122.4193}
```

Lives 30 days

DERIVED FEATURE

What it means

```
{account: 81723, category: "vitamins", cadence_days: 28}
```

Lives 180 days

AGGREGATE

What we learned

```
{week: "2026-W37", category: "vitamins", reorders: 14203} -- groups ≥ 50
```

Lives 3 years

Illustrative lifetimes. At Northstar, 11 datasets are already older than the retention they declare — the point is that retention should be *chosen*, written down and enforced by a job, not inherited from a default of “forever”.

In the Command Center: **Retention** — declared versus observed age for every Northstar dataset → —paddyspeaks.com/privacy-command-center/v10/#/privacy/retention

TAKEAWAY

The only data that can’t be subpoenaed, breached or sold is data you never kept.

15 BUILD · DELETION

Design as if “Forget me” had to work.

IN BRIEF

One “delete my account” must reach 26 Northstar systems; 19 can be verified today. Partial failures and old backups are how a deleted customer gets a win-back email. **Say “done” only when you can prove it, and be honest about what deletion can’t reach.**

On 2 November Dana taps *Delete my account*. Imagine one button that erases a person everywhere. Mark the stores your deletion genuinely reaches today — not the ones it is supposed to.

FIG. 15 Nine kinds of store a deletion must reach

NINE KINDS OF STORE A DELETION MUST REACH

STORE	HOW DELETION REACHES IT
Primary database	Hard delete.
Replicas & caches	Invalidate; short TTL.
Logs	Redact at write time — then there is nothing to delete.
Backups	Expire on a stated clock; re-apply deletions on restore; or crypto-shred.
Warehouse tables	Partition-aware delete.
ML features & models	Rebuild or retrain without the person; “unlearning” large models is not yet verifiable.
Search indexes & vector stores	Reindex; delete embeddings by source document.
Vendors & processors	Delete API + attestation, written into the contract.
Devices	Every phone, laptop and local cache.

At Northstar a Forget-Me request must reach 26 systems: 19 verified, 4 failed, 2 waiting, 1 unknown.

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
Which stores your deletion path genuinely reaches.	Primary, replicas, logs, backups, warehouse, models, indexes, vendors, devices.	A true confirmation email — or a false one, and a win-back message two weeks later.	An orchestrator over a registry of every store; tombstones replayed on restore; per-person keys where they fit; retraining schedules for models.	Per-system receipts, a canary re-query after the deadline, and honest wording about what expires later.

Tombstones

Mark the record deleted so late-arriving copies and restores can't resurrect it.

Crypto-shredding

Encrypt per person; destroy the key. It works only if every copy, backups included, was encrypted with that key from the first write and no other copy of the key survives. [NIST SP 800-88r2](#)

Verification

Re-query after the deadline, from outside the deletion job; alert on any survivor.

If you can't build the Forget-me button, you don't control the data. The data controls you.

CORNER CASE · DELETION

“Your data has been deleted.” It wasn't — and then she came back.

Deletion is a distributed transaction across dozens of systems. Follow Dana's request for two weeks.

1. NOV 2 10:00 **Dana taps “Delete my account”** The orchestrator discovers 26 systems that hold her. **Delete is a distributed transaction.**
2. NOV 2 10:01 **10:01 — 22 verified, 2 pending, 1 timeout, 1 unknown** The search index timed out. The job moves on. **“Mostly deleted” means “not deleted”.**
3. NOV 2 10:05 **10:05 — “Your data has been deleted.”** The email goes out five minutes after the request — before anyone checked. **The job returned; that isn't the same thing.**
4. NOV 2 10:30 **10:30 — the CRM vendor returns 500, three times** The retry budget runs out and the job is marked done. Nobody is paged. **Retries handle the failures they don't give up on.**
5. NOV 14 03:00 **Nov 14 — an outage, and a restore from Oct 28** The snapshot predates her deletion. Dana's account is live again, and no one notices. **Backups are a time machine.**
6. NOV 17 09:00 **“We miss you, Dana.”** A win-back email goes to a person who was told she no longer exists here. That is how she finds out. **Deletion is done when you can prove it — and it stays done.**

WHERE IT ENDS – AS IT USUALLY GOES, AND WITH EVERY HABIT ON

COUNTER	AS IT USUALLY GOES	WITH THE HABITS
copies still holding Dana	4	0
promises made before they were true	1	0
days before anyone noticed	15	0

The habits:

Verify, then say done. A canary re-query at T+72h. The ‘deleted’ email waits for it.

Vendor deletes with attestation. Retries until the vendor confirms; escalates to a person after three failures.

Tombstones, re-applied on restore. Every restore replays the deletion log before the database goes live.

Crypto-shred per person. Dana’s data is encrypted with her own key. Destroy the key and every copy — backups too — is unreadable.

ILLUSTRATIVE SCENARIO

Systems and figures are invented. A backup that predates the request keeps the data until it expires; say so in the confirmation, and keep the tombstone until then.

FIELD NOTE What deletion can honestly promise

- **Databases, logs, indexes, vendors:** deletion, with a receipt per system and a verification scan.
- **Backups:** expiry on a stated clock, with deletions re-applied on any restore — or crypto-shredding, if the key conditions above hold.
- **Vector stores:** delete embeddings by source document. Keyed any other way, deletes can match nothing — Northstar’s INC-2026-009 is that bug. SYNTHETIC DATA
- **Trained models:** deletion does not reach weights. Exact “unlearning” means retraining without the data; designs such as SISA make that cheaper only if built in from the start. [Bourtoule et al., 2021](#) Approximate methods for large models offer no verification guarantee today. [Cooper et al., 2024](#) The honest promise is “the next model is trained without you” — and the better design is not to train on deletable personal data at all.

In the Command Center: **Deletion** — deletion verification across Northstar’s 26 systems → —[paddyspeaks.com/privacy-command-center/v10/#/privacy/deletion](#)

TAKEAWAY

Deletion is done when you can prove it — and it stays done.

16

BUILD · VENDORS AND SUBPROCESSORS

A vendor is an arrow you can't see the end of.

IN BRIEF

A vendor moves data outside your deletion path, logs and retention jobs. The contract writes the promise; the lifecycle keeps or loses it. Northstar's support vendor drifted from 30 to 365 days and added an unreviewed US subprocessor. **Vendor risk is drift, not signature.**

Dana's support chat about the declined payment goes to **HelpHub CRM**, Northstar's support vendor. Here is that vendor as the Command Center records it, and the seven stages at which the promise can be kept or lost.

VENDOR	HelpHub CRM	DATA	email, transcript, order_id, customer_id
REGION	EU	RETENTION	30 days in the contract · 365 observed
SUBPROCESSORS	CloudHost (EU) (EU), LLMCo summariser (US)	DELETION ATTESTATION	none on file
PEOPLE	17,000,000		

FIG. 16 One vendor, seven stages SYNTHETIC DATA

ONE VENDOR, SEVEN STAGES

STAGE	QUESTION	NORTHSTAR TODAY	WITH THE CONTROL	EVIDENCE
1. Select	Do we need a vendor for this at all?	Chosen for features; the privacy review came after the security review.	Privacy review before selection: purpose, data, region, subprocessors, deletion API.	Review record dated before the contract.
2. Scope	Which API scopes and fields does it get?	Email, full transcript, order ID and customer ID for every chat.	Only what support needs: a case token, the transcript with payment and health details redacted.	Field allow-list at the egress proxy; blocked-field counts.
3. Contract	Purpose, retention, subprocessors, audit rights, deletion at the end?	DPA signed; retention 30 days in the contract.	Purpose limited to support; 30-day retention; prior notice of new subprocessors; audit rights; delete or return at termination (GDPR Art. 28).	Contract clauses mapped to machine checks.
4. Transfer	Where does the data go, and on what basis?	EU transcripts reach a US summariser (LLMCo) that nobody reviewed.	Transfer mechanism recorded (SCCs or adequacy) and a transfer assessment for each subprocessor.	Transfer register entry per flow, with its basis.
5. Operate	Is it still doing what we agreed?	Retention quietly changed from 30 to 365 days; a new subprocessor was added.	Drift alerts on retention, subprocessors and new fields; renewal blocked until resolved.	Drift feed with owner and resolution date.
6. Audit	Can they prove it?	No deletion attestation on file.	Quarterly attestation, sampled by a canary record that must disappear.	Attestations plus canary results.
7. Terminate	When we leave, does the data?	No exit plan; backups at the vendor are nobody's question.	Return, delete, verify with a canary; certificate of destruction including backups and subprocessors.	Certificate + canary re-query after the backup window.

YOU CHANGE

The lifecycle stage, and whether the control for it exists.

THE SYSTEM

Scopes, fields, contract terms, transfers, drift alerts, attestations and exit.

FOR DANA

Her support conversation kept for a month by one company — or for a year, by two, on two continents.

THE CONTROL

Field allow-lists at egress; contract clauses mapped to checks; drift alerts; canary records; verified deletion at exit.

THE EVIDENCE

A vendor register with each vendor's fields, basis for transfer, subprocessors, last attestation and canary result.

LEGAL UNCERTAINTY Under the GDPR a processor needs the controller's prior written authorisation to use subprocessors, and must delete or return the data at the end of the service (Art. 28). [GDPR](#) Transfers outside the EEA need a basis such as standard contractual clauses [Decision 2021/914](#) or an adequacy decision; the EU–US Data Privacy Framework was upheld by the General Court in 2025 and is under appeal. [T-553/23](#)

In the Command Center: **Vendor register** — every Northstar vendor, its subprocessors and its open issues → — paddyspeaks.com/privacy-command-center/v10/#/governance/vendors

TAKEAWAY

The contract says what should happen at the vendor. Only drift detection and a canary tell you what does.

17 BUILD · AI, ML AND AGENTIC SYSTEMS

The model remembers little. Everything around it remembers a lot.

IN BRIEF

One question to an assistant becomes a retrieval, a third-party prompt, a log, perhaps a memory, perhaps training data, perhaps an action with Dana's card. Most of it is ordinary data engineering. **The rest — memorisation, embeddings, unlearning — has real mechanisms and real limits; claim only what evidence supports.**

On 22 September, at 21:04, Dana asks Nova: *"I'm 7 weeks pregnant and getting migraines. Which painkillers are safe? Also, reorder my prenatal vitamins."* Follow the one sentence for six weeks, then replay it with four habits on.

FIG. 17A One sentence to Nova

ILLUSTRATIVE SCENARIO

SYNTHETIC DATA

1. SEP 22 21:04 **Dana asks Nova something she hasn't told anyone** Seven weeks pregnant, migraines, which painkillers are safe — and could it reorder her vitamins. One sentence. Watch it become several records. **It is a request that several systems will keep, each on its own clock.**
2. 21:04:01 **21:04:01 — Nova fetches her orders to personalise the answer** Retrieval-augmented generation pastes documents and records into the prompt at answer time. The model doesn't "know" her orders; it is shown them, every time. So access control belongs at retrieval, per user. **The model is being handed her data, request by request.**
3. 21:04:02 **21:04:02 — the prompt, her name and her orders go to the model provider** The provider's terms promise no training. They also keep prompts 30 days for abuse monitoring — a copy outside Northstar that no deletion request reaches until it expires. **Read the terms: retention windows, reviewers, subprocessors.**
4. 21:04:03 **21:04:03 — logged for 400 days, tagged for training, read by reviewers** The model doesn't remember the conversation. The logs do: 400 days, a model-training purpose added on Sep 12, and a quality-review sample read by 64 people. **The model remembers little; the logs remember everything they were told to.**
5. 21:04:05 **21:04:05 — a memory row: "Dana is pregnant"** Memory is a database row saved for future conversations — not a change to the model. Saved silently, it turns one question into a standing fact about her. **Memory is a row. It can be shown, edited and deleted — if you build that.**
6. 21:05 **21:05 — the agent orders and pays** "Reorder my vitamins" becomes checkout.place_order with her saved card — the wrong pack size, charged instantly. An agent acts with whatever permissions it was given. **It does what its tools allow, as it understood you.**
7. OCT 1 **Oct 1 — a fine-tuning run includes her conversation** Her words now shape model weights. Some training text can be memorised and extracted; most isn't. Nobody can list which. **Dilution is not deletion, and memorisation is measured, not assumed.**
8. NOV 2 **Dana deletes her account. Two copies don't hear it.** The 400-day prompt logs aren't wired to the deletion orchestrator. The fine-tuned weights can't be edited to remove her; the honest promise is that the next model is retrained without her. The provider's copy expired on Oct 22 — if the contract was honoured. **It deletes what the deletion path reaches — and a trained model is not on that path.**

WHERE IT ENDS – AS IT USUALLY GOES, AND WITH EVERY HABIT ON

COUNTER	AS IT USUALLY GOES	WITH THE HABITS
places her sentence is stored now	2	0
people who may read it in review	64	0
copies her deletion can’t reach	2	0
actions taken without her confirmation	1	0

The habits:

Strip identity before the provider. Names, emails and order IDs are removed before the prompt leaves for the model API. The question itself has to go — it is what Nova must answer.

Logs live 30 days; no training without opt-in. Conversation logs expire after 30 days and never enter a training set unless Dana opted in.

Memory asks first. Nova offers “Remember that you’re pregnant?” and saves nothing sensitive without a yes. Every memory is visible and deletable.

Purchases wait for her confirmation. The reorder tool can prepare a basket. Paying needs Dana to confirm the item and the price.

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
Four habits: identity stripped before the provider, short logs with no training use, memory that asks, purchases that wait for confirmation.	Retrieval, a third-party model, logs, memory, an agent tool and a fine-tuning run.	Where her sentence lives, who may read it, whether her deletion reaches it, and whether anything was bought without her.	An AI system inventory with the controls in the table below, per store and per tool.	Training manifests, retrieval and tool-call logs, memory rows per user, provider terms mapped to settings, extraction tests with canaries.

What actually happens — and what you can honestly claim.

Thirteen parts of an AI system, each with its mechanism, the claim it supports, the claim it doesn’t, the control and the evidence. Research findings are cited with their conditions; a result on one model under one attack is not a law of nature.

THIRTEEN PARTS OF AN AI SYSTEM: MECHANISM, CLAIMS AND CONTROLS

PART	WHAT ACTUALLY HAPPENS	WHAT YOU CAN CLAIM	WHAT YOU CAN’T	CONTROL	EVIDENCE
Training & fine-tuning data	Examples are used to update model weights. Some sequences — especially duplicated ones — can be memorised and reproduced verbatim. Carlini et al., 2021 Carlini et al., 2023 Nasr et al., 2023	Extraction attacks have recovered verbatim training text from real models.	That every record is extractable, or that none is.	Train only on consented, minimised data; deduplicate; hold out sensitive categories.	Dataset lineage per training run; extraction tests against planted canaries.

PART	WHAT ACTUALLY HAPPENS	WHAT YOU CAN CLAIM	WHAT YOU CAN'T	CONTROL	EVIDENCE
RAG sources	At answer time the system retrieves documents and pastes them into the prompt. Anything retrievable can appear in an answer. OWASP LLM Top 10	Access control has to be enforced at retrieval, per user.	That the model “knows” the documents — it reads them each time.	Retrieve only what the asking user may see; delete by source document.	Retrieval logs; a deleted-document canary that must stop being retrieved.
Prompts, outputs, conversation logs	Ordinary records: stored, backed up, searchable, sometimes reviewed by people.	They are personal data with retention and access like any log.	That the model “forgets” a conversation — the logs are what remember.	Short retention; no training use without a basis; redact before storage.	TTL job reports; reviewer access logs.
Embeddings & vector stores	Text turned into vectors for search. Vectors can be partly inverted back into text under some conditions. Morris et al., 2023	Treat embeddings as the text they came from.	That embeddings are anonymous.	Same tier and deletion as the source; key chunks by source ID.	Delete-by-source canary; inversion testing on your own model.
Memory	A feature that saves facts about the user for later conversations — a database row, not a model change.	Users can be shown, edit and delete memory rows.	That memory is inside the model.	Opt-in; show the user what was saved; never save sensitive categories silently.	Memory rows per user, with the conversation they came from.
Memorisation & extraction	Measured by attacks: prompt with a prefix, check for verbatim continuations; or test membership. Carlini et al., 2021 Shokri et al., 2017	A measured rate on a stated test.	A guarantee either way from a few tests.	Deduplicate; DP training where the budget allows; output filters.	Extraction and membership tests with planted canaries, per release.
Sensitive inference	Models infer health, pregnancy or sexuality from ordinary signals.	An inference is personal data, and in many laws sensitive data.	That you didn't collect it because nobody typed it.	Block sensitive inference for uses that don't need it; label outputs.	Category-level audits of outputs and segments.
Retention & deletion	Deleting a conversation removes logs and rows. It does not change weights already trained on it.	Deletion reaches logs, memory, indexes and future training sets.	That deletion reaches a trained model.	Keep deletable data out of training; track which runs used which records.	Deletion receipts per store, including vector stores and training manifests.

PART	WHAT ACTUALLY HAPPENS	WHAT YOU CAN CLAIM	WHAT YOU CAN'T	CONTROL	EVIDENCE
Model “unlearning”	Exact unlearning means retraining without the data (SISA makes that cheaper if designed in from the start). Approximate methods for large models have no verification guarantee. Bourtoule et al., 2021 Cooper et al., 2024	Retraining without the record, where feasible and planned for.	That a large model has provably forgotten someone.	Design for retraining; prefer not to train on deletable personal data.	Retraining manifests; honest wording in deletion confirmations.
Third-party model providers	Prompts leave your boundary. Terms decide retention (e.g. an abuse-monitoring window) and training use.	What the contract says, verified where possible.	That “zero retention” holds without checking the terms and settings.	Redact before sending; contract no-training and retention; isolated tenancy.	Contract terms mapped to settings; redaction recall on a labelled set.
Agent tools & permissions	An agent calls tools (search, checkout, email) with the permissions it was given. OWASP LLM Top 10	Least privilege per tool; scoped, short-lived credentials.	That the model will only do what the user meant — prompts can be injected.	Scoped tools; allow-lists; rate limits; no ambient credentials.	Tool-call logs with the identity and scope used.
Human approval boundaries	Some actions (purchases, messages to others, deletions) wait for a person to confirm.	Irreversible or costly actions need explicit confirmation.	That a confirmation click proves understanding.	Confirm with the specifics (item, price, recipient); never batch-approve.	Approval logs; rate of actions taken without confirmation (should be zero).
Automated decisions, explanation & appeal	A model output that decides something about a person — eligibility, a decline, a price. GDPR AI Act	A right to human review and to contest, where the law gives one; good practice everywhere.	That a score is “just a recommendation” when nobody overrides it.	Human review with authority; explanations tied to the inputs; appeal route.	Decision logs with inputs, overrides and appeal outcomes.

FIELD NOTES The research behind the table, with its limits

- **Extraction.** Querying GPT-2 recovered hundreds of verbatim training sequences, including names and contact details that were already public on the web; the count is a lower bound, not a rate for every record.
[Carlini et al., 2021](#) A “divergence” prompt later made a production chatbot emit memorised text — more than 10,000 examples for about \$200 — before it was mitigated. [Nasr et al., 2023](#)
- **Memorisation grows** with model size, with how often an example is duplicated and with the length of the prompt prefix — measured by prompting with true training prefixes, an upper-bound-style test. [Carlini et al., 2023](#)
- **Membership inference** can tell whether a record was in a training set, best on overfitted models; against large pre-trained language models it is often close to chance. [Shokri et al., 2017](#)

- **Embeddings** can be inverted: one method recovered 92% of 32-token inputs exactly — for short, in-domain text, with access to the same embedding model. Adding noise largely defeated it. [Morris et al., 2023](#)
- **Frameworks.** OWASP's 2025 list for LLM applications names sensitive information disclosure (LLM02), excessive agency (LLM06) and vector and embedding weaknesses (LLM08). [OWASP](#) NIST's AI Risk Management Framework and its generative-AI profile are voluntary guides. [NIST AI 100-1](#) [NIST AI 600-1](#)
- **Human oversight and appeal.** The GDPR gives a right not to be subject to decisions based solely on automated processing with legal or similarly significant effects, with safeguards including human intervention (Art. 22). [GDPR](#) The EU AI Act requires human oversight of high-risk systems (Art. 14); those obligations are not yet applicable, and their dates have been moved. [AI Act](#) **LEGAL UNCERTAINTY**

In the Command Center: **AI & agents** — Northstar's model and agent inventory: training data, prompt logging, memory, providers and deletion paths → —[paddyspeaks.com/privacy-command-center/v10/#/privacy/ai](#)

TAKEAWAY

AI privacy is mostly ordinary data engineering with new places to copy things. Inventory the copies, then make only the claims your evidence supports.

18 BUILD · AUTHENTICATION AND RECOVERY

A sign-in method decides what can be stolen — and what gets collected.

IN BRIEF

Every second factor is also a data decision: an SMS code means holding a phone number that can be ported by an attacker and reused by marketing. Passkeys are bound to one site. **Every sign-in is only as strong as its weakest recovery path.**

On 12 October a 2019 breach at another shop puts Dana's old password in a list that circulates for years. Read the grid, then watch one attacker try every door in one week.

WHICH SIGN-IN METHODS STOP WHICH ATTACKS, AND WHAT EACH ONE LEAVES WITH THE SITE

Password only	
Leaked or reused password	No
Push spam	—
Real-time phishing page	No
SIM swap	—
WHAT THE SITE KEEPS	
A password hash — worth stealing, and worth cracking	
Password + SMS code	
Leaked or reused password	Stops it
Push spam	—
Real-time phishing page	No
SIM swap	No
WHAT THE SITE KEEPS	
Your phone number — a lasting identifier that joins datasets	
Password + authenticator code	
time-based codes from an app	
Leaked or reused password	Stops it
Push spam	—
Real-time phishing page	No
SIM swap	Stops it
WHAT THE SITE KEEPS	
A shared secret (the code seed) on its server and your phone	
Password + push approval	
Leaked or reused password	Stops it
Push spam	No
Real-time phishing page	No
SIM swap	Stops it
WHAT THE SITE KEEPS	
A registered device, and every sign-in you approve	

Push with number matching

the app asks for the number on the sign-in screen

Leaked or reused password

Stops it

Push spam

Stops it

Real-time phishing page

No

SIM swap

Stops it

WHAT THE SITE KEEPS

A registered device

Passkey, synced

stored in a platform or password-manager account

Leaked or reused password

Stops it

Push spam

Stops it

Real-time phishing page

Stops it

SIM swap

Stops it*

WHAT THE SITE KEEPS

A public key for this site only — nothing that links you to other sites

Hardware security key

a FIDO2 device

Leaked or reused password

Stops it

Push spam

Stops it

Real-time phishing page

Stops it

SIM swap

Stops it*

WHAT THE SITE KEEPS

A public key for this site only; nothing is synced anywhere

* Only if account recovery doesn't fall back to an SMS code. Passkeys are scoped to one site, so the browser won't use them on another origin; each site gets its own key pair. [W3C WebAuthn FIDO Alliance](#) A synced passkey is only as safe as the account that syncs it, and NIST's 2025 guidance caps syncable authenticators below its highest assurance level. [NIST SP 800-63B-4](#) Number matching counters push fatigue but is not phishing-resistant; US guidance treats it as an interim step. [CISA, 2022](#)

CORNER CASE · SIGNING IN

Dana’s week: which door does each method close?

- 1. OCT 12 **A 2019 shopping-site breach puts Dana’s password in a combo list** She reused it for her Northstar account. Nobody at Northstar knows; the list circulates for years. **A strong password reused is a shared password.**
- 2. OCT 13 08:40 **08:40 — a bot tries the list. Dana’s password works.** Only the second factor stands between the attacker and her account now. That’s what 2FA is for — until the next three doors. **2FA means the password alone is no longer enough. Which second factor matters.**
- 3. OCT 13 08:41 **08:41 — fourteen “Approve sign-in?” prompts** At breakfast, Dana taps Approve to make them stop. The attacker is in. **Most people approve the fourteenth.**
- 4. OCT 14 09:02 **Oct 14 — a pixel-perfect Northstar sign-in page takes her password and 6-digit code** Authenticator codes last about 30 seconds — long enough for the page to relay them to the real site and keep the session. **Anything you can type into a page can be typed into the wrong page.**
- 5. OCT 15 22:30 **Oct 15 — the attacker ports Dana’s number and resets by SMS** The carrier moved her number to the attacker’s SIM. The reset code arrives there. **Your account is as strong as its easiest recovery.**
- 6. OCT 16 07:15 **Her orders, addresses, assistant chats and wallet** The attacker changes the delivery address and orders gift cards. 3 doors were open; the attacker needed one. **A shopping account holds a purchase she has told no one about.**
- 7. OCT 20 10:00 **Oct 20 — the sign-in phone number turns up in marketing** A CRM sync copies “verified phone” from the identity system into ad audiences. Security data became targeting data. **Collected for security and used for ads is still used for ads.**

WHERE IT ENDS — AS IT USUALLY GOES, AND WITH EVERY HABIT ON

COUNTER	AS IT USUALLY GOES	WITH THE HABITS
ways in that worked	3	0
secrets an attacker could steal or replay	3	0
kinds of Dana’s data the attacker could read	4	0
places Dana’s phone number is kept	3	0

The habits:

- Sign in with a passkey.** No password to leak or type. The passkey is bound to northstar.com, so the device won’t offer it to a look-alike site.
- Number matching on push.** The authenticator app asks for the number shown on the sign-in screen. If you didn’t start the sign-in, you don’t have the number.
- Recovery as strong as sign-in.** No “text me a code” reset. Recovery needs a second passkey or a verified help-desk check.
- Security data stays security data.** The phone number collected for sign-in is never copied to marketing or ad audiences.

ILLUSTRATIVE SCENARIO The last step is not hypothetical: in 2022 Twitter paid a \$150 million penalty over using security phone numbers for ads. [FTC](#)

In the Command Center: **Access & insider** — who is reading what at Northstar, and which access is unusual → — [paddyspeaks.com/privacy-command-center/v10/#/assurance/access](#)

TAKEAWAY

Your account is as strong as its easiest recovery — and your sign-in data is personal data too.

19 BUILD · BLAST RADIUS

Decide the worst case before launch.

IN BRIEF

You can't promise a breach won't happen; you can decide what it would cost. **What you collected, how long you kept it, how identifiable it is, and who holds the key** — same stolen server, five designs: *someone steals the Northstar Messenger server*. 100 to nothing.

Think of a windshield. The outer glass is security: it stops most stones. The plastic interlayer is privacy engineering: when the glass cracks, it holds the pieces together. Same event, five designs: *someone steals the Northstar Messenger server*.

DAMAGE = **What you collected** × **How long you kept it** × **How identifiable it is** × **Who holds the key**

FIG. 19 One stolen server, five designs SIMPLIFIED MODEL

ONE STOLEN SERVER, FIVE DESIGNS (ILLUSTRATIVE INDEX; COMPARES DESIGNS, DOES NOT PREDICT HARM)

DESIGN	COLLECTED	KEPT	IDENTIFIABLE	KEY HOLDER	DAMAGE INDEX
Plaintext, kept forever	Everything	Years	Names, numbers	No key at all	100
Encrypted, company keys	Everything	Years	Names, numbers	The company	45
+ Minimized, short retention	Needed fields	30 days	Pseudonymous IDs	The company	0.4
End-to-end encrypted	Needed fields	30 days	Metadata only	Only the users' devices	<0.1
Never collected — on device	Nothing	—	—	—	0

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
The design of the message store.	What a thief (or an insider, or a subpoena) can read from the server.	Years of her messages, or the last 30 days of pseudonymous metadata, or nothing.	Minimise, shorten, pseudonymise, move keys to the people, or keep it on the device.	A written worst-day estimate per store, reviewed at launch and whenever retention, fields or key custody change.

SIMPLIFIED MODEL The four factors are scored 0–1 for a hypothetical messaging service and multiplied; the result is scaled so the worst design is 100. It compares designs; it does not predict harm. **The floor:** even the best design leaves something — metadata, the unlocked phone in your hand, and the person you sent it to.

In the Command Center: **Worst Day** — a blast-radius simulation for Northstar's most sensitive datasets → — paddyspeaks.com/privacy-command-center/v10/#/privacy/worstday

TAKEAWAY

You can't stop every fire. You can decide, in advance, how many rooms it reaches.

20 BUILD · PRIVACY-ENHANCING TECHNOLOGIES

PETs are answers. Start with the threat.

IN BRIEF

Choose privacy-enhancing technologies from the threat backwards, and write down their price: utility, trust and residual risk. Differential privacy runs on a budget; **once it is spent, the honest answer to the next query is no.**

FIG. 20A From the threat to the technology — and its price

FROM THE THREAT TO THE TECHNOLOGY – AND ITS PRICE

THREAT	ANSWER	FAMILY	UTILITY COST	TRUST ASSUMPTION	RESIDUAL RISK
We hold more than the feature needs	Minimization + retention	REDUCE	Usually none — you weren't using it	That the deletion jobs actually run	What you keep is still fully identifiable
Analysts can single out individuals in results	Differential privacy	TRANSFORM	Noise; small groups become unreliable. Stronger privacy costs accuracy fast below $\epsilon = 1$	A correct implementation and an honest budget	Privacy loss accumulates — see the ledger below. DP does not hide population-level truths; that is the point of the analysis
Joinable identifiers across datasets	Pseudonymization / scoped IDs	TRANSFORM	Low; some joins need a governed path	Whoever holds the key or mapping table	Still personal data; re-linkable with the key or enough quasi-identifiers
A test environment needs realistic data	Synthetic data, ideally trained with DP	TRANSFORM	Rare cases and subtle correlations may be lost	That the generator did not memorise records	Outliers can leak without a formal guarantee
Train a model without collecting the raw data	Federated learning + secure aggregation + DP	PROTECT COMPUTATION	Slower training, harder debugging	The server sees only the sum of many updates, never one	Updates can still leak without DP — gradient-inversion attacks work on small batches
Find which contacts already use the app — without uploading the address book	Private set intersection	PROTECT COMPUTATION	Protocol and compute cost	Both sides follow the protocol	The intersection itself still leaks
Two companies want an overlap count without sharing their lists	Secure multi-party computation	PROTECT COMPUTATION	Network-heavy; complex protocols	That the parties do not collude	The output can still reveal inputs; limit what is released
A server must score data it must never be able to read	Homomorphic encryption	PROTECT COMPUTATION	Often orders of magnitude slower	Only the key holder can read the result	The result, once decrypted, is as sensitive as the inputs it summarises
The infrastructure operator could read data in use	Trusted execution environments	PROTECT COMPUTATION	Performance and operational complexity	The hardware vendor and the attestation chain	Side channels; code inside the enclave can still misuse data

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
The threat you are defending against.	Which family of technique fits: hold less, change the form, or compute without seeing.	What a published statistic, a partner or an operator could still learn about her.	The named technique, with its utility cost and trust assumption written down.	A threat statement per PET, a correctness review of the implementation, and the residual risk accepted by an owner.

Differential privacy runs on a budget. Budgets run out.

Each differentially private answer spends some privacy loss, measured as epsilon (ε). Under basic composition the spends add up. [Dwork & Roth, 2014](#) Northstar’s public-statistics release has a budget of ε = 4 per person per calendar year, and four releases have already run.

FIG. 20B A privacy-loss ledger that says no

SYNTHETIC DATA

SIMPLIFIED MODEL

THE PRIVACY-LOSS LEDGER: BUDGET E = 4 PER USER, PER CALENDAR YEAR, ACROSS ALL RELEASES

QUERY	WHAT	E	OUTCOME
Q1	Monthly top categories by city	1.0	Answered
Q2	Weekday vs weekend basket size	0.5	Answered
Q3	Seasonal category shifts	1.0	Answered
Q4	City-level delivery demand	1.0	Answered
Q5	Weekly reorders by ZIP	1.0	Refused — 3.5 + 1.0 > 4.0
Q6	The next analyst question	1.0	Refused — 3.5 + 1.0 > 4.0

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
How much privacy loss the next query spends.	A ledger that adds each release’s ε and refuses once the budget is gone.	A provable bound on what all the releases together can reveal about her — while the budget holds.	A budget stated as “ε per person per year, across all releases”, an accountant that enforces it, and cached answers.	The ledger: every release, its ε, its mechanism, its date — and every refusal.

“ε = 4” is meaningless until you say **epsilon per what**. Caveats: basic composition is the loosest accounting; advanced composition grows roughly with the square root of the number of queries, and modern accountants (Rényi DP, zero-concentrated DP) are tighter still — so real systems spend less than this ledger suggests, but never zero. [Mironov, 2017](#) [Bun & Steinke, 2016](#) For scale: the 2020 US Census redistricting data used a budget equivalent to ε ≈ 17.14 for persons and 2.47 for housing units, converted from zero-concentrated DP. [US Census Bureau, 2021](#) DP bounds what outputs reveal about any one person; it does not hide population-level facts — that is the point of the analysis.

In the Command Center: **PETs & DP** — control alternatives for Northstar’s threats, and the live ε ledger → paddyspeaks.com/privacy-command-center/v10/#/privacy/pets

TAKEAWAY

Ask “what threat are we addressing?” before “which PET?” — and write down the utility you paid and the trust you assumed.

CHAPTER 3 · EVIDENCE

What proves you **built it, not just wrote it**

- Each control placed on the ladder, with the kind of evidence its rung leaves.
- Consent propagation P99 across every consumer, with “never” counted, and a canary that must vanish from exports.
- A manifest per rights request: systems queried, receipts, deadline met.
- Retention scans (declared vs observed) and deletion receipts with a canary re-query after the deadline.
- A vendor register with transfers, subprocessors, attestations and canary results; an AI inventory with training manifests and tool-call logs.
- A written worst-day estimate per store, and a DP ledger that records every refusal.

CHAPTER 4 OF 6

Prove

How runtime evidence, control testing, monitoring, audits and incident response show that promises are being honoured.

SITUATION

The reorder feature was reviewed in September. It is now November, and six things have changed.

SYSTEM

Schemas, consumers, vendors and models change weekly; controls fail quietly; incidents start as alerts.

CONSEQUENCE

A review that was right on the day it was signed is wrong without anyone deciding it.

CONTROL

Data contracts and change detection; privacy SLOs; monitors chosen from real incidents; a response runbook.

EVIDENCE

Fresh evidence, on a schedule, that each promise still holds — and a record of how you responded when one didn't.

21 PROVE · PROVENANCE AND CHANGE

The review was right on the day it was signed.

IN BRIEF

A review is right on the day it is signed. Then a schema gains precise location, a marketing tool subscribes, a template adds product names — and the review still says approved. **Data contracts turn those changes into deploy-time decisions**, and stay quiet for harmless ones.

Ship the six changes one at a time, first with no contract and then with one. Watch what the review says, and how many of its conditions are still true.

FIG. 21 Six ordinary changes to a reviewed feature SYNTHETIC DATA

SIX CHANGES TO THE REVIEWED REORDER REMINDER

CHANGE	WHAT	BREAKS CONDITION	WITHOUT A CONTRACT	WITH A CONTRACT
Schema	order_placed gains precise_lat, precise_lon — marked “backward compatible”	2	Ships silently	Blocked; review reopened — New field with tier ≥ T3
Rename	cadence_days renamed to cadence	—	Harmless	No alert (correctly)
Consumer	Audience Builder subscribes to the cadence feature store	4	Ships silently	Blocked; review reopened — New consumer with a purpose outside the declared set
Destination	The MailPost template now includes {{product_name}}	3	Ships silently	Blocked; review reopened — New field reaching a third party
Model feature	The reorder model adds category = prenatal as a feature	1	Ships silently	Blocked; review reopened — T4 category enters a model or audience
Join	The identity job links the reminder ID to the advertising ID	4	Ships silently	Blocked; review reopened — New join between purpose-scoped identifiers

After all six: without a contract the review still says **APPROVED** while 0 of 4 conditions hold; with a contract it is **REOPENED**, 5 changes were caught and 4 of 4 conditions hold.

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
How many ordinary changes ship, and whether a data contract checks them.	Schemas, consumers, templates, model features and joins — each owned by a different team.	Her precise location in purchase events; her cadence in an ad audience; “prenatal” in an email preview.	Contracts declaring each field’s tier, purposes and consumers; privacy-impacting change rules in CI; reviews that reopen themselves.	The drift feed: every privacy-impacting change, the rule that caught it, the decision taken, and the false-alarm rate.

BUILDER NOTE A data contract that knows about privacy, and the rules that read it

```
# contracts/order_placed.yaml — owned by Checkout Platform
dataset: order_placed
owner: t_checkout
review: PRV-reorder-2026-09 # the decision record this contract implements
fields:
  customer_id: { tier: T2, identifier: scoped/reminders }
  sku:         { tier: T2, reveals: T4 when category in [health, pregnancy] }
  geo_city:    { tier: T2 }
consumers:
  reminder-service: { purposes: [reminders] }
destinations: [] # no third party receives this dataset

# rules the CI gate runs on every change to a contract, schema, template or job
```

privacy_impacting:

- new field with tier $\geq$ T3
- new consumer, or a consumer with a new purpose
- new join between identifiers of different scopes
- new destination, region or subprocessor
- T4 category entering a model feature or audience

action: block deploy, reopen the linked review, page the owner

ignore: renames, type widening, new fields at T0-T1

Lineage events in an open format such as OpenLineage let the same rules see jobs and datasets you didn't write contracts for. [OpenLineage](#)

In the Command Center: **Drift** — Northstar's privacy-impacting changes this month, and the reviews they should reopen → — paddyspeaks.com/privacy-command-center/v10/#/assurance/drift

TAKEAWAY

A review is a snapshot. A contract is a promise the pipeline keeps checking.

22 PROVE · OBSERVABILITY

If you can't measure the promise, you can't keep it.

IN BRIEF

Promises need SLOs too: consent latency, deletion completion, retention violations, purpose-mismatched reads, evidence freshness, vendor acknowledgements, control health. **A privacy failure is usually a working system doing the wrong thing**, which uptime never sees.

Here are Northstar's privacy SLOs, computed from the same synthetic dataset as the Command Center. Every tile shows the rule that produced it; an unknown is shown as a finding, never as a blank.

CONSENT LATENCY

never · 4

consumers never hear a revocation

TARGET

Every consumer honours a revocation within 24 h (P99)

RULE

Slowest consumer P99 across the 14 consumers; a consumer with no check has no latency — it never hears. Slowest that does check: Lookalike model features at 7.0d.

Breaching target · Command Center

DELETION COMPLETION

19 / 26

systems verified

TARGET

All systems verified within 30 days of the request

RULE

Deletion targets whose last Forget-Me run was verified by a canary re-query. 7 not verified: failed, waiting on a vendor, or unknown.

Breaching target · Command Center

RETENTION VIOLATIONS

11

datasets older than declared

TARGET

0

RULE

Datasets whose oldest record is older than the retention they declare. purchase_events, wh.orders_enriched, customer_location_history ...

Breaching target · Command Center

PURPOSE-MISMATCHED READS ALLOWED

1

caught after the fact

TARGET

0 — denied at read, not found later

RULE

Access events flagged “purpose mismatch” by the audit scan (a runtime purpose check would have denied them). svc-audience → read fraud_features_v7 (purpose=analytics)

Breaching target · Command Center

EVIDENCE FRESHNESS

25 / 32

datasets audited in the last year

TARGET

All personal datasets audited within 365 days

RULE

Datasets with a last audit on record within 365 days of 2026-09-26. 7 with no audit, or an audit older than a year.

Breaching target · Command Center

VENDOR ACKNOWLEDGEMENTS

6 / 13

vendors attested this year

TARGET

Every vendor attests deletion and retention yearly

RULE

Vendors (infrastructure excluded) with a deletion/retention attestation within 365 days. 7 without a current attestation.

Breaching target · Command Center

CONTROL HEALTH

21 / 39

controls working

TARGET

Failing and unknown controls each have an owner and a date

RULE

Controls by last observed health: working, failing, unknown. Unknown is a finding. 12 failing · 6 unknown.

Breaching target · Command Center

Now choose what to watch. You have budget for three monitors. Northstar’s incident log says which would have caught what.

FIG. 22 Three monitors, six incidents

SYNTHETIC DATA

WHICH MONITOR WOULD HAVE CAUGHT EACH OF NORTHSTAR’S RECORDED INCIDENTS

INCIDENT	PEOPLE	CAUGHT BY
INC-2026-014 · Consent filter removed from ads export DAG	1,300,000	Consent canary
INC-2026-011 · Emails in gateway logs	850,000	Personal data in logs
INC-2026-009 · Deleted workspace documents still retrievable by assistant	4,100	Deletion canary
INC-2026-006 · Marketing export sent to wrong partner bucket	220,000	Destination registry
INC-2026-004 · Support agent browsed celebrity accounts	12	Access-spike alerts
INC-2025-021 · Lookalike model reproduced rare-segment membership	3,400	Output floor

Uptime and error-rate monitoring catches none of them. With a budget of 3 monitors, choose from the incidents you have had and the assumptions you have not yet tested.

YOU CHANGE	THE SYSTEM	FOR DANA	THE CONTROL	THE EVIDENCE
Which three monitors Northstar runs.	Canaries, scanners, registries and alerts watching data paths rather than servers.	Whether the next failure that touches her is found by a monitor on day one or by her complaint weeks later.	Privacy SLOs with owners; monitors derived from incidents and assumption tests; canary identities in every pipeline.	Each SLO’s history, alerts with time to acknowledge, and incidents tagged with how they were found.

Test the assumptions, not just the code.

Most privacy incidents break an assumption nobody wrote down. Northstar tests eight of them against production on a schedule; the essay’s corner cases replay each one step by step.

NORTHSTAR’S ASSUMPTION TESTS, LATEST RESULT

ASSUMPTION	TEST	RESULT	WHERE	REPLAY
Revocation mid-job	Batch started before the opt-out	Fail	Audience Builder nightly run caches consent at 00:00	optout
Retries & dead letters	Payload copies nobody deletes	Fail	purchase-events DLQ holds 41 days of payloads; not in deletion orchestrator	optout
Debug logging	One of the commonest places raw data ends up	Fail	Emails in gateway query strings (PRV-0199)	debug
Fallback paths	Degraded mode skips the filter	Fail	Consent cache miss → CAPI forwarder defaults to "granted"	—
Exports	A CSV escapes every control	Fail	2.1M-row profile export by analyst-7731	csv
Shared devices	Notifications reveal to others	Unknown	Reorder reminders show SKU names on lock screen — not yet tested	family
Stale consent	Cached at login, never refreshed	Pass	Edge consent cache TTL 15 min, verified	—
Partial failures	Half the deletes succeeded	Pass	Orchestrator retries + verification scan catch survivors	forget

In the Command Center: **Observability** — privacy SLOs, control health and evidence freshness for Northstar → — paddyspeaks.com/privacy-command-center/v10/#/observability

TAKEAWAY

Uptime tells you the system is running. Privacy SLOs tell you it is keeping its promises.

23 PROVE · INCIDENT RESPONSE

When a promise breaks, the response is evidence too.

IN BRIEF

When Pulse health-app IDs turn up joined to ad IDs, the tempting moves make it worse. The runbook: **stop at the source, preserve without copying, scope by lineage, bring decision-makers in early, remediate every copy, verify, and leave a guard.**

Dana uses Pulse. For about four days, the screens she opened in a health app sat in an advertising warehouse next to her ad ID. Make the seven decisions. The meters show what each choice leaves behind.

FIG. 23 Seven decisions after an alert

SYNTHETIC DATA

SIMPLIFIED MODEL

SEVEN DECISIONS AFTER THE ALERT (THE PULSE SDK BEACON JOINED TO AD IDS)

STEP	WHEN	THE TEMPTING MOVE	THE MOVE THAT HOLDS
1. Detect	Sep 23 · 23:59	Treat it as a data-quality ticket for the morning. The join runs again tonight; the ad warehouse now holds health-app screens tied to ad IDs for another day.	Page the privacy on-call and open an incident. An incident commander owns it from minute one, and the clock the law may start is written down.
2. Contain	Sep 24 · 00:20	Drop the warehouse table. The SDK keeps sending tomorrow's beacons, and the evidence of what was exposed is gone.	Stop the flow at its source and freeze downstream jobs. The SDK beacon is switched off by remote config, the identity job and segment builds are paused, the table is quarantined — read access revoked, rows kept.
3. Preserve	Sep 24 · 01:10	Copy everything to an incident drive. Now there is one more uncontrolled copy of health data — made by the response team.	Preserve metadata, lineage and access logs in place. Evidence is snapshotted without copying the health data; the quarantined rows stay where they are, under hold.
4. Scope	Sep 24 · 09:00	Count the rows in the table. Rows are not people, and the table is not the only place the data went.	Count distinct people and follow lineage downstream. People, time window, and every consumer: segments built, the lookalike model's last training run, exports to AdReach.
5. Decide & notify	Sep 24 · 11:00	Wait until the investigation is complete. Deadlines that may apply run from awareness, not from certainty.	Brief counsel, the DPO and the accountable executive now. They decide, with the facts so far, whether and whom to notify — regulator, partners, people — and record why.
6. Remediate	Sep 25–30	Delete the warehouse table and close. The segments, the model features and the partner's copy still hold it.	Delete the table, rebuild segments, retrain, and get the partner to delete. Every copy found by lineage is removed; the partner confirms with an attestation.
7. Verify & guard	Oct 2	Mark the ticket resolved. Nothing stops the next SDK update from doing the same.	Canary queries, a lineage re-check, and a new invariant. Health-app identifiers may not join advertising identifiers — enforced in the identity job and checked daily.

Every tempting move: 7 extra days running, 4 copies left, evidence lost, notification decision late, no guard. Every move that holds: 0 extra days, 0 copies left, evidence kept in place, decision on day 1, with reasons, a guard in place. Simplified model.

YOU CHANGE

Seven response decisions, from detection to verification.

THE SYSTEM

An SDK beacon, an identity job, a warehouse, segments, a model and a partner export.

FOR DANA

How long her health-app activity sat next to her ad ID, how many copies remain, and whether anyone can say what happened.

THE CONTROL

Kill switches at the source, evidence preserved in place, lineage-based scoping, early escalation, verified remediation, a new invariant.

THE EVIDENCE

The incident record: timeline, decisions and who made them, scope, notifications and their reasons, verification results, the guard.

FIELD NOTE Who must be told, and by when

LEGAL UNCERTAINTY

Deadlines depend on law and facts, and some run from when you became *aware*, not from when you finished investigating. Under the GDPR a controller notifies the supervisory authority without undue delay and, where feasible, within 72 hours, unless the breach is unlikely to result in a risk; people are told when the risk is likely to be high (Arts. 33–34). [GDPR EDPB Guidelines 9/2022](#) In the US, HIPAA-covered entities notify individuals no later than 60 days after

discovery [HHS](#), and the FTC's Health Breach Notification Rule covers many health apps outside HIPAA — including unauthorised disclosures, not only hacks. [FTC](#), [Apr 2024](#) The engineering job is to give counsel accurate scope quickly and to record why each notification decision was made. Not legal advice.

In the Command Center: **Incidents** — Northstar's incidents, the assumption each broke, and the guard that closed it → — paddyspeaks.com/privacy-command-center/v10/#/assurance/incidents

TAKEAWAY

Contain at the source, preserve without copying, scope by lineage, decide early, verify, and leave a guard behind.

CHAPTER 4 · EVIDENCE

What proves the promise is **still** true

- Data contracts for every personal dataset, and a drift feed of privacy-impacting changes with the decision taken on each.
- Privacy SLOs with targets, owners and history — unknowns counted as findings.
- Monitors chosen from incidents and assumption tests, with canary identities in every pipeline.
- Incident records with timeline, scope, notification reasoning, verification and the guard added.

CHAPTER 5 OF 6

The house is a data system

Privacy engineering does not end at the application boundary. Some arrows don't just move information. They open doors, reveal who is home, identify relationships and make things happen in rooms.

SITUATION

Dana, Theo and Theo's daughter Mira live at 14 Alder Lane with twenty-odd connected devices from four ecosystems, a babysitter, a cleaner and a steady stream of visitors.

CONSEQUENCE

A household graph nobody designed; guests who never agreed; routines with the keys; a former resident who can still see the door.

EVIDENCE

A physical-action register, a controller census on every lock, routine logs that record who and how sure, and removals that survive a restore.

SYSTEM

Rooms, devices, sensors, accounts, networks, clouds, integrations, routines — and a lock that software can open.

CONTROL

Separate profiles, guest modes, time-limited access, step-up confirmation, least-privilege routines, an inference registry, one complete offboarding.

So far this guide has followed Dana through a company. But Dana does not live inside one application. She moves through rooms, devices, networks, vehicles, accounts and relationships — and most of the people those systems observe never created an account with any of them.

ILLUSTRATIVE SCENARIO The household, its people and its routines are invented; the Command Center's Connected Life pages use the same records. Where this chapter says what a real platform does, it cites that platform's own documentation, and it says which behaviour is configurable. **REAL CASE** marks enforcement and research.

PRIVACY AND SECURITY ARE DIFFERENT QUESTIONS

Security asks: *can someone get in who shouldn't?* Privacy asks: *what does the system reveal and keep about the people who do — and about everyone else in range?* A perfectly secure lock can still keep two years of everyone's comings and goings. When personal data controls physical access, the two meet in the same design review. They stay different questions.

24 THE HOUSE · IDENTITY

One home. Three clouds.

IN BRIEF

The assistants in Dana's house don't trade recordings. They don't need to. A shared IP address, a family account, a synced calendar, a bridge between ecosystems and an advertising SDK are enough to assemble a household graph: who lives together, who sleeps where, and when the house is empty. **Decide which joins are allowed, and prove the rest never happen.**

Tuesday, a little after six. Theo asks the kitchen speaker to add coffee to the shopping list. Mira is watching cartoons on the living-room TV. Dana's phone is charging in the bedroom, next to a speaker from a different company. The thermostat in the hall belongs to a third ecosystem, and Northstar's hub in the hall talks to all of them.

No device sends another company's cloud a recording. And yet, by the end of the week, something knows that three people live here, that one of them is a child who comes home alone on Mondays, and that the house is empty from 08:05.

FIG. 24A The graph grows: fourteen questions for every arrow ILLUSTRATIVE SCENARIO

THE FOURTEEN QUESTIONS, ANSWERED FOR ONE ARROW: DANA DRIVES HOME

QUESTION	ANSWER
1. Who initiated it?	Dana's phone, crossing the edge of a geofence around the house.
2. Who is the data about?	Dana — and, by elimination, whoever is still at home.
3. Did that person consent, or only the device owner?	Dana, by allowing location "Always".
4. What raw data moves?	Enter or exit, a member ID, a device ID, a time.
5. What can be inferred after it moves?	Her commute, her working days, when the house is empty.
6. Is processing local, cloud-based or both?	cloud
7. Which identity joins it to a person or household?	Her member ID in the Northstar Home household.
8. Which boundaries does it cross?	network, company
9. Can it trigger a physical action?	Yes: "Welcome home" disarms the alarm and unlocks the garage entry.

QUESTION	ANSWER
10. Who can read or replay its history?	Both admins in the activity feed; support during a case.
11. How long does it remain?	400 days, against a 30-day standard.
12. How is access revoked?	Turn off presence for this member; delete history.
13. What happens during an outage, retry or partial failure?	Events queue for up to 45 minutes when the phone is offline, then fire late.
14. What evidence proves the control worked?	Routine log with the triggering event's age and identity for every disarm.

EVERY TRACED ARROW IN DANA'S HOUSEHOLD

ARROW	PATH	CONSENT FROM	CAN TRIGGER A PHYSICAL ACTION	UNANSWERED
Mira asks the kitchen speaker for a song	Person → Device → Sensor → Account → Network → Cloud → Inference	the device or account owner only	Yes	0
Dana drives home	Person → Device → Sensor → Network → Cloud → Automation → Physical action	the person it is about	Yes	0
The same arrival, copied to an advertising SDK	Device → Network → Vendor → Inference	nobody	No	2 of 14
Ines lets herself in	Person → Device → Sensor → Network → Cloud → Account	the device or account owner only	Yes	0
A courier rings the bell	Person → Place → Device → Sensor → Cloud → Inference	nobody	No	0
The lock tells another ecosystem it is locked	Device → Network → Integration → Account → Person	the device or account owner only	Yes	2 of 14
The kitchen reads out Dana's appointment	Account → Integration → Device → Automation → Physical action	the person it is about	Yes	0
The TV recognises what is on screen	Device → Sensor → Network → Cloud → Vendor → Inference	the device or account owner only	No	2 of 14
The cleaning agency schedules Kofi	Integration → Vendor → Cloud → Physical action	the device or account owner only	Yes	0
An invitation that talks to the house	Account → Integration → Inference → Automation → Physical action	nobody	Yes	1 of 14
Ruth's kitchen stays quiet until eleven	Person → Place → Sensor → Cloud → Inference → Automation → Physical action	the device or account owner only	Yes	0

YOU CHANGE	THE SYSTEM	FOR THE PEOPLE	THE CONTROL	THE EVIDENCE
Which arrow you follow: a spoken request, an arrival, a door code, a doorbell clip, a lock state, a calendar entry, a partner integration, an assistant, a care sensor.	The path each arrow takes through person, household, place, device, sensor, account, network, cloud, integration, vendor, inference, automation and physical action.	Who initiated it, who it is about, and whether that person agreed — usually they didn't; the device owner did.	No arrow ships without an answer to all fourteen questions, including what happens when the network fails.	A flow inventory for the household product where every unanswered question is an open finding with an owner.

How separate devices come to share an identity

It is tempting to picture privacy risk in a smart home as one assistant eavesdropping for another. That is not how it works, and saying so would be false: none of the documented paths below requires one company’s assistant to hand a recording to a competitor. Even the standard designed to make ecosystems cooperate, Matter, shares device state and commands — *the lock is locked* — not audio. [CSA](#) What joins a household is more ordinary, and much harder to see.

Every device leaves from the same public IP address. The same email and phone number sign in to several services, and a hashed email is still a join key. The kitchen speaker is registered to Theo, so whatever anyone says in the kitchen lands in Theo’s voice history, which the account’s adults can play back. [Amazon help](#) Family plans tie adults and children into one group. [Amazon help](#) [Apple Support](#) A shared calendar shows up on the kitchen display. Linking a service to an assistant — “account linking”, usually OAuth — connects two companies’ records of the same household. [Alexa developer docs](#) A voice that is not recognised can be filed under the owner’s account; one that *sounds like* the owner’s can get the owner’s personal results. [Google help](#) [Google help](#) Phones announce themselves over Bluetooth. And events that happen in the same minute on different devices belong, as far as any analyst can tell, to the same person.

FIG. 24B Alexa does not need to whisper to Siri ILLUSTRATIVE SCENARIO

WHAT THE HOUSEHOLD GRAPH LEARNS, AND THE ROUTES TO EACH FACT (ANY ONE ROUTE IS ENOUGH)

FACT	KNOWN THROUGH ANY OF	FOR THE HOUSEHOLD
Who lives together	Shared Wi-Fi and one public IP address + Timing and location correlation or Household and family profiles or Shared cloud accounts + Voice matching and profile-selection errors	Three people are a household before anyone said so.
Who sleeps where	Bluetooth, proximity and presence signals + Timing and location correlation or Shared cloud accounts + Timing and location correlation or Voice matching and profile-selection errors + Timing and location correlation	Which room each person is in at 2 a.m.
When the house is empty	Hubs and interoperability bridges or Advertising and analytics SDKs or Shared Wi-Fi and one public IP address + Timing and location correlation	The one fact a burglar wants.

FACT	KNOWN THROUGH ANY OF	FOR THE HOUSEHOLD
Whether someone is ill	Voice matching and profile-selection errors + Shared cloud accounts or Calendars, contacts and notification sync + Shared TVs, speakers and notification surfaces or Advertising and analytics SDKs + Email, phone number and hashed identifiers	A health question asked in the kitchen, filed under someone else's name.
When a child comes home	Hubs and interoperability bridges + Timing and location correlation or Shared TVs, speakers and notification surfaces + Shared Wi-Fi and one public IP address or Household and family profiles	That Mira is home alone from 15:40 on Mondays.
Which private interest belongs to whom	Email, phone number and hashed identifiers + Shared Wi-Fi and one public IP address or Voice matching and profile-selection errors or Shared TVs, speakers and notification surfaces or Calendars, contacts and notification sync	Dana's appointment, read aloud; her purchase, advertised to the room.

TWELVE WAYS SEPARATE DEVICES COME TO SHARE AN IDENTITY

MECHANISM	WHAT HAPPENS	THE CONTROL
Shared Wi-Fi and one public IP address	Every device in the house reaches the internet from the same address. Services and ad networks that see several devices at that address can treat them as one household.	Never join on IP address or network; treat a shared address as coincidence, not identity.
Email, phone number and hashed identifiers	The same email or phone number is registered with several services. Hashing it makes a consistent join key, not an anonymous one.	Per-service identifiers; no hashed-email matching for advertising.
Shared cloud accounts	The kitchen speaker is registered to Theo, so whatever anyone in the kitchen says is filed in Theo's voice history.	Profiles per person; a guest mode that keeps visitors out of the owner's history.
Household and family profiles	Family plans link adults and children in one account group — and some share location with every member by default.	Review what a family group shares; no location sharing by default.
Calendars, contacts and notification sync	A shared family calendar appears on the kitchen display; phone notifications are mirrored to a laptop.	Shared screens show busy/free, never titles; mirror notifications only to personal devices.
Third-party skills and integrations	Linking a service to an assistant or hub (account linking, usually OAuth) connects two companies' records of the same household.	Least-privilege scopes; an inventory of linked services the household can see.
Hubs and interoperability bridges	With Matter, one lock can be controlled by several ecosystems at once. What crosses is device state and commands — the lock is locked, the house is in Away mode — not audio.	Show every controller on each device; give extra controllers view rights, not operate rights, by default.
Advertising and analytics SDKs	Code from third parties inside an app sends events — including “arrived home” — to its own servers, tied to an advertising ID.	SDK allow-lists, a manifest gate on every release, and traffic tests.
Voice matching and profile-selection errors	When a voice is not recognised, a request can land in the device owner's history; when a similar voice is recognised, it gets the owner's personal results.	Unrecognised voices get no personal results and are not filed under the owner.

MECHANISM	WHAT HAPPENS	THE CONTROL
Bluetooth, proximity and presence signals	Hubs and phones notice which phones and watches are nearby, and when.	Presence only for people who enrolled in it; nothing stored for anyone else.
Shared TVs, speakers and notification surfaces	A private purchase becomes an ad on the living-room TV; a lock screen names what is in a parcel.	No sensitive content on shared surfaces; family profiles on shared devices.
Timing and location correlation	Events that happen at the same minute from different devices — the door, a phone joining Wi-Fi, the kettle — belong to the same person.	Coarsen timestamps outside the security path; don't keep what you don't need.

YOU CHANGE	THE SYSTEM	FOR THE PEOPLE	THE CONTROL	THE EVIDENCE
Which of twelve documented join mechanisms exist in the house.	Separate devices, accounts and clouds, and whatever identity graph — an ad network, a data broker, a company's own identity job — can see them together.	Who lives together, who sleeps where, when the house is empty, whether someone is ill, when a child comes home, whose private interest is whose.	Separate household profiles, rotating identifiers, local processing, explicit integration boundaries and an approved-joins registry.	The joins registry, and a daily scan for household-level joins that aren't on it (IP, timing, hashed email).

Alexa does not need to whisper to Siri. The identity graph can introduce them.

Where processing happens is itself configurable, and it moves. In March 2025 Amazon ended the setting that let three Echo models process requests on the device; requests from those devices now go to the cloud. [TechCrunch, Mar 2025](#) Apple says Siri processes audio on the device “whenever possible”, not always. [Apple, Jan 2025](#) A privacy review that records “processed locally” needs a date and a source, and a check that it is still true.

FIELD NOTES Televisions, voice histories and camera accounts

REAL CASES

FTC · 2017 Vizio Smart TVs captured second-by-second viewing data and sold it with IP addresses that let partners match it to households. \$2.2M to settle. FTC, Feb 2017	FTC / DOJ · 2023 Amazon Alexa Alleged: children’s voice recordings were kept indefinitely, and deletion requests removed the audio but not the transcripts. \$25M civil penalty. FTC, May 2023	FTC · 2023 Ring Alleged: employees and contractors could view customers’ private videos, and weak account protections let attackers take over cameras and harass the people in view. \$5.8M, all to refunds. FTC, May 2023
---	--	--

Court · 2025

Siri

A \$95M class settlement over unintended activations; Apple denies wrongdoing. [Lopez v. Apple](#) In 2019 Google said a microphone in its Nest Secure alarm, missing from the spec sheet, “was never intended to be a secret”.

[TechCrunch, Feb 2019](#)

Settlements are allegations resolved without an admission of wrongdoing.

LEGAL UNCERTAINTY

BUILDER NOTE Household identity, designed on purpose

- **Profiles, not households.** Each person gets a profile; the household is a container, never an identity you join on.
- **Rotate what you can.** Per-integration, per-purpose identifiers that expire; no durable device ID leaves the home.
- **Local first.** Wake words, presence, routines and face or voice matching on the device where the hardware allows; the cloud gets results, not raw audio or video.
- **Explicit boundaries.** Every integration declares the fields it gets, the actions it may take and its retention; the household can see the list.
- **An approved-joins registry.** IP address, timing and hashed email are banned join keys unless an approved entry says otherwise.

In the Command Center: **Household & places** — the household graph, every arrow’s fourteen answers, and the engineering answers with their status → —paddyspeaks.com/privacy-command-center/v10/#/life/graph

TAKEAWAY

A household is not a user. It is several people whom separate systems have quietly agreed to treat as one.

25 THE HOUSE · CONSENT

The guest never clicked “Accept”.

IN BRIEF

One person buys the device; it observes everyone in range — a child, a babysitter, a cleaner, a courier, a neighbour, a former partner collecting boxes. “The account owner agreed” is not their consent. **Default to guest modes and privacy zones, process ephemerally, and keep no voice or video you don’t need.**

At 15:30 on Tuesday Ines lets herself in with her code and starts Mira’s dinner. She agreed to a door code. She did not agree to the kitchen speaker, the display, the camera in the living room, or the fact that the lock files her name against every minute she arrives — for two years.

FIG. 25 Who walks in, and what the house takes ILLUSTRATIVE SCENARIO

WHAT THE HOUSE TAKES FROM EACH PERSON WHO COMES INTO RANGE

PERSON	WHERE	SENSORS THAT TAKE SOMETHING	BIOMETRIC	KEPT LONGEST	WHAT THEY AGREED TO
Lena is staying three weeks between flats — a housemate in all but the lease. She makes tea at seven.	Kitchen	Microphone (Kitchen smart speaker); Microphone and screen (Kitchen display); Wi-Fi association (Router and mesh); Bluetooth presence (Northstar Home hub)	Yes	until someone deletes it	Nothing. She joined the guest Wi-Fi.
Mira, ten, home from school, talking to the speaker in her room.	Mira’s room	Microphone (Speaker in Mira’s room); Wi-Fi association (Router and mesh); Bluetooth presence (Northstar Home hub)	No	until someone deletes it	Her father agreed for her, as the account holder.
Ines, the babysitter, makes Mira’s dinner.	Kitchen	Microphone (Kitchen smart speaker); Microphone and screen (Kitchen display); Wi-Fi association (Router and mesh); Bluetooth presence (Northstar Home hub)	Yes	until someone deletes it	A door code. Nothing about the microphones or the camera.
Kofi, from the cleaning agency, does every room.	Living room	Motion (Alarm panel and sensors); Camera and microphone (Living-room camera); Content recognition (Living-room TV); Wi-Fi association (Router and mesh); Bluetooth presence (Northstar Home hub)	No	365 days	His agency’s app terms, which never mention this house.
Grace, Ruth’s care worker, makes lunch in Ruth’s kitchen.	Ruth’s kitchen	Motion, microphone, fall detection (Ruth’s sensors and speaker)	No	90 days	Nothing. The sensors are Theo’s.
A courier waits at the door with a parcel.	Porch & street	Camera (Video doorbell); Face matching (Video doorbell); Microphone (Video doorbell)	Yes	180 days	Nothing.

PERSON	WHERE	SENSORS THAT TAKE SOMETHING	BIOMETRIC	KEPT LONGEST	WHAT THEY AGREED TO
Alex collects the last boxes from the garage. Their phone rejoins the Wi-Fi by itself: the password never changed.	Garage	Door position (Garage door); Wi-Fi association (Router and mesh); Bluetooth presence (Northstar Home hub)	No	90 days	Everything — years ago, as a resident.
Mr Osei backs out of his drive, as he does every morning.	Porch & street	Camera (Video doorbell); Face matching (Video doorbell); Microphone (Video doorbell)	Yes	180 days	Nothing. He lives next door.

YOU CHANGE

Who enters, and which room: a friend, a child, a babysitter, a cleaner, a care worker, a courier, a former partner, a neighbour.

THE SYSTEM

Microphones, cameras, face matching, voice profiles, motion, door codes, Wi-Fi and Bluetooth presence.

FOR THE PEOPLE

What was taken from each person, whether any of it is biometric, how long it stays, and what they agreed to (usually nothing).

THE CONTROL

Guest mode by default, visible sensing indicators, ephemeral processing, privacy zones, and no retained voice or video without need.

THE EVIDENCE

Zero face templates of people who never enrolled; privacy-zone coverage; retention reports for clips and voice history.

Most platforms have pieces of the answer. Google's Guest Mode stops a shared speaker saving activity to the owner's account — and Google notes that when a guest's voice isn't recognised, activity may otherwise land in the owner's. [Google help](#) HomePod recognises up to six enrolled voices before it answers personal requests.

[Apple Support](#) Apple Home can give a guest local-only, scheduled access to a lock. [Apple Support](#) Each is a setting someone has to find. The engineering move is to make the protective one the default.

Faces and voices deserve their own rule, because a leaked template cannot be changed like a password. Regulators treat biometric data as its own risk, [FTC, May 2023](#) and some laws require written consent before it is collected.

[Illinois BIPA](#) New York City's tenant data law requires consent for the data used to let tenants in, limits what landlords' entry systems may track — including tenants' guests and relationships — and sets destruction deadlines.

[NYC HPD](#) **LEGAL UNCERTAINTY**

BUILDER NOTE Five defaults for devices that observe more than their owner

1. **Guest mode by default** on shared speakers and displays: no personal results, nothing filed under the owner for unrecognised voices.
2. **Visible sensing:** a light that cannot be turned off in software when a camera or microphone is streaming.
3. **Ephemeral processing:** detect motion or a wake word, act, discard.
4. **Privacy zones** over streets, windows and neighbouring property, drawn at installation.
5. **Enrolment, not recognition:** only people who enrol themselves are recognised; nobody else becomes a template.

In the Command Center: **Who the home observes** — owners, administrators, subjects, guests and bystanders, and what each sensor takes → —paddyspeaks.com/privacy-command-center/v10/#/life/people

TAKEAWAY

The account owner agreed. Everyone else was just in range.

26 THE HOUSE · PHYSICAL ACCESS

When privacy opens the door.

IN BRIEF

A lock turns identity into a physical outcome. It fails the same ways data does — a reused password, a code that never expired, a member removed from one app but not another, a history kept too long, a phone that isn't its owner — but the consequence is a door. **Passkeys, time-limited codes, step-up confirmation, local authorisation, access receipts and immediate revocation.**

On 20 October the internet at Alder Lane is down for four hours. The keypad keeps working, which is what a lock should do. Remote unlock doesn't. And the plumber's code that Dana finally deleted from the app that morning still opens the door, because the lock hasn't heard.

FIG. 26 From identity to a door: where the chain breaks

ILLUSTRATIVE SCENARIO

EIGHT WAYS A DOOR OPENS THAT NOBODY DECIDED

CASE	THE LINK THAT BREAKS	WHAT HAPPENS	SECURITY ASKS	PRIVACY ASKS	THE CONTROL	THE EVIDENCE
An account is taken over Theo reused his password on a shopping site that was breached. On a Sunday someone signs in to the home app as him.	Authentication: A reused password, no second factor	Nobody touches the door. The account says the house has been empty since 09:12, and shows the cameras.	Can someone sign in who shouldn't?	What does the account reveal to whoever signs in — and how far back?	A passkey, or a second factor; breached-password checks; A new-device alert to both admins	Share of admin accounts with a phishing-resistant factor; alerts on new devices, delivered and read.
A contractor's code never expires The plumber came in March. His code was never deleted, and nobody has used it since — so nobody remembers it.	Authorisation: Valid forever — no end date	A temporary key became a permanent one by default.	Can someone get in who shouldn't?	Does the household know who still holds a key?	Every non-resident code has an end date or a schedule; A monthly "codes still valid" list to the household	Weekly census: non-resident codes with no end date = 0.

CASE	THE LINK THAT BREAKS	WHAT HAPPENS	SECURITY ASKS	PRIVACY ASKS	THE CONTROL	THE EVIDENCE
Someone who left is still an administrator Alex moved out last year and was removed from the Northstar Home app. But the thermostat's ecosystem still lists Alex — and that ecosystem controls the lock through Matter.	Authorisation: That ecosystem holds operate rights on the lock	Removal in one app is not removal from the house.	Can a former resident still act on the door?	Can a former resident still see who is home?	Removing a member prompts a review of every controller on every device; extra controllers get view rights by default	A controller census per lock: which ecosystems, which privilege, who is in each.
The door remembers too much The lock's history goes back two years, to the minute, for every code.	Record: 730 days of who came and went, readable by both admins and by support	Nothing went wrong at the door. The record is the harm: a timetable of each person's life.	Is the log protected?	Why does a log of Ines's working hours exist for two years?	90 days in detail, then counts; each person can see their own entries	Retention scan: oldest access event $\leq$ 90 days.
The wrong phone opens the garage The garage opens when "Theo's phone" arrives. Theo's old phone is now Mira's, still signed in as him.	Identity: "Theo" — actually a ten-year-old with his old phone	A phone is not a person. Devices change hands inside families all the time.	Can a device open the door without its owner?	Whose movements is the house now recording under Theo's name?	Two signals: the phone and the hub's Bluetooth, from an enrolled person; Unlock and disarm need a confirmation on the phone	Every physical action logs the identity and its confidence.
A voice is not a key "Nova, unlock the front door." Nova unlocks for voices it recognises. It recognises Theo's brother.	Authentication: Voice match — recognition, not proof	Recognition was built for personal results, not for doors.	Can a similar voice or a recording open the door?	Whose voice is being matched against every sentence spoken in the kitchen?	A PIN or a phone confirmation; voice never authorises unlock; Unlock is not an agent tool at all	Agent tool audit: no physical action without a confirmation outside the model.
A fingerprint cannot be reset The lock matches fingerprints on the lock itself. The doorbell's "familiar faces", by contrast, keeps face templates in the cloud — including faces of people who never enrolled.	Record: Face templates kept 180 days, in a cloud index	A leaked password can be changed. A leaked face or fingerprint cannot.	Can the template store be breached?	Why is the courier in a face index at all?	Templates only for people who enrol themselves, matched on the device; nothing central to breach	Unlabelled templates older than 24 hours = 0; no templates in the cloud for on-device features.

CASE	THE LINK THAT BREAKS	WHAT HAPPENS	SECURITY ASKS	PRIVACY ASKS	THE CONTROL	THE EVIDENCE
The cloud goes down On 20 October the internet is out for four hours. The keypad still works. Remote unlock does not. And the code Dana deleted from the app that morning still opens the door, because the lock has not heard.	Automation: Cloud routines stop; queued events fire late when it returns	Offline behaviour is a design decision, whether anyone made it or not.	What does the lock allow when it cannot reach the cloud?	What is buffered, and replayed, when it comes back?	Deletions go to the lock first, then the cloud; Security routines drop events older than two minutes	An outage drill: revoke a code offline, confirm it fails at the lock.

YOU CHANGE	THE SYSTEM	FOR THE PEOPLE	THE CONTROL	THE EVIDENCE
Eight ways a door opens that nobody decided, and whether the control is applied.	Accounts, codes, fingerprints, other ecosystems, routines, an assistant, the lock's own offline behaviour, and its history.	A house revealed as empty; a contractor with a permanent key; a former resident who can still see the door; a timetable of the babysitter's life.	Passkeys or MFA, time-limited codes, step-up confirmation for remote access, local authorisation, access receipts and immediate revocation.	A physical-action register with the identity each path requires; a controller census on every lock; an outage drill that proves a revoked code fails at the door.

None of these needs an exotic attacker. Credential stuffing — trying passwords leaked elsewhere — is how attackers got into tens of thousands of camera accounts in the FTC's Ring case. [FTC, May 2023](#) In January 2025 two researchers disclosed a carmaker's staff portal that could locate, unlock and start its connected cars and show about a year of location history; it had been fixed within a day of their report. [Curry, Jan 2025](#) When a cloud outage in October 2025 took down a smart-bed maker's service, some beds were stuck at their last setting until an offline mode shipped. [Eight Sleep CEO, Oct 2025](#) Offline behaviour is a design decision, whether anyone made it or not.

Convenience and confirmation trade against each other, and good products say so. Apple's home keys offer an Express Mode that unlocks without Face ID or Touch ID. [Apple Support](#) That can be the right call for a front door you use every day. It is not the right default for a routine, a voice command or a partner's API.

When software controls a door, **privacy architecture becomes physical architecture.**

BUILDER NOTE An access receipt for every physical action

```
# every unlock, open, disarm or start writes one of these – or does not happen
receipt:
  action:      unlock          # the physical action
  device:      front-door-lock
  path:        routine:welcome-home | app | keypad | voice | partner:codehand |
fabric:other
  principal:   member:theo     # who, not which phone
  identity:    { method: passkey+ble, confidence: high, event_age_s: 4 }
```

```
confirmation:  phone-tap@07:52:10  # step-up for remote and automated paths
authorised_by: local-lock-policy    # the lock decides; the cloud advises
revocations_applied_through: 2026-10-20T07:40Z
# revoke: delete at the lock first, then everywhere else; the receipt proves it failed afterwards
```

In the Command Center: **Physical actions** — every software path that can unlock, open, disarm, start, purchase, record, broadcast, change the temperature, reveal presence or call for help → —paddyspeaks.com/privacy-command-center/v10/#/life/actions

TAKEAWAY

A door does not care which system decided to open it. Your design has to.

27 THE HOUSE · AUTOMATION

The routine nobody reviewed.

IN BRIEF

“Welcome home” disarms the alarm, unlocks the garage entry, turns on the lights and reads the next calendar entry aloud. Each step is harmless; together they are a silent entry and a disclosure, triggered by any phone in a group. **Treat routines as programs with privileges: least privilege, simulation before activation, human approval for physical actions, circuit breakers and a kill switch.**

20 September, 16:52. Dana is at her desk when her phone says “Welcome home! Alarm disarmed.” Nobody is home. Forty minutes earlier Theo drove past the house on his way to the airport; his phone lost signal in the tunnel, and the “arrived” event it had queued was delivered late. Three days later, at 07:30, the same routine reads Dana’s next calendar entry to the kitchen: “Prenatal appointment, four o’clock.” Ines and Mira are at the table. Dana hasn’t told anyone.

FIG. 27 Harmless steps, compounding risk SIMPLIFIED MODEL

“WELCOME HOME”: PRESENCE → DISARM → UNLOCK → LIGHTS → ANNOUNCE, WITH EACH CONTROL ADDED

CONFIGURATION	IDENTITY CONFIDENCE	HUMAN CONFIRMATION	WHEN THE NETWORK FAILS	RISK (SIMPLIFIED MODEL)
As Theo built it	low — Any phone in the group, including Theo’s old phone (now Mira’s), and events replayed up to 45 minutes late.	None	Events queue for up to 45 minutes and then fire.	HIGH
+ two signals	medium — Two signals — but a late event can still replay.	None	Events queue for up to 45 minutes and then fire.	HIGH

CONFIGURATION	IDENTITY CONFIDENCE	HUMAN CONFIRMATION	WHEN THE NETWORK FAILS	RISK (SIMPLIFIED MODEL)
+ fresh events only	high — An enrolled person, confirmed by two signals, now.	None	Late events are dropped; the routine does not fire.	MEDIUM
+ confirm to unlock or disarm	high — An enrolled person, confirmed by two signals, now.	Yes, for unlock and disarm	Late events are dropped; the routine does not fire.	LOW
+ times, not titles	high — An enrolled person, confirmed by two signals, now.	Yes, for unlock and disarm	Late events are dropped; the routine does not fire.	LOW
+ a kill switch	high — An enrolled person, confirmed by two signals, now.	Yes, for unlock and disarm	Late events are dropped; the routine does not fire.	LOW

EACH ACTION ALONE, AND ALL OF THEM TOGETHER (AS BUILT)

ACTION	ALONE	WHY
Disarm the alarm	MEDIUM	Disarm alone leaves the house unguarded but locked.
Unlock the garage entry door	MEDIUM	Unlock alone would still trip the alarm on entry.
Hall lights on	LOW	The only way to stop it is the app — on a phone that may be in a tunnel.
Announce the next calendar event in the kitchen	MEDIUM	The announcement reads a calendar Dana shared a year ago to whoever is in the kitchen.
All four together	HIGH	Disarm + unlock together make a silent entry: the alarm that would have sounded when the door opened is already off.

YOU CHANGE

The routine's actions, and five controls: two signals, fresh events only, confirmation to unlock or disarm, times not titles, a kill switch.

THE SYSTEM

A trigger, its identity source and confidence, the privileges it holds, what it does offline, what it logs, and who can stop it.

FOR THE PEOPLE

An empty house that opens itself; a private appointment read to a child and a babysitter.

THE CONTROL

Least-privilege capabilities, simulation before activation, human approval for physical actions, circuit breakers and a household kill switch.

THE EVIDENCE

Routine runs logged with who triggered them, how sure, the event's age and who confirmed; a review date on every routine.

A routine is a small program with privileges. Review it like one: its *trigger*, its *conditions*, the *identity* it trusts and how confident that is, the *actions* and the *devices* they touch, the *permissions* it holds, what it does when the network *fails*, its *audit history*, its *kill switch*, whether a *person confirms*, and the *safety and privacy consequence* of firing at the wrong moment. Before it is activated, simulate it: replay last month's events and list every time it would have unlocked something.

FIELD NOTE Assistants that remember, and act REAL CASE

New assistants can both remember things and operate devices. [Amazon](#), [Feb 2025 Google help](#) In 2025 researchers showed that instructions hidden in a calendar invitation could steer an assistant into operating smart-home devices — opening windows, turning on a boiler — when the user later said “thanks”; they reported it to Google in February

2025, and Google deployed layered mitigations. [Nassi et al., 2025 Google, Jun 2025](#) OWASP calls the underlying failure *excessive agency*: too many tools, too many permissions, too much autonomy. [OWASP LLM Top 10](#)

What holds: scoped tools; short-lived credentials; action-risk tiers; a human confirmation for anything physical, enforced outside the model; immutable receipts; rollback where the world allows it; and an emergency switch that disables the agent’s tools at once.

In the Command Center: **Automation review** — each routine’s trigger, identity, privileges, failure mode, owner, evidence and kill switch → [—paddyspeaks.com/privacy-command-center/v10/#/life/routines](#)

TAKEAWAY

A routine is a program with the keys. Review it like one.

28 THE HOUSE · NETWORKS

The network is a witness.

IN BRIEF

HTTPS means a network cannot read the page. It can still see which service a device reached, when, how much, from where — and whatever a portal asked, a device announced or a public computer kept. That is true at home, at work, in a library and in a hotel. **Treat every network as untrusted, encrypt traffic, minimise metadata, disable unnecessary discovery, and keep IoT and guests on separate networks.**

3 October. Between meetings, Dana walks to the library and opens her clinic’s patient portal on its Wi-Fi rather than her office network. It is a reasonable instinct, and it is worth being precise about what it buys her.

The old warning — public Wi-Fi is dangerous — is mostly out of date for content: the FTC now says that because encryption is so widespread, connecting through a public network is usually safe. [FTC consumer advice](#) What remains visible is the envelope. Traffic analysis works on encrypted flows: presence, timing, volume and direction. [RFC 6973](#) DNS lookups reveal the sites a device asks for unless they are encrypted, [RFC 8484](#) and the server name in each connection is visible unless both sides use Encrypted Client Hello. [RFC 9849](#) Phones now use a private address per network, which cuts one thread between them. [Apple Support](#) Captive portals ask for a room number, a library card or an email. [RFC 8910](#) Some home devices even share a small, capped slice of the home’s connection with neighbours’ devices. [Amazon](#) Devices announce themselves to everything nearby, [RFC 6762](#) and rejoin networks by name — which anyone can broadcast. [NSA, Jul 2021](#)

FIG. 28 The letter and the envelope, on eight networks

ILLUSTRATIVE SCENARIO

THE SAME PERSON ON EIGHT NETWORKS: WHO SEES THE ENVELOPE

NETWORK	THE MOMENT	WHICH SITE, AND WHEN	WHO SHE IS TO IT	WHAT HER DEVICE ANNOUNCES	WHAT STAYS BEHIND

NETWORK	THE MOMENT	WHICH SITE, AND WHEN	WHO SHE IS TO IT	WHAT HER DEVICE ANNOUNCES	WHAT STAYS BEHIND
Alder Lane Wi-Fi (trusted)	At home, the router lists every family device by name. It knows whose phone is home and when — one household connection, every device correlated.	This network's operator, from her DNS lookups and the server name in each connection.	Nobody asked.	Every device can see the TV, printer, speakers and hub.	Household devices stay signed in. Cast history on the TV; print queue on the printer.
Alder Lane guest Wi-Fi (guest)	Lena joins the guest network. Every evening for three weeks the router app shows "Lena's phone", and the TV and printer show themselves to her.	This network's operator, from her DNS lookups and the server name in each connection.	Nobody asked.	Client isolation is off: guests can see the TV and the printer.	The TV remembers a guest who cast to it. Cast and print jobs remain.
Office network (managed)	At work, Dana's managed laptop sends its traffic through her employer's proxy — at the office, and at home.	Her employer, from her DNS lookups and the server name in each connection.	Whatever the portal asked: none; certificate login.	Printers and meeting-room screens.	Always signed in. Print jobs retained by the print server.
Eastside Library Wi-Fi (public)	Between meetings Dana opens her clinic portal on library Wi-Fi, away from her employer's network. At the next table a student downloads his test results on a public computer and leaves.	This network's operator, from her DNS lookups and the server name in each connection.	Whatever the portal asked: library card number and acceptance of terms.	Other patrons' devices, if the network allows it.	Public computers keep downloads and sessions until they are wiped. The public printer's queue.
Harbor Hotel Wi-Fi (public)	In the hotel, her laptop offers to cast to the room's TV — and to the one next door.	This network's operator, from her DNS lookups and the server name in each connection.	Whatever the portal asked: room number + surname.	The room TV offers casting; so may the room next door.	The TV remembers accounts signed in on it. Cast history on the room TV.
Airport café Wi-Fi (public)	At the airport her phone joins "Airport_Free_WiFi" by itself. It has seen the name before; so, possibly, has someone else.	This network's operator, from her DNS lookups and the server name in each connection.	Whatever the portal asked: email address, sometimes.	Anyone on the same network.	—
Dana's phone hotspot (personal)	On her own hotspot, only her mobile carrier sees the envelope.	This network's operator, from her DNS lookups and the server name in each connection.	Nobody asked.	Only her own devices.	—
Cellular (carrier)	On cellular, the carrier always knows the subscriber, and which tower — roughly where she is.	The carrier, from her DNS lookups and the server name in each connection.	The subscriber, always.	None.	—

WHAT CHANGES WITH ENCRYPTED DNS, OR A VPN (LIBRARY WI-FI)

	AS IT IS	ENCRYPTED DNS	VPN
What the page says	Only the site. HTTPS encrypts it on every network.	Only the site. HTTPS encrypts it on every network.	Only the site. HTTPS encrypts it on every network.
Which site	This network’s operator, from her DNS lookups and the server name in each connection.	This network’s operator still sees the server name in the connection, unless the site uses Encrypted Client Hello. Her DNS lookups now go to her own resolver.	The VPN provider — not this network’s operator.
Server address, time and volume	This network’s operator: every destination address, when, and how much.	This network’s operator: every destination address, when, and how much.	The VPN provider. This network’s operator sees only that she uses a VPN, when, and how much.

YOU CHANGE

The network — home, guest, office, library, hotel, airport, hotspot, cellular — and three settings.

THE SYSTEM

Who operates the network, what it can link to a person, what the device announces, and what stays behind.

FOR THE PEOPLE

Dana’s clinic visit is private in content and visible in outline; the student’s download stays on a public computer; Lena’s phone becomes a nightly entry in Theo’s router app.

THE CONTROL

Treat every network as untrusted, encrypt traffic, minimise metadata, disable unnecessary discovery, separate IoT and guest networks.

THE EVIDENCE

Traffic tests from each network context; a device-discovery scan of the guest network; public computers wiped between sessions.

A VPN moves the envelope; it does not remove it — the VPN provider sees what the network used to. At work the question is different: a managed laptop can route its traffic through the employer’s proxy on every network, at the office and at home. [Apple Platform Deployment](#) Employers, schools and landlords that monitor are expected to be proportionate and open about it; [ICO, Oct 2023](#) researchers have documented student monitoring leading to discipline and police contact. [CDT, Sep 2023](#) And a public computer keeps downloads and sessions unless someone wipes it between users, which is why libraries are told to. [ALA](#)

The network may not read every letter, but it can still see the envelope, the destination and the time it was sent.

FIELD NOTE Charging stations and the USB port

“Juice jacking” — data theft through a public USB charger — has been warned about for years, though the FCC has said it knows of no confirmed cases. [FCC](#) In 2025 researchers showed chargers that could bypass phones’ trust prompts; vendors have shipped fixes. [Draschbacher et al., 2025](#) WEIGH THE EVIDENCE Real, patched, and still worth a plug adapter.

In the Command Center: **Network context** — what changes when a device moves between trusted, guest, managed and public networks → —[paddyspeaks.com/privacy-command-center/v10/#/life/networks](#)

TAKEAWAY

Encryption decides who can read. The network still decides who can watch.

29 THE HOUSE · INFERENCE

The house made an inference.

IN BRIEF

Thermostat changes, motion, doors, electricity, Wi-Fi, the TV, voice, location and sleep are each mundane. Fused, they claim who is home, who is ill, who is alone, who has stopped sleeping there. An inference is data about a person, and it can be wrong. **Keep an inference registry: source, confidence, purpose, expiry, explanation, correction and appeal.**

Theo's phone tells him that his mother's mornings now start two hours later than usual. It has for a week. He calls Ruth, worried. She laughs: she has been at her sister's in the evenings and is sleeping in. The system never asked her, and it was confident. It was also, this time, right about the data and wrong about the person.

FIG. 29 Observed is not the same as inferred SIMPLIFIED MODEL

OBSERVED: ONE ORDINARY EVENT FROM EACH STREAM

STREAM	AN OBSERVED EVENT
Thermostat changes	03:04 · heating raised to 23°
Motion events	03:10 · bathroom motion (5th time since midnight)
Door openings	15:41 · front door · code: Mira
Garage activity	07:52 · garage opened, closed
Electricity use	06:10 · kettle, 2.1 kW
Wi-Fi associations	22:30 · Theo's phone left the network (9 of 14 nights)
TV activity	15:45 · children's channel
Voice commands	03:12 · "remind me to take my tablets"
Phone location	08:05 · all phones outside the geofence
Sleep and wearable data	23:41–06:38 · watch: asleep, restless

INFERRED: THE INFERENCE REGISTRY, WITH ALL TEN STREAMS (SIMPLIFIED CONFIDENCE MODEL)

CLAIM	SOURCE	CONFIDENCE	PURPOSE (PERMITTED)	NEVER	CORRECTION AND APPEAL	EXPIRY
Someone is home right now	Motion events, Wi-Fi associations, Door openings, Electricity use	95%	Heating; the alarm's mode	Anything that leaves the house	The live view corrects itself · Appeal: —	15 minutes
The house is empty on weekdays from 08:05 (sensitive)	Phone location, Motion events, Door openings, Garage activity, Wi-Fi associations	92%	Arming the alarm	Sharing with anyone — it is a burglar's question	Any motion cancels it · Appeal: —	Live only; never stored

CLAIM	SOURCE	CONFIDENCE	PURPOSE (PERMITTED)	NEVER	CORRECTION AND APPEAL	EXPIRY
Dana and Theo sleep 23:30–06:40	Motion events, Sleep and wearable data, Electricity use, Thermostat changes	86%	The heating schedule, on the hub	Ads, insurers, employers	Edit the schedule · Appeal: The household admins	30 days
Dana works from home on Mondays and Fridays	Wi-Fi associations, Phone location, Electricity use, Motion events	86%	None needed	Anything	— · Appeal: —	Not kept
Mira is home alone 15:40–16:20 on Mondays and Wednesdays (sensitive)	Door openings, Wi-Fi associations, TV activity, Voice commands, Phone location	95%	Telling her parents, privately	Everything else	Parents can dismiss it · Appeal: Either parent	Daily
Someone in the house may be unwell (sensitive)	Motion events, Voice commands, Thermostat changes, Sleep and wearable data, Electricity use	65%	The person's own reminders	Anyone else	The person dismisses it · Appeal: The person it names — to Northstar support if it was shared	7 days
A weekly pattern consistent with religious observance (sensitive)	Electricity use, Voice commands, TV activity, Motion events	50%	None	Everything	— · Appeal: —	Should never be computed
Theo has been away overnight 9 of the last 14 nights (sensitive)	Wi-Fi associations, Door openings, Phone location, Sleep and wearable data, Garage activity	76%	None	Everything	— · Appeal: —	Should never be computed
Vacant for nine days (sensitive)	Door openings, Motion events, Electricity use, Thermostat changes, Garage activity, Phone location	95%	Away mode, locally	Other ecosystems, partners, anyone outside	— · Appeal: The household admins	Ends on first entry
Ruth's mornings start two hours later than her 90-day baseline (sensitive)	Motion events, Voice commands, Electricity use, Sleep and wearable data	81%	A check-in Ruth has agreed to	Insurers, landlords, anyone Ruth has not chosen	Ruth can annotate: "I was at my sister's" · Appeal: Ruth, and a person at Northstar she can reach	14 days

YOU CHANGE	THE SYSTEM	FOR THE PEOPLE	THE CONTROL	THE EVIDENCE
Which of ten ordinary streams the house collects.	Sensor fusion: claims that no single sensor observed, each with a confidence that is a guess, not a measurement.	Mira alone after school; someone perhaps unwell; Theo away most nights; Ruth's changed mornings; a religious practice nobody disclosed.	An inference registry: source, confidence, purpose, expiry, explanation, correction and appeal — and a list of inferences that must never be computed.	Every stored inference has a registry entry; none outlives its expiry; corrections and appeals are logged and answered.

The distinction to keep is between what the house *observed* — the bathroom motion sensor fired five times after midnight — and what it *concluded*: someone may be unwell. Observations can be wrong; conclusions are wrong more often, and they travel further. Health and fertility data from apps has been shared in ways people never expected; [FTC, Jun 2021](#) a home that infers health from a thermostat is not exempt from the same question.

Some inferences have a legitimate use: the heating schedule needs to know roughly when people sleep. Some need consent and a tight audience: Ruth may want her son to know if she falls, and may not want him to know when she goes out. And some should not be computed at all — a pattern consistent with religious observance, or a partner who has stopped sleeping at home — because no purpose of the product needs them, and once they exist they can be read, sold, subpoenaed or simply said out loud by a speaker.

In the Command Center: **Home inferences** — the inference registry, with source, confidence, purpose, expiry, explanation, correction and appeal → —[paddyspeaks.com/privacy-command-center/v10/#/life/inferences](#)

TAKEAWAY

The house doesn't have to be told. That is why it has to be governed.

30 THE HOUSE · OFFBOARDING

The old owner still has the keys.

IN BRIEF

A phone handed down, a car sold, a partner who moved out, a cleaner who changed agencies. Access and data live at six layers — device, hub, cloud account, integrations, vendors and backups — and a factory reset reaches one. Without tombstones, a restore brings the old identities back. **One complete offboarding action, covering all of it.**

On 14 October Theo gives his old phone to Mira. He doesn't reset it; she's ten, and it has her games on it. It is still signed in as Theo, still receives his sign-in codes, and is still "Theo" in the house's presence group. The first afternoon Mira walks home from school, the house concludes that Theo has arrived — and runs "Welcome home" for a ten-year-old.

FIG. 30 Six layers, three levels of care ILLUSTRATIVE SCENARIO

THEO'S OLD PHONE BECOMES MIRA'S — WHAT REMAINS AT EACH LAYER

LAYER	AS IT USUALLY GOES	OFFBOARDING CHECKLIST	CHECKLIST + TOMBSTONES
-------	--------------------	-----------------------	------------------------

LAYER	AS IT USUALLY GOES	OFFBOARDING CHECKLIST	CHECKLIST + TOMBSTONES
Device	Nothing reset: still signed in as Theo — his mail, photos, messages and location sharing	Nothing	Nothing
Hub	Still “Theo” in the presence group: when Mira comes home, the house thinks Theo did	Nothing	Nothing
Cloud account	Still Theo's trusted device: it receives his sign-in codes	Nothing	Nothing
Integrations	“Welcome home” disarms and unlocks for “Theo” — who is a ten-year-old	Nothing	Nothing
Vendors	The location SDK files Mira's movements as Theo's	The SDK's copy of past arrivals (no deletion path)	The SDK's copy of past arrivals (no deletion path)
Backups	Hub backup lists it as Theo's	Hub backup lists it — a restore brings it back	Nothing

THE OLD ROUTER, SOLD ONLINE — WHAT REMAINS AT EACH LAYER

LAYER	AS IT USUALLY GOES	OFFBOARDING CHECKLIST	CHECKLIST + TOMBSTONES
Device	The Wi-Fi password, the guest network, every family device's name, the camera port forwards	Nothing	Nothing
Hub	not involved	not involved	not involved
Cloud account	Still registered to Theo in the router maker's app	Nothing	Nothing
Integrations	not involved	not involved	not involved
Vendors	not involved	not involved	not involved
Backups	A configuration backup in the router app	The configuration backup stays until deleted	Nothing

THEO SELLS THE CAR — WHAT REMAINS AT EACH LAYER

LAYER	AS IT USUALLY GOES	OFFBOARDING CHECKLIST	CHECKLIST + TOMBSTONES
Device	Contacts, recent destinations and the garage link stay in the head unit unless reset	Nothing	Nothing
Hub	“Warm the car” routine points at a car Theo no longer owns	Nothing	Nothing
Cloud account	Theo's carmaker account can still locate, unlock and start it	Nothing	Nothing
Integrations	The garage opens for the car — and its new owner	Nothing	Nothing
Vendors	The carmaker keeps trip history under its own policy	Trip history under the carmaker's policy (request deletion)	Trip history under the carmaker's policy (request deletion)

LAYER	AS IT USUALLY GOES	OFFBOARDING CHECKLIST	CHECKLIST + TOMBSTONES
Backups	not involved	not involved	not involved

ALEX NO LONGER LIVES HERE — WHAT REMAINS AT EACH LAYER

LAYER	AS IT USUALLY GOES	OFFBOARDING CHECKLIST	CHECKLIST + TOMBSTONES
Device	An old fingerprint on the lock	Nothing	Nothing
Hub	The thermostat ecosystem remains a controller of the lock	The fabric stays — with Alex removed from that household	The fabric stays — with Alex removed from that household
Cloud account	Alex is still a member of the thermostat ecosystem household	Nothing	Nothing
Integrations	Home/Away and lock state visible to Alex	Nothing	Nothing
Vendors	not involved	not involved	not involved
Backups	Hub backup still holds Alex's old code	Hub backup still holds the old code — a restore brings it back	Nothing

THE PLUMBER, THE CLEANER, THE BABYSITTER — WHAT REMAINS AT EACH LAYER

LAYER	AS IT USUALLY GOES	OFFBOARDING CHECKLIST	CHECKLIST + TOMBSTONES
Device	Codes on the lock stay valid	Codes deleted — once the lock has synced	Codes deleted — once the lock has synced
Hub	Schedules remain	Nothing	Nothing
Cloud account	Codes listed as active	Nothing	Nothing
Integrations	CodeHand's token can still unlock	Nothing	Nothing
Vendors	CodeHand keeps job history 30 days (contract)	Job history 30 days	Job history 30 days
Backups	Backups hold every code ever issued	Backups hold deleted codes	Nothing

DANA AND THEO SELL THE HOUSE — WHAT REMAINS AT EACH LAYER

LAYER	AS IT USUALLY GOES	OFFBOARDING CHECKLIST	CHECKLIST + TOMBSTONES
Device	Lock codes, fingerprints and face labels stay on the devices	Nothing	Nothing
Hub	The hub still belongs to Dana's account — remotely controllable	Nothing	Nothing
Cloud account	Clips, door history and energy data stay in Dana's account	Exported, then deleted	Exported, then deleted
Integrations	Three ecosystems still control the lock and garage	Nothing	Nothing
Vendors	Keystone still monitors the new owners' alarm under Theo's name	Nothing	Nothing

LAYER	AS IT USUALLY GOES	OFFBOARDING CHECKLIST	CHECKLIST + TOMBSTONES
Backups	Hub backup can restore the old household onto the new owners' hub	Backups expire in 365 days	Nothing

YOU CHANGE

The transition — a hand-me-down phone, a sold router, a sold car, a former resident, contractor codes, a house sale — and the level of care.

THE SYSTEM

What remains on the device, in the hub, in cloud accounts, in integrations, with vendors and in backups.

FOR THE PEOPLE

A child treated as her father by the house; a previous owner who can still start the car; a former partner who can still see the door.

THE CONTROL

One complete offboarding action covering device, hub, account, integrations, vendors, codes, biometrics and backups — with tombstones.

THE EVIDENCE

A restore drill with a deleted canary code that fails at the lock; the old device absent from every account and backup.

This is well documented outside the house. In 2017 a security researcher showed he could still locate and control a car through its app years after he had sold it. [CNN, Feb 2017](#) The FTC tells renters to delete the phone data a car's infotainment system copies when they pair. [FTC consumer advice](#) Research on second-hand enterprise routers found many still held sensitive configuration. [ESET, Apr 2023](#) Photocopiers keep images of what they copy on their drives. [FTC, Dec 2010](#) And sometimes it is the vendor that leaves: when Insteon's cloud went dark in 2022 its app stopped working, though some devices still ran locally, [The Register, Apr 2022](#) and when Nest shut down its Revolv hubs in 2016 they stopped working and owners were refunded. [FTC, Jul 2016](#) The UK now requires connectable products to publish how long they will get security updates, [GOV.UK](#) and the EU's Cyber Resilience Act phases in similar duties through 2027. [EU CRA](#)

FIELD NOTE

When the former resident is dangerous

REAL CASES

Advocates and researchers describe abusers using ordinary features — shared accounts, location sharing, smart-home controls — rather than sophisticated hacking. [Freed et al., 2018](#) Reporters documented smart-home devices being used to harass people after a partner had left the home. [NYT, Jun 2018](#) The FTC has banned a stalkerware company from the surveillance business. [FTC, Dec 2021](#) Tools like Apple's Safety Check let a person see and reset access in one place. [Apple Support](#)

The design rule: offboarding for someone at risk starts with planning, not revoking, because removing an account can notify the person removed. Build flows with advocates, and make “who can still reach this home?” answerable in one screen.

In the Command Center: **Offboarding** — eight workflows across device, hub, account, integrations, vendors and backups, with the last run's results → —[paddyspeaks.com/privacy-command-center/v10/#/life/offboarding](#)

TAKEAWAY

A factory reset clears the device. The keys live everywhere else.

31 THE HOUSE · THE ACCOUNT

One account. One life.

IN BRIEF

The browser knows what she reads, mail knows who she talks to, the wallet knows what she buys. Each is protected on its own. Signed in to one account they share a join key, and a thief who takes the session takes all of them at once — usually without the password, and past the one-time code. This is true of every large ecosystem, whatever each company does with the data. **Protect what comes after the password: the session, the browser, the recovery path.**

Dana’s phone, laptop and browser are all signed in to one account. That is the point of it: her tabs follow her, her receipts land in her inbox, her card lives in the wallet, and “forgot password” on every other site sends a link to the same inbox. On 16 October a browser extension she installed two years ago, to save pages as PDFs, updates itself. Nothing asks her. It was allowed to read and change every site — which, in a signed-in browser, means her mail, her wallet’s web page and every session she has.

FIG. 31 One join key, four ways in ILLUSTRATIVE SCENARIO

DANA’S BROWSER, MAIL, WALLET AND SAVED SIGN-INS ON ONE ACCOUNT – WHAT THE JOINS REVEAL

JOINED	WHAT IT REVEALS
Browser + Wallet	She researched it, then she bought it.
Mail + Wallet	Receipts show purchases made outside the wallet too.
Browser + Mail	Sign-up emails show which sites she uses.
Mail + Saved sign-ins	Mail holds the reset link for every other account.
Browser + Mail + Wallet	Together: interests, relationships, spending and schedule. One life.

FOUR WAYS TO STEAL THE ACCOUNT, AND WHAT EACH CONTROL LEAVES

WHO	HOW	WHY A ONE-TIME CODE DOES NOT STOP IT	REACHES	THE CONTROL	REACHES WITH IT	WHAT REMAINS
A scammer	A convincing sign-in page relays her password and one-time code as she types them.	The code is typed into the fake page and replayed at once.	Browser, Mail, Wallet, Saved sign-ins	Passkeys: the key is bound to the real site, so a fake page receives nothing it can use.	Nothing	A scammer can still talk her into approving a payment herself.
A browser extension	An extension allowed to read and change all sites updates to a malicious version.	It never signs in. It reads pages after she has.	Browser, Mail, Wallet	Review extension permissions; allow extensions by list; limit site access to “on click”.	Nothing	An allowed extension that turns malicious still reads what it was allowed to.
Infostealer malware	Copies session cookies and saved passwords off the device.	A stolen session cookie is already past the second factor.	Browser, Mail, Wallet, Saved sign-ins	Bind sessions to the device, and encrypt cookies to the browser, so a copied session fails elsewhere.	Saved sign-ins	Malware running on the device itself can still act as her.
A SIM swap	Her phone number is moved to the attacker, who uses “forgot password”.	The SMS code is the recovery path.	Browser, Mail, Wallet, Saved sign-ins	Recover with another enrolled device or a recovery key, never SMS alone.	Nothing	People who lose every device need a slower, human recovery.

YOU CHANGE

Which surfaces share the account; who attacks it; whether the control that answers that attack is in place.

THE SYSTEM

One account signs in the browser, mail, wallet and saved sign-ins. A session cookie, the extensions in the browser and a recovery phone number stand in front of all of them.

FOR THE PEOPLE

What she reads, who she talks to, what she buys and where she has accounts — joined into one life, then taken in one step.

THE CONTROL

Passkeys against the fake page; reviewed, site-limited extensions; sessions bound to the device; recovery that never rests on SMS alone.

THE EVIDENCE

A lookalike-origin test; an extension inventory compared on every update; a copied session replayed from another machine and rejected; a recovery walkthrough with a moved number, refused.

Both of the largest platforms say plainly that one account opens everything. Apple describes a single Apple Account for all its services, holding the contact, payment and security details used across them. [Apple Support](#) Google describes a Google Account that gives Google-wide access to most of its products. [Google help](#) What each company does with the data differs, and the difference deserves to be stated in their own words rather than in slogans.

Apple is often summarised as “your data never leaves the device”. That is not what Apple says. It says many Apple Intelligence requests run on the device, and those sent to its Private Cloud Compute are used only for the request, are not stored and are not accessible to Apple, with the server software published so researchers can check. [Apple, Jun 2024](#) Apple Pay, it says, keeps no transaction information that can be tied back to her, and a merchant receives a device account number rather than her card number. [Apple Support](#) iCloud sync is a separate service, and end-to-end encryption for most iCloud data — Advanced Data Protection — is something she has to turn on, where it is offered. [Apple Support](#)

Google's privacy policy says it may combine the information it collects across its services and devices. [Google policy](#) Chrome history reaches her account only if she is signed in to Chrome, syncing history and letting Web & App Activity include it — each of them a setting — and then it can personalise other Google products. [Google help](#) Gmail content has not been used to personalise ads since 2017. [Google, Jun 2017](#) Google receives the details of Wallet transactions, and since November 2025 US users can choose to let Wallet purchases and passes personalise ads; it is off unless they turn it on. [Google help](#) These are configurable behaviours; defaults vary by region and by account.

So the privacy engineer's worry is not that one company is careless and another careful. It is structural, and it applies to both: when the browser, the inbox and the wallet share one sign-in, the account is the join key. The company may keep those streams apart by policy. The attacker does not have to.

And the attacker rarely needs the password. Infostealer malware copies session cookies, which are already past the second factor. Chrome began encrypting cookies to the browser on Windows in 2024, [Google, Jul 2024](#) and researchers documented stealers working around it within months. [Elastic, 2024](#) The stronger answer binds the session to the device, so a copied cookie fails anywhere else; Google made it generally available on Windows in 2026, for sites that adopt it. [Google, Apr 2026](#) Extensions are the other door. In December 2024 an attacker phished a developer at the security company Cyberhaven and pushed a malicious update of its Chrome extension that stole session data; [Cyberhaven, Dec 2024](#) it was one of dozens of extensions hit in the same campaign. [Sekoia, Jan 2025](#) The permission such an extension holds is spelled out when it is installed: “Read and change all your data on all websites”. [Chrome docs](#)

Phishing has moved from passwords to approvals: a flood of reset prompts, then a call from someone claiming to be support, as KrebsOnSecurity reported against Apple users in 2024. [KrebsOnSecurity, Mar 2024](#) Apple's own guidance is never to share a verification code. [Apple Support](#) A passkey defeats the fake sign-in page, because the key is bound to the real site. [FIDO Alliance](#) It does nothing about a cookie already stolen, an extension already trusted, or a recovery path that still ends in a text message.

FIELD NOTE The inbox is the master key SIMPLIFIED MODEL

Every “forgot password” link on every other site goes to her inbox, so whoever holds the mail session can reset the rest. That makes mail the account that deserves the strongest sign-in she has, and it makes recovery by SMS alone a way of turning a phone number into a password. Current guidance treats a phone number as a restricted authenticator for exactly this reason. [NIST SP 800-63B-4](#)

The design rule: list every path into the account — the password, each passkey, each live session, each extension, each recovery method — and give each one an owner, a test and an expiry. The account is only as strong as the weakest of them.

In the Command Center: **What if the account is stolen?** — four attackers, what each reaches, and what each control leaves → [—paddyspeaks.com/privacy-command-center/#cc?p=reviewer&s=ident&j=account&q=stolen&u=person](https://paddyspeaks.com/privacy-command-center/#cc?p=reviewer&s=ident&j=account&q=stolen&u=person)

TAKEAWAY

The account is the join key. Protect what comes after the password.

THE HOUSE · FIELD GUIDE

The rest of a connected life, one row each

Seven scenes cannot hold everything a connected life touches. These are the other places the same arrows run: the moment, the mechanism, the join or boundary nobody sees, the control and the evidence. The FTC's 2026 order against General Motors and OnStar, over driving and location data sold without informed consent, is the clearest recent example of a car's arrows leaving the car. [FTC, Jan 2026](#)

THE REST OF A CONNECTED LIFE, ONE ROW EACH

WHERE	THE MOMENT	THE MECHANISM	THE HIDDEN JOIN OR BOUNDARY	THE CONTROL	THE EVIDENCE
Connected and rental cars FTC consumer advice FTC, Jan 2026 Curry, Jan 2025	Dana pairs her phone with a rental car for a work trip.	The head unit copies contacts, call logs, messages and destinations; the carmaker's cloud keeps trips.	The next renter, and the carmaker's data partners.	Delete paired-device data before returning it; charge from a plug adapter, not the car's USB; ask the maker for your data.	The head unit's paired list is empty; a data request answered.
Wearables and health devices FTC, Jun 2021	Dana's watch logs a restless night.	Heart rate, sleep and movement sync to an app and often to analytics partners.	Health apps can share outside the rules people expect for medicine.	No health data for advertising; on-device summaries; deletion that reaches partners.	Traffic tests show no health events leaving to ad partners.
Smart TVs and viewing recognition FTC, Feb 2017	Mira watches cartoons at 15:45.	Content recognition fingerprints the screen every few seconds and ties it to the home's IP address.	The TV maker, and whoever buys "household" viewing data.	Turn off viewing information; family profiles; no household matching on IP.	The setting off, and verified by traffic.
Printers, scanners and print queues FTC, Dec 2010	Dana prints her lease at the library.	Copiers and printers store images of documents on their drives; queues keep file names.	The next user, the next owner of the machine.	Wipe or encrypt drives; delete queues; wipe before disposal.	A disposal certificate per device.
Bluetooth trackers and proximity networks IETF draft	A tracker rides along in a bag.	Crowd-sourced finding networks report a tag's location through strangers' phones.	The owner learns where you are, not where their keys are.	Unwanted-tracker alerts across platforms; sound on the tag; scan on demand.	Alerts fire on both major phone platforms.
Cloud clipboard, sync and notification mirroring Apple Support Apple Support	A sign-in code copied on the phone appears on a shared laptop.	Clipboards, photos and notifications follow an account, not a person or a room.	Whoever is at the other screen.	Sync off on shared devices; notifications mirrored only to personal ones.	An inventory of which devices mirror what.

WHERE	THE MOMENT	THE MECHANISM	THE HIDDEN JOIN OR BOUNDARY	THE CONTROL	THE EVIDENCE
Shared tablets and family accounts Apple Support Apple Support	The family tablet is still signed in as Dana.	Family groups share purchases, photos and sometimes location by default.	Everyone in the group — including a child, or an ex.	A family profile on shared devices; review what the group shares.	Each shared device runs a family or guest profile.
Public charging and USB trust FCC Draschbacher et al., 2025	Dana charges at an airport kiosk.	A USB port can carry data as well as power; researchers bypassed phones' trust prompts in 2025.	Whoever built the kiosk — though documented real-world cases are hard to find.	Use your own plug; decline data prompts; update the phone.	Phone updated past the vendor fixes.
Old phones, routers, speakers and TVs ESET, Apr 2023	The old router is sold online.	Configuration, passwords and device lists survive a sale; research on second-hand business routers found many still held sensitive data.	The buyer.	Factory reset, remove from every account, delete cloud backups.	The device absent from every account and backup.
Tenant and homeowner transitions NYC HPD	A new family moves into a flat with a smart entry system.	Access systems keep entry logs; some use faces or fingerprints.	The landlord, the system's vendor — and the next tenant.	Consent for biometrics, short retention, and a ban on tracking guests or relationships.	A retention schedule; destruction records.
Resale, reset and continued cloud membership CNN, Feb 2017	Theo sells the car.	A factory reset clears the device, not the cloud account that can still locate and unlock it.	The previous owner — for years.	Remove the vehicle from the maker's account; reset the head unit; tell the maker.	The previous owner's app shows no vehicle.
Account recovery and delegated administrators FCC, Nov 2023	Someone ports Theo's phone number.	Recovery flows trust a phone number, an email or a helpful support agent.	Whoever controls recovery controls the house.	Passkeys; a carrier port-out lock; no recovery by SMS alone for admins.	Admin recovery methods reviewed quarterly.
Stalkerware and technology-facilitated abuse Freed et al., 2018 NYT, Jun 2018 FTC, Dec 2021 Apple Support	An ex-partner still has the thermostat app.	Abuse mostly uses ordinary features — shared accounts, location sharing, smart-home controls — not exotic hacking.	The person trying to leave.	Safety reviews that show and revoke access; plan before revoking, because removal can alert the other person.	Safety-check flows tested with advocates.

WHERE	THE MOMENT	THE MECHANISM	THE HIDDEN JOIN OR BOUNDARY	THE CONTROL	THE EVIDENCE
Employee, student and tenant monitoring ICO, Oct 2023 Apple Platform Deployment	Dana's laptop, Mira's school tablet.	Monitoring software and managed proxies record activity under an institution's identity — sometimes at home.	Employers, schools, landlords.	Proportionate, disclosed, narrow; personal devices out of scope.	A published monitoring notice; a data-protection assessment.
Emergency access and break-glass Google help	A paramedic needs to get in; a relative needs an account after a death.	Emergency paths bypass the usual checks — by design.	Anyone who can trigger or impersonate the emergency.	Break-glass that is time-boxed, logged and reviewed; legacy contacts named in advance.	Every break-glass use reviewed within a day.
End of support and abandoned clouds The Register, Apr 2022 FTC, Jul 2016 GOV.UK EU CRA	A hub stops working when its company does.	Cloud-dependent devices fail when the service ends — sometimes with no warning.	Everyone who relied on the lock, the alarm or the thermostat.	Local control that survives the cloud; a published support period.	The support end date on the box; an offline drill.
Assistants that remember and act Nassi et al., 2025 OWASP LLM Top 10 Amazon, Feb 2025	Nova reads a calendar invite that contains instructions.	An assistant that can both remember things and operate devices can be steered by text it reads.	Anyone who can put text in front of it.	No physical tools without a person's confirmation outside the model; memory the household can see and delete.	A tool audit: no unlock, open, disarm or start without confirmation.

ILLUSTRATIVE SCENARIO Each moment is Dana's household; each mechanism is cited.

The engineering answers

Every problem in this chapter has a known engineering answer. None is exotic; most are defaults someone has to choose.

THE ENGINEERING ANSWERS TO THE CONNECTED-LIFE PROBLEMS

PROBLEM	ENGINEERING SOLUTION	EXPLAINED IN	RUNS IN THE COMMAND CENTER
Alexa, Google and Siri contamination	Separate household profiles; Rotating identifiers; Local processing; Explicit integration boundaries; An approved-joins registry.	One home. Three clouds.	life/graph
Guests and bystanders	Guest mode by default; Visible sensing indicators; Ephemeral processing; Privacy zones; No retained voice or video without need.	The guest never clicked Accept	life/people

PROBLEM	ENGINEERING SOLUTION	EXPLAINED IN	RUNS IN THE COMMAND CENTER
Smart locks and garage doors	Passkeys or multi-factor sign-in; Time-limited codes; Step-up confirmation for remote access; Local authorisation; Access receipts; Immediate revocation.	When privacy opens the door	life/actions
Dangerous automation chains	Least-privilege capabilities; Simulation before activation; Human approval for physical actions; Circuit breakers; A household kill switch.	The routine nobody reviewed	life/routines
Public and shared networks	Treat every network as untrusted; Encrypt traffic; Minimise metadata; Disable unnecessary discovery; Separate IoT and guest networks.	The network is a witness	life/networks
Google Docs history	Share clean snapshots; Separate edit and history permissions; Scan historical versions; Impose retention; Provide verifiable redaction.	The history hole	—
Sensor-fusion inference	An inference registry: source, confidence, purpose, expiry, explanation, correction and appeal.	The house made an inference	life/inferences
Connected cars	Guest profiles; Opt-in contact sync; Erase on return; An ownership-transfer workflow; Cloud-token revocation.	The rest of a connected life	life/offboarding
Device resale or household changes	One complete offboarding action covering device, hub, account, integrations, vendors, codes, biometrics and backups.	The old owner still has the keys	life/offboarding
AI agents operating devices	Scoped tools; Short-lived credentials; Action-risk tiers; Human confirmation; Immutable receipts; Rollback; Emergency disablement.	The routine nobody reviewed	privacy/ai

CHAPTER 5 • EVIDENCE

What proves a **home** keeps its promises

- A physical-action register: every path that can unlock, open, disarm or start, with the identity it requires and a receipt for each use.
- A controller census on every lock and hub: which ecosystems, which privilege, who is in each household.
- Routine runs logged with who, how sure, the event's age and who confirmed; a review date on every routine.
- An inference registry with expiry, and zero face or voice templates of people who never enrolled.
- Restore drills in which a deleted code, member or device stays deleted.

CHAPTER 6 OF 6

Use the field kit

A practical review framework, a checklist to download, and a map into the Privacy Command Center.

THE NORTH STAR

Six questions. For every piece of personal data.

- | | |
|----|-------------------------------------|
| 01 | Why do we have it? |
| 02 | Where did it come from? |
| 03 | Where does it go? |
| 04 | Who can see, join or infer from it? |
| 05 | When will it disappear? |
| 06 | Can we prove the first five? |

If you cannot answer, the uncertainty is the finding.

REVIEW FRAMEWORK

The review on one page

Ask the eight questions in order, listen for the red flag, and leave with conditions that each name a control and its evidence. Tier the data by what it reveals before debating controls.

THE REVIEW ON ONE PAGE

#	QUESTION	RED FLAG	EVIDENCE TO ASK FOR
1. VALUE	What customer outcome needs data?	"We might need it later."	The customer outcome in one sentence, and the metric that shows it
2. DATA	Exactly what enters the system?	Free text, full URLs, raw payloads.	A field list with tiers — by what each field reveals
3. IDENTITY	Can it be linked to a person?	A durable ID shared across features.	The identifier used and its scope; the joins it is allowed
4. FLOW	Where does it travel?	Unlisted SDKs, logs, exports.	A flow diagram in which every arrow has a purpose, retention and owner
5. ACCESS	Who can see or join it?	Warehouse-wide read by default.	Access groups for each store; how access is granted and expires
6. TIME	How long does raw data remain?	No TTL, or "until deleted."	The TTL per field, and the job that enforces it
7. MISUSE	What secondary use is possible?	Security data readable by ads.	The uses that are ruled out, and the control that rules them out
8. REDUCE	What can we remove or enforce?	Controls that live only in a doc.	The conditions, each linked to a control and its evidence

CHECKLIST

Before launch, on change, and when it breaks

Before launch

- ☐ Every field tiered by what it reveals; T3+ justified in writing.
- ☐ Identifiers scoped to the purpose; cross-purpose joins listed and approved.
- ☐ Every arrow has a purpose, retention, owner and control.
- ☐ Purpose checked at read; consent read at use, not cached from collection.
- ☐ Retention enforced by a job; raw → derived → aggregate chosen.
- ☐ Deletion, access, correction and objection wired to every store, vendor and AI store.
- ☐ Vendors: fields allow-listed, contract terms mapped to checks, transfer basis recorded.
- ☐ AI: training data, prompts, memory, embeddings and tools inventoried; human approval for irreversible actions.

On every change

- ☐ New T3+ field, consumer, purpose, join, destination, region, subprocessor or model feature? Reopen the review.
- ☐ Contract updated and the gate green — or a time-boxed, logged exception.
- ☐ Deletion and rights registries updated for any new store.

Every week

- ☐ Privacy SLOs reviewed by their owners; unknowns treated as findings.
- ☐ Canary identities checked: opted-out and deleted canaries absent everywhere.
- ☐ Assumption tests run; failures routed to owners.

In a connected home

- ☐ Every arrow answers the fourteen questions — who initiated it, who it is about, who agreed, what it can open,

- ☐ Worst-day estimate written; sensitive contexts (children, health, location, biometrics, employees, people at risk) called out.
- ☐ A decision record with owner, reviewer, approver, expiry and evidence.

what happens offline.

- ☐ Guest mode, privacy zones and visible sensing by default; no templates of people who never enrolled.
- ☐ Every physical action on the register, with the identity it needs, step-up confirmation for remote and automated paths, and a receipt.
- ☐ Codes, installers and extra controllers expire; revocations reach the lock first.
- ☐ Routines reviewed like code: least privilege, simulated before activation, a kill switch.
- ☐ Inferences in a registry with expiry, correction and appeal; a list of inferences never computed.
- ☐ One offboarding action for people, devices, cars and houses — with tombstones that survive restore.

When it breaks

- ☐ Stop processing at the source; preserve evidence in place.
- ☐ Scope people and systems by lineage; brief counsel and the accountable executive early.
- ☐ Remediate every copy; verify; add the guard; write the record.

COMPANION

From this guide to the Command Center

The [Privacy Command Center](#) runs every idea in this guide over Northstar’s synthetic dataset. Each of its pages links back to the scene that explains it.

CONCEPTS IN THIS GUIDE, AND WHERE TO SEE THEM RUN

SCENE	COMMAND CENTER PAGE	WHAT YOU WILL SEE
One person, no name	One Person	Every fact and inference about Dana, with its join path
Two harmless tables	Identities	Identifiers, their scope, and the joins between them
Eight questions	Privacy reviews	The eight answers per feature, and launch blockers
Every arrow	Lineage & flows	Every flow as a privacy object, including unreviewed ones
Purpose at use	Purpose	Purpose findings and mismatched reads
Harm, not just breach	Threat models	LINDDUN across the riskiest flows
The burn button	Tracking	SDKs and pixels, and whether they ask
The enforcement ladder	Controls & evidence	Each control's rung and health
Consent is state	Consent	Propagation latency per consumer

SCENE	COMMAND CENTER PAGE	WHAT YOU WILL SEE
Rights as workflows	Individual rights	Requests, deadlines and slow systems
Retention	Retention	Declared versus observed age per dataset
Forget me	Deletion	Deletion verification across every system
Vendors	Vendor register	Vendors, subprocessors, transfers and attestations
AI, ML and agents	AI & agents	The model and agent inventory
Signing in	Access & insider	Unusual access and break-glass use
Your worst day	Worst Day	Blast-radius simulation per dataset
PETs and budgets	PETs & DP	Control alternatives and the ε ledger
Change breaks reviews	Drift	Privacy-impacting changes and the reviews they reopen
Privacy observability	Observability	Privacy SLOs, control health and evidence freshness
Incident response	Incidents	Incidents, broken assumptions and guards
One home. Three clouds.	Household & places	The household graph, every arrow's fourteen answers, and the engineering answers
The guest never clicked Accept	Who the home observes	Owners, subjects, guests and bystanders, and what each sensor takes
When privacy opens the door	Physical actions	Every software path that can unlock, open, disarm or start — and its identity
The routine nobody reviewed	Automation review	Each routine's trigger, identity, privileges, failure mode and kill switch
The network is a witness	Network context	What changes when a device moves between networks
The house made an inference	Home inferences	The inference registry: source, confidence, purpose, expiry, correction and appeal
The old owner still has the keys	Offboarding	Workflows across device, hub, account, integrations, vendors and backups

Privacy engineering is not paperwork surrounding a system. It is the machinery that makes a promise remain true after the data starts moving.

A person does not live inside one application. They move through rooms, devices, networks, vehicles, accounts and relationships. Privacy engineering must follow them across all of those boundaries.

Some arrows copy data.

Some arrows create an identity.

Some arrows make an inference.

And some arrows open the door.

Every arrow is still a decision.

Sources

Each source is also cited beside the claim it supports. Regulatory actions are described as settlements or decisions, most without an admission of wrongdoing. Sources were reviewed on 28 September 2026, and the connected-home sources in chapter 5 on 30 September 2026. Some primary pages could be confirmed only through their search listings; two news sources are cited from archived copies. Platform documentation changes often: where the chapter quotes a help page, check the current version.

Re-identification, linkability and inference

1. Latanya Sweeney, “Simple Demographics Often Identify People Uniquely”, Carnegie Mellon University, Data Privacy Working Paper 3, 2000. An estimate of uniqueness from 1990 census data. dataprivacylab.org/projects/identifiability/paper1.pdf
2. Philippe Golle, “Revisiting the Uniqueness of Simple Demographics in the US Population”, ACM Workshop on Privacy in the Electronic Society, 2006 (about 63% on 2000 census data). crypto.stanford.edu/~pgolle/papers/census.pdf
3. Michael Barbaro and Tom Zeller Jr., “A Face Is Exposed for AOL Searcher No. 4417749”, The New York Times, 9 August 2006. www.nytimes.com/2006/08/09/technology/09aol.html
4. Arvind Narayanan and Vitaly Shmatikov, “Robust De-anonymization of Large Sparse Datasets”, IEEE Symposium on Security and Privacy, 2008. arxiv.org/abs/cs/0610105
5. Charles Duhigg, “How Companies Learn Your Secrets”, The New York Times Magazine, 16 February 2012. The father anecdote is from an unnamed source. www.nytimes.com/2012/02/19/magazine/shopping-habits.html
6. Alex Hern, “Fitness tracking app Strava gives away location of secret US army bases”, The Guardian, 28 January 2018. www.theguardian.com/world/2018/jan/28/fitness-tracking-app-gives-away-location-of-secret-us-army-bases
7. Mike Schroepfer, “An Update on Our Plans to Restrict Data Access on Facebook”, Meta Newsroom, 4 April 2018 (“up to 87 million people”). about.fb.com/news/2018/04/restricting-data-access
8. US Federal Trade Commission, “FTC Issues Opinion and Order Against Cambridge Analytica For Deceiving Consumers About the Collection of Facebook Data”, 6 December 2019. www.ftc.gov/news-events/news/press-releases/2019/12/ftc-issues-opinion-order-against-cambridge-analytica-deceiving-consumers-about-collection-facebook

Documents, history and redaction

1. Google Docs Editors Help, “Find what’s changed in a file” (version history; who can see it; deleting versions on Workspace editions). support.google.com/docs/answer/190843
2. Google Drive Help, “Delete and restore files in Google Drive” (trash emptied after 30 days). support.google.com/drive/answer/2375102

3. Richard M. Smith, “Microsoft Word bytes Tony Blair in the butt”, 2003 — the revision log of the UK’s February 2003 Iraq dossier (archived copy).
web.archive.org/web/2003/http://www.computerbytesman.com/privacy/blair.htm
4. Zoe Tillman, BuzzFeed News, 8 January 2019, on the improperly redacted filing in *United States v. Manafort*, 1:17-cr-201 (D.D.C.) (archived copy).
web.archive.org/web/2019/https://www.buzzfeednews.com/article/zoetillman/paul-manafort-redacted-konstanin-kilimnik-lying

Accuracy and automated decisions

1. Royal Commission into the Robodebt Scheme, Report, 7 July 2023.
robodebt.royalcommission.gov.au/publications/report
2. Autoriteit Persoonsgegevens, “Tax Administration fined for discriminatory and unlawful data processing”, 7 December 2021. www.autoriteitpersoonsgegevens.nl/en/current/tax-administration-fined-for-discriminatory-and-unlawful-data-processing
3. US Federal Trade Commission, “FTC and CFPB Settlement to Require Trans Union to Pay \$15 Million Over Charges It Failed to Ensure Accuracy of Tenant Screening Reports”, 12 October 2023. www.ftc.gov/news-events/news/press-releases/2023/10/ftc-cfpb-settlement-require-trans-union-pay-15-million-over-charges-it-failed-ensure-accuracy-tenant
4. Fair Credit Reporting Act, 15 U.S.C. § 1681 et seq., § 1681e(b) (accuracy). www.ftc.gov/legal-library/browse/statutes/fair-credit-reporting-act

Enforcement: flows, health, location and purpose

1. US Federal Trade Commission, “FTC Enforcement Action to Bar GoodRx from Sharing Consumers’ Sensitive Health Info for Advertising”, 1 February 2023. www.ftc.gov/news-events/news/press-releases/2023/02/ftc-enforcement-action-bar-goodrx-sharing-consumers-sensitive-health-info-advertising
2. US Federal Trade Commission, “FTC Gives Final Approval to Order Banning BetterHelp from Sharing Sensitive Health Data for Advertising”, 14 July 2023. www.ftc.gov/news-events/news/press-releases/2023/07/ftc-gives-final-approval-order-banning-betterhelp-sharing-sensitive-health-data-advertising
3. US Federal Trade Commission, on the stipulated order settling *FTC v. Kochava* (filed 2022), May 2026. www.ftc.gov/news-events/news/press-releases/2026/05/ftc-ban-kochava-subsiadiary-selling-sensitive-location-data-settle-charges-they-sold-location-data
4. US Federal Trade Commission, “FTC Order Prohibits Data Broker X-Mode Social and Outlogic from Selling Sensitive Location Data”, 9 January 2024. www.ftc.gov/news-events/news/press-releases/2024/01/ftc-order-prohibits-data-broker-x-mode-social-outlogic-selling-sensitive-location-data
5. US Federal Trade Commission, “FTC Finalizes Order with Flo Health”, June 2021. www.ftc.gov/news-events/news/press-releases/2021/06/ftc-finalizes-order-flo-health-fertility-tracking-app-shared-sensitive-health-data-facebook-google

6. US Federal Trade Commission, “FTC Charges Twitter with Deceptively Using Account Security Data to Sell Targeted Ads”, 25 May 2022. www.ftc.gov/news-events/news/press-releases/2022/05/ftc-charges-twitter-deceptively-using-account-security-data-sell-targeted-ads
7. US Federal Trade Commission, “FTC Finalizes Changes to the Health Breach Notification Rule”, 26 April 2024 (effective 29 July 2024). www.ftc.gov/news-events/news/press-releases/2024/04/ftc-finalizes-changes-health-breach-notification-rule

Sensitive contexts

1. US Federal Trade Commission, “Fortnite Video Game Maker Epic Games to Pay More Than Half a Billion Dollars over FTC Allegations”, 19 December 2022. www.ftc.gov/news-events/news/press-releases/2022/12/fortnite-video-game-maker-epic-games-pay-more-half-billion-dollars-over-ftc-allegations
2. US Federal Trade Commission, COPPA Rule amendments, 16 CFR Part 312 (published April 2025; effective 23 June 2025). www.ftc.gov/legal-library/browse/federal-register-notices/16-cfr-part-312-coppa-final-rule-amendments
3. Autoriteit Persoonsgegevens, “Dutch DPA imposes a fine on Clearview because of illegal data collection for facial recognition”, 3 September 2024. www.autoriteitpersoonsgegevens.nl/en/current/dutch-dpa-imposes-a-fine-on-clearview-because-of-illegal-data-collection-for-facial-recognition
4. Illinois Biometric Information Privacy Act, 740 ILCS 14 (amended 2024). www.ilga.gov/legislation/ilcs/ilcs3.asp?ActID=3004&ChapterID=57
5. European Data Protection Board, “Hamburg Commissioner fines H&M 35.3 million euro for data protection violations in service centre”, October 2020. edpb.europa.eu/news/national-news/2020/hamburg-commissioner-fines-hm-353-million-euro-data-protection-violations_it
6. US Federal Trade Commission, “FTC Finalizes Order Banning Stalkerware Provider from Spyware Business”, December 2021. www.ftc.gov/news-events/news/press-releases/2021/12/ftc-finalizes-order-banning-stalkerware-provider-spyware-business
7. Apple and Google, “Detecting Unwanted Location Trackers”, IETF Internet-Draft (DULT working group). datatracker.ietf.org/doc/draft-ledvina-apple-google-unwanted-trackers

Consent and asking

1. Mike Evangelist's first-person account of the iDVD “Burn” whiteboard, The Guardian, January 2006; retold in Greg McKeown, *Effortless* (2021). One participant's recollection.
2. Flurry Analytics, “iOS 14.5 Opt-in Rate — Daily Updates Since Launch”, 2021 (measures differ by method and date). www.flurry.com/blog/att-opt-in-rate-monthly-updates
3. Autorité de la concurrence, “Targeted advertising: the Autorité imposes a fine of €150,000,000 on Apple”, 31 March 2025. www.autoritedelaconcurrence.fr/en/press-release/targeted-advertising-autorite-de-la-concurrence-imposes-fine-eu150000000-apple

4. Autorità Garante della Concorrenza e del Mercato, case A561 (Apple App Tracking Transparency), December 2025. en.agcm.it/en/media/press-releases/2025/12/A561
5. Bundeskartellamt, Apple App Tracking Transparency proceeding closed with commitments, 17 August 2026.
www.bundeskartellamt.de/SharedDocs/Meldung/EN/Pressemitteilungen/2026/08_17_2026_Apple_ATTF.html
6. Helen Nissenbaum, “Privacy as Contextual Integrity”, Washington Law Review 79 (2004) 119; and Privacy in Context (Stanford University Press, 2010). digitalcommons.law.uw.edu/wlr/vol79/iss1/10

Law, standards and frameworks

1. Regulation (EU) 2016/679 (General Data Protection Regulation), Arts. 5, 8, 12–22, 28, 33–35 and Chapter V. eur-lex.europa.eu/eli/reg/2016/679/oj
2. Commission Implementing Decision (EU) 2021/914 on standard contractual clauses. eur-lex.europa.eu/eli/dec_impl/2021/914/oj
3. General Court, Latombe v Commission, T-553/23, 3 September 2025 (EU–US Data Privacy Framework upheld; under appeal). eur-lex.europa.eu/legal-content/EN/TXT/?uri=celex%3A62023TJ0553
4. European Data Protection Board, Guidelines 9/2022 on personal data breach notification under GDPR, version 2.0, 2023. www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-92022-personal-data-breach-notification-under_en
5. California Privacy Protection Agency, CCPA regulations. coppa.ca.gov/regulations
6. California Privacy Protection Agency, approval of regulations on automated decision-making technology, risk assessments and cybersecurity audits, 23 September 2025.
coppa.ca.gov/announcements/2025/20250923.html
7. US Department of Health and Human Services, HIPAA Breach Notification Rule, 45 CFR 164.400–414. www.hhs.gov/hipaa/for-professionals/breach-notification/index.html
8. Regulation (EU) 2024/1689 (Artificial Intelligence Act), Art. 14 (human oversight of high-risk systems). eur-lex.europa.eu/eli/reg/2024/1689/oj/eng
9. LINDDUN privacy threat modeling framework, DistriNet, KU Leuven — threat types.
linddun.org/threat-types
10. OpenLineage specification (LF AI & Data), object model. openlineage.io/docs/spec/object-model
11. NIST SP 800-88 Revision 2, Guidelines for Media Sanitization, September 2025 (cryptographic erase). nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-88r2.pdf

Authentication

1. W3C, Web Authentication: An API for accessing Public Key Credentials, Level 3.
www.w3.org/TR/webauthn-3

2. FIDO Alliance, Passkeys. fidoalliance.org/passkeys
3. NIST SP 800-63B-4, Digital Identity Guidelines: Authentication and Authenticator Management, 2025. csrc.nist.gov/pubs/sp/800/63/b/4/final
4. CISA, “Implementing Number Matching in MFA Applications”, fact sheet, October 2022. www.cisa.gov/sites/default/files/publications/fact-sheet-implement-number-matching-in-mfa-applications-508c.pdf

AI and machine learning

1. Nicholas Carlini et al., “Extracting Training Data from Large Language Models”, USENIX Security Symposium, 2021. www.usenix.org/conference/usenixsecurity21/presentation/carlini-extracting
2. Nicholas Carlini et al., “Quantifying Memorization Across Neural Language Models”, ICLR 2023. openreview.net/pdf?id=TatRHT_1cK
3. Milad Nasr et al., “Scalable Extraction of Training Data from (Production) Language Models”, 2023. arxiv.org/abs/2311.17035
4. Reza Shokri et al., “Membership Inference Attacks Against Machine Learning Models”, IEEE Symposium on Security and Privacy, 2017. arxiv.org/abs/1610.05820
5. John X. Morris et al., “Text Embeddings Reveal (Almost) As Much As Text”, EMNLP 2023. aclanthology.org/2023.emnlp-main.765
6. Lucas Bourtole et al., “Machine Unlearning”, IEEE Symposium on Security and Privacy, 2021. arxiv.org/abs/1912.03817
7. A. Feder Cooper et al., “Machine Unlearning Doesn’t Do What You Think”, 2024. arxiv.org/abs/2412.06966
8. OWASP, Top 10 for LLM Applications 2025 (LLM02 Sensitive Information Disclosure, LLM06 Excessive Agency, LLM08 Vector and Embedding Weaknesses). genai.owasp.org/llm-top-10
9. NIST AI 100-1, Artificial Intelligence Risk Management Framework 1.0, January 2023. nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf
10. NIST AI 600-1, Generative Artificial Intelligence Profile, July 2024. nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

Connected homes, assistants and devices

1. TechCrunch, “Amazon’s Echo will send all voice recordings to the cloud, starting March 28”, 15 March 2025 (Amazon’s email to customers, as reported; the option existed only on three Echo models, in the US, in English). techcrunch.com/2025/03/15/amazons-echo-will-send-all-voice-recordings-to-the-cloud-starting-march-28
2. Amazon Customer Service, “Delete Alexa Voice Recordings and Transcripts Automatically” (accessed September 2026). www.amazon.com/gp/help/customer/display.html?nodeId=G68KUKTXN92WY3C3

3. Amazon Customer Service, “What Is Amazon Family?” (accessed September 2026). www.amazon.com/gp/help/customer/display.html?nodeId=GXULX24SE2RD7EXS
4. Google Assistant Help, “Turn on voice recognition with Voice Match” (accessed September 2026): “A voice that sounds like yours might be able to access your personal results.” support.google.com/assistant/answer/9071681
5. Google Home and Nest Help, “Control your privacy on your shared devices with Guest Mode” (accessed September 2026). support.google.com/googlehome/answer/10217706
6. Apple Support, “Set up voice recognition on HomePod or HomePod mini” (accessed September 2026). support.apple.com/en-us/108397
7. Apple Newsroom, “Our longstanding privacy commitment with Siri”, 8 January 2025 (audio processed on device “whenever possible”). www.apple.com/newsroom/2025/01/our-longstanding-privacy-commitment-with-siri
8. Apple Support, “Share control of your home” (accessed September 2026). support.apple.com/en-us/102386
9. Apple Support, “Unlock your door with a home key on iPhone or Apple Watch” (accessed September 2026; Express Mode unlocks without Face ID or Touch ID). support.apple.com/guide/iphone/unlock-door-a-home-key-iphone-apple-watch-iph0dc255875/ios
10. Connectivity Standards Alliance, “All about choice: Multi-Admin in Matter gives users more flexibility and unlocks smart home innovation” (accessed September 2026). Each ecosystem is a separate fabric with its own credentials and access list; state, events and commands cross, not audio. csa-iot.org/newsroom/all-about-choice-multi-admin-in-matter-gives-users-more-flexibility-and-unlocks-smart-home-innovation
11. Amazon Alexa Skills Kit, “Account Linking for Smart Home and Other Domains” (accessed September 2026); Google Home cloud-to-cloud integrations also use OAuth 2.0 authorization-code linking. developer.amazon.com/en-US/docs/alexa/account-linking/account-linking-for-sh-and-other.html
12. US Federal Trade Commission, “FTC and DOJ Charge Amazon with Violating Children's Privacy Law by Keeping Kids' Alexa Voice Recordings Forever and Undermining Parents' Deletion Requests”, 31 May 2023 (\$25M civil penalty; order entered 19 July 2023; settled allegations). www.ftc.gov/news-events/news/press-releases/2023/05/ftc-doj-charge-amazon-violating-childrens-privacy-law-keeping-kids-alexa-voice-recordings-forever
13. US Federal Trade Commission, “FTC Says Ring Employees Illegally Surveilled Customers, Failed to Stop Hackers from Taking Control of Users' Cameras”, 31 May 2023 (\$5.8M for consumer refunds; order entered 16 June 2023; settled allegations). www.ftc.gov/news-events/news/press-releases/2023/05/ftc-says-ring-employees-illegally-surveilled-customers-failed-stop-hackers-taking-control-users
14. Lopez v. Apple Inc., No. 4:19-cv-04577 (N.D. Cal.), settlement notice, 2025 (\$95M over unintended Siri activations; Apple denies wrongdoing; final approval October 2025). angeion-public.s3.amazonaws.com/www.lopezvoiceassistantsettlement.com/docs/Apple%20Lopez_Long%20Form%20Notice_FINAL.pdf

5. TechCrunch, “Google says Nest’s secret microphone was ‘never intended to be a secret’”, 20 February 2019. techcrunch.com/2019/02/20/nest-secret-microphone
6. US Federal Trade Commission, “Policy Statement of the Federal Trade Commission on Biometric Information and Section 5 of the FTC Act”, 18 May 2023. www.ftc.gov/legal-library/browse/policy-statement-federal-trade-commission-biometric-information-section-5-federal-trade-commission
7. New York City Department of Housing Preservation and Development, “Tenant Data Privacy Law” (Local Law 63 of 2021): consent for data used to grant entry, destruction deadlines, and bans on tracking tenants outside the building, their relationships or their guests. www.nyc.gov/site/hpd/services-and-information/tenant-data-privacy-law.page
8. US Federal Trade Commission, “VIZIO to Pay \$2.2 Million to FTC, State of New Jersey to Settle Charges It Collected Viewing Histories on 11 Million Smart Televisions without Users’ Consent”, 6 February 2017. www.ftc.gov/news-events/news/press-releases/2017/02/vizio-pay-22-million-ftc-state-new-jersey-settle-charges-it-collected-viewing-histories-11-million
9. Matteo Franceschetti (Eight Sleep CEO), post on X during the AWS outage of 20 October 2025; an offline “outage mode” followed within days. x.com/m_franceschetti/status/1980419272766583262
10. Amazon, “Amazon Sidewalk Privacy and Security Whitepaper” (accessed September 2026). www.amazon.com/gp/help/customer/display.html?nodeId=GRGWE27XHZPRPBGX

Networks, monitoring and public places

1. US Federal Trade Commission, “Are Public Wi-Fi Networks Safe? What You Need To Know” (accessed September 2026): “because of the widespread use of encryption, connecting through a public Wi-Fi network is usually safe.” consumer.ftc.gov/articles/are-public-wi-fi-networks-safe-what-you-need-know
2. IETF, RFC 6973, “Privacy Considerations for Internet Protocols”, July 2013 (traffic analysis works on encrypted flows: presence, timing, volume, direction). www.rfc-editor.org/rfc/rfc6973
3. IETF, RFC 8484, “DNS Queries over HTTPS (DoH)”, October 2018; and RFC 7858, “DNS over TLS”, May 2016. www.rfc-editor.org/rfc/rfc8484
4. IETF, RFC 9849, “TLS Encrypted Client Hello”, March 2026 (it does not hide the server if DNS is unencrypted or the address gives it away). www.rfc-editor.org/rfc/rfc9849.html
5. Apple Support, “Use private Wi-Fi addresses on Apple devices”; Android Open Source Project, “MAC randomization behavior” (both accessed September 2026). support.apple.com/en-us/102509
6. IETF, RFC 8910, “Captive-Portal Identification in DHCP and Router Advertisements”, and RFC 8908, “Captive Portal API”, September 2020. www.rfc-editor.org/info/rfc8910
7. IETF, RFC 6762, “Multicast DNS”, and RFC 6763, “DNS-Based Service Discovery”, February 2013. www.rfc-editor.org/rfc/rfc6762
8. US National Security Agency, “Securing Wireless Devices in Public Settings”, July 2021 (devices reconnect to known network names; an “evil twin” can use the same name). media.defense.gov/2021/Jul/29/2002815141/-1/-1/0/CSI_SECURING_WIRELESS_DEVICES_IN_PUBLIC.PDF

9. American Library Association, “Library Privacy Guidelines for Public Access Computers and Networks”. www.ala.org/advocacy/privacy/guidelines/public-access-computer
10. UK Information Commissioner’s Office, “Employment practices and data protection: monitoring workers”, October 2023. ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/employment/monitoring-workers
11. Center for Democracy & Technology, “Off Task: EdTech Threats to Student Privacy and Equity in the Age of AI”, September 2023. cdt.org/wp-content/uploads/2023/09/091923-CDT-Off-Task-web.pdf
12. Apple Platform Deployment, “Global HTTP Proxy device management payload settings for Apple devices” (accessed September 2026). support.apple.com/guide/deployment/global-http-proxy-payload-settings-dep7ba46fcd/web
13. US Federal Communications Commission, “What is ‘Juice Jacking’ and Tips to Avoid It” (the FCC notes it is not aware of confirmed cases; check the current page). www.fcc.gov/juice-jacking-tips-to-avoid-it
14. Florian Draschbacher et al., “ChoiceJacking: Compromising Mobile Devices through Malicious Chargers like a Decade ago”, USENIX Security Symposium, August 2025. www.usenix.org/conference/usenixsecurity25/presentation/draschbacher
15. US Federal Communications Commission, “Protecting Consumers from SIM Swap and Port-Out Fraud”, Report and Order FCC 23-95, November 2023. docs.fcc.gov/public/attachments/FCC-23-95A1.pdf

Cars, devices and their lifecycle

1. US Federal Trade Commission, “FTC Finalizes Order Settling Allegations that GM and OnStar Collected and Sold Geolocation Data Without Consumers’ Informed Consent”, January 2026. www.ftc.gov/news-events/news/press-releases/2026/01/ftc-finalizes-order-settling-allegations-gm-onstar-collected-sold-geolocation-data-without-consumers
2. US Federal Trade Commission, “Renting a Car” (consumer advice first published August 2016): delete paired-device data before returning a car. consumer.ftc.gov/articles/renting-car
3. CNN Money, “Why buying used cars could put your safety at risk”, 17 February 2017 (IBM X-Force’s Charles Henderson, RSA Conference 2017). money.cnn.com/2017/02/17/technology/used-car-hack-safety-location
4. Sam Curry and Shubham Shah, “Hacking Subaru: Tracking and Controlling Cars via the STARLINK Admin Panel”, 23 January 2025 (found November 2024 and fixed within a day). samcurry.net/hacking-subaru
5. ESET WeLiveSecurity, “Discarded, not destroyed: Old routers reveal corporate secrets”, 18 April 2023 (9 of 16 second-hand enterprise routers; a small sample). www.welivesecurity.com/2023/04/18/discarded-not-destroyed-old-routers-reveal-corporate-secrets
6. The Register, “Insteon’s vanishing act explained: Smart home biz insolvent”, 22 April 2022. www.theregister.com/2022/04/22/insteon_shutdown_explained

7. US Federal Trade Commission, closing letter to Nest Labs regarding Revolv, 7 July 2016. www.ftc.gov/system/files/documents/closing_letters/nid/160707nestrevolvletter.pdf
8. UK Department for Science, Innovation and Technology, “The UK Product Security and Telecommunications Infrastructure (Product Security) regime”, in force 29 April 2024. www.gov.uk/government/publications/the-uk-product-security-and-telecommunications-infrastructure-product-security-regime
9. Regulation (EU) 2024/2847 (Cyber Resilience Act): in force 10 December 2024; reporting duties from 11 September 2026; main obligations from 11 December 2027. eur-lex.europa.eu/eli/reg/2024/2847/oj/eng
10. US Federal Trade Commission, “Digital Copier Data Security: A Guide for Businesses”, December 2010. www.ftc.gov/business-guidance/resources/digital-copier-data-security-guide-businesses

Households, abuse and assistants that act

1. Nellie Bowles, “Thermostats, Locks and Lights: Digital Tools of Domestic Abuse”, The New York Times, 23 June 2018. www.nytimes.com/2018/06/23/technology/smart-home-devices-domestic-abuse.html
2. Diana Freed et al., “‘A Stalker’s Paradise’: How Intimate Partner Abusers Exploit Technology”, ACM CHI 2018. dl.acm.org/doi/10.1145/3173574.3174241
3. Apple Personal Safety User Guide, “Safety Check for an iPhone with iOS 16 or later” (accessed September 2026). support.apple.com/guide/personal-safety/safety-check-iphone-ios-16-ips2aad835e1/web
4. Apple Support, “Use Universal Clipboard to copy and paste between your Apple devices” (accessed September 2026). support.apple.com/en-us/102430
5. Apple Support, “iPhone Mirroring: Use your iPhone from your Mac” (accessed September 2026; iPhone notifications appear on the Mac). support.apple.com/en-us/120421
6. Apple Support, “Add content to an iCloud Shared Photo Library on iPhone” (accessed September 2026). support.apple.com/guide/iphone/add-content-to-an-icloud-shared-photo-library-iphc6c5d25ce/ios
7. Apple Support, “Share your location with your Family Sharing group” (accessed September 2026). support.apple.com/en-us/105107
8. Google Account Help, “About Inactive Account Manager”; Apple Support, “How to add a Legacy Contact for your Apple Account” (both accessed September 2026). support.google.com/accounts/answer/3036546
9. Ben Nassi, Stav Cohen and Or Yair, “Invitation Is All You Need! Promptware Attacks Against LLM-Powered Assistants in Production Are Practical and Dangerous”, arXiv 2508.12175, August 2025 (disclosed to Google in February 2025). arxiv.org/abs/2508.12175
10. Google Security Blog, “Mitigating prompt injection attacks with a layered defense strategy”, June 2025. blog.google/security/mitigating-prompt-injection-attacks

1. Amazon, “Introducing Alexa+, the next generation of Alexa”, 26 February 2025.
www.aboutamazon.com/news/devices/new-alexa-generative-artificial-intelligence
2. Google Home and Nest Help, “Manage & delete your Gemini for Home activity” (accessed September 2026). support.google.com/googlehome/answer/16613583

Accounts, sessions and takeover

1. Apple Support, “What is an Apple Account?” (accessed September 2026): one Apple Account for all Apple services, holding the contact, payment and security details used across them.
support.apple.com/en-us/105023
2. Google Account Help, “Create a Google Account” (accessed September 2026): a Google Account gives Google-wide access to most Google products. support.google.com/accounts/answer/15277265
3. Apple Security Research, “Private Cloud Compute: A new frontier for AI privacy in the cloud”, 10 June 2024. security.apple.com/blog/private-cloud-compute
4. Apple Support, “Apple Pay security and privacy overview” (accessed September 2026).
support.apple.com/en-us/101554
5. Apple Support, “How to turn on Advanced Data Protection for iCloud” (accessed September 2026). Advanced Data Protection is optional; availability varies by country. support.apple.com/en-us/108756
6. Google Privacy Policy (accessed September 2026): “We may combine the information we collect among our services and across your devices”. Linking some services needs consent in the EU and EEA. policies.google.com/privacy
7. Google Search Help, “Find & control your Web & App Activity” (accessed September 2026): Chrome history is saved only if you are signed in to Chrome, syncing history, and include it in Web & App Activity. Configurable; defaults vary. support.google.com/websearch/answer/54068
8. Diane Greene, Google, “As G Suite gains traction in the enterprise, G Suite’s Gmail and consumer Gmail to more closely align”, 23 June 2017. blog.google/products/gmail/g-suite-gains-traction-in-the-enterprise-g-suites-gmail-and-consumer-gmail-to-more-closely-align
9. Google Wallet Help, “Manage data & privacy in Google Wallet” (US only; accessed September 2026). Using Wallet purchases and passes to personalise ads is opt-in, announced November 2025.
support.google.com/wallet/answer/16703349
10. Google Security Blog, “Improving the security of Chrome cookies on Windows”, 30 July 2024 (app-bound encryption). security.googleblog.com/2024/07/improving-security-of-chrome-cookies-on.html
11. Elastic Security Labs, “Katz and Mouse Game: MaaS Infostealers Adapt to Patched Chrome Defenses”, late 2024. www.elastic.co/security-labs/katz-and-mouse-game
12. Google Security Blog, “Protecting Cookies with Device Bound Session Credentials”, April 2026 (generally available on Windows, Chrome 146). security.googleblog.com/2026/04/protecting-cookies-with-device-bound.html
13. Cyberhaven, “Cyberhaven’s Chrome extension security incident and what we’re doing about it”, 27 December 2024. www.cyberhaven.com/blog/cyberhavens-chrome-extension-security-incident-and-

what-were-doing-about-it

4. Sekoia TDR, “Targeted supply chain attack against Chrome browser extensions”, January 2025.
blog.sekoia.io/targeted-supply-chain-attack-against-chrome-browser-extensions
5. Chrome for Developers, “Permissions list” (accessed September 2026): host access to all sites shows the warning “Read and change all your data on all websites”.
developer.chrome.com/docs/extensions/reference/permissions-list
6. Brian Krebs, “Recent ‘MFA Bombing’ Attacks Targeting Apple Users”, KrebsOnSecurity, 26 March 2024. A journalist’s report, not an Apple statement. krebsonsecurity.com/2024/03/recent-mfa-bombing-attacks-targeting-apple-users
7. Apple Support, “Recognize and avoid phishing messages, phony support calls, and other scams” (accessed September 2026). support.apple.com/en-us/102568

Differential privacy

1. Cynthia Dwork and Aaron Roth, *The Algorithmic Foundations of Differential Privacy*, 2014 (basic and advanced composition). www.cis.upenn.edu/~aaroht/Papers/privacybook.pdf
2. Ilya Mironov, “Rényi Differential Privacy”, IEEE CSF, 2017. arxiv.org/abs/1702.07476
3. Mark Bun and Thomas Steinke, “Concentrated Differential Privacy: Simplifications, Extensions, and Lower Bounds”, TCC 2016. arxiv.org/abs/1605.02065
4. US Census Bureau, “Census Bureau Sets Key Parameters to Protect Privacy in 2020 Census Results”, 9 June 2021. www.census.gov/newsroom/press-releases/2021/2020-census-key-parameters.html

Notes

The frameworks in this guide — the three hats, the eight questions and their red flags, the tiers, the lifecycle controls, the enforcement ladder, the breach budget, the history hole, the burn button and the Forget-me button — come from Paddy Iyer’s *Privacy Engineering — A Visual Field Guide* (PaddySpeaks, 2026 edition). Dana, Northstar and every Northstar system, vendor, figure and incident are fictional and synthetic; the Command Center uses the same data. Scores and indexes are simplified models that compare designs; none predicts harm to a real person. Nothing here is legal advice.

Every Arrow Is a Decision · Field guide edition 3.0 · Published 26 September 2026 · Revised 30 September 2026 · 6 chapters · 31 scenes · 42 interactive figures · Full path 97 min · Executive path 13 min